ZIRLANDIA MILKOVIC

THE HIDDEN COST OF AI

Privacy Risks, Data Protection Mistakes and **Compliance Lessons** Every Small Business Should Know



PROTECT YOUR DATA

STAY GDPR COMPLIANT

USE AI SAFELY

BUILD A STRONGER, MORE RESILIENT BUSINESS

GDPRGard

AI COMPLIANCE SUITE FOR EUROPEAN SMBs

A SMALL BUSINESS GUIDE

THE HIDDEN COST OF AI

Privacy Risks, Data Protection Mistakes and Compliance Lessons Every Small Business Should Know

ZIRLANDIA MILKOVIC

PROTECT YOUR DATA · STAY GDPR COMPLIANT · USE AI SAFELY

The Hidden Cost of AI

Privacy Risks, Data Protection Mistakes and Compliance Lessons Every Small Business Should Know

© 2026 Zirlandia Milkovic. All rights reserved. No part of this book may be reproduced, stored or transmitted in any form without written permission, except for brief quotations in reviews and for copying the checklists, templates and policy text for your own business use. Published in association with GDPRGard (https://gdprgard.eu/).

EDUCATIONAL USE ONLY. This book is a general educational guide to data protection, cybersecurity and AI risk for small businesses in Europe. It is not legal advice, not a professional cybersecurity service and not a compliance assessment. It does not create a lawyer-client or consultant-client relationship, it cannot take your individual circumstances into account, and the author is not presented as a lawyer, a certified data protection officer or a regulator. Reading this book, using its templates or completing its checklists does not make a business compliant with the GDPR or any other law, is not a certification or audit, and does not prevent cyberattacks or guarantee any outcome in an investigation, complaint, claim or incident.

THE LAW MOVES. Legal research for this edition closed on 24 October 2026. Data protection, cybersecurity and AI law, regulator guidance, court decisions and provider terms change often, and national rules differ between countries. Check the sources listed in Appendix M and the Sources section, and take advice from a qualified professional before relying on anything here for a decision with real consequences.

Product and company names belong to their owners and are used only for identification and education. This independent book is not affiliated with, sponsored or endorsed by any of them. The DATA SHIELD METHOD is an original practical framework created for this book. It is not an official regulatory standard.

All people, businesses and incidents in the scenarios and case studies are hypothetical, invented to illustrate ideas. They are not real enforcement cases.

Kindle Edition 2026 · Legal research cut-off: 24 October 2026

Contents

Info Educational and Legal Disclaimer 6
Bio A Note From the Author 7
Intro The Price We Don't See 8
Use How to Use This Book 12

PART I **The Hidden Risks**

01 The Hidden Cost Behind the AI Revolution 16
02 What Happens to Your Data When You Use AI? 24
03 The Everyday AI Privacy Mistakes Businesses Make 32

PART II **Law, Vendors and People**

04 GDPR and AI: What Every Small Business Needs to Understand 42
05 The AI Vendor Trap: Choosing Tools Without Exposing Your Business 51
06 Employees, Shadow AI and the Human Factor 60

PART III **Where AI Touches Customers, Staff and Systems**

07 Customer Data, Marketing and AI Personalisation 68
08 AI in HR: When Efficiency Creates Human Risk 77
09 Cybersecurity Risks You Cannot Afford to Ignore 85

PART IV **When Things Go Wrong**

10 When AI Causes a Data Breach 94
11 The EU AI Act: Understanding Your Business Obligations 103
12 The Real Cost of Getting AI Privacy Wrong 113

PART V **Your Framework**

13 Build Your Small Business AI Privacy Framework 122
14 The 30-Day AI Privacy Action Plan 132
End Use AI Without Losing Control 141

THE AI PRIVACY TOOLKIT: TWELVE COPY-READY TEMPLATES

T1 AI Tool and Use-Case Inventory 143
T2 AI Privacy Risk Assessment Checklist 145
T3 AI Vendor Due-Diligence Questionnaire 146
T4 Employee AI Acceptable-Use Policy Template 148
T5 Personal Data Classification Guide 149

T6 AI Privacy Incident-Response Checklist 150
T7 AI-Related Data Breach Decision Checklist 153
T8 DPIA Screening Questionnaire 154
T9 AI Privacy Notice Review Checklist 155
T10 Monthly AI Governance Review 156
T11 Small Business AI Privacy Maturity Scorecard 157
T12 30-Day AI Privacy Implementation Tracker 158
G Glossary of Essential Terms 159
Ref Sources 162
Bio About the Author and GDPRGard 167

Educational and Legal Disclaimer

Please read this page before you use anything else in the book.

This book is an educational publication. It explains, in plain English, how data protection law, cybersecurity practice and artificial intelligence (AI) fit together for small businesses in Europe. It is **not legal advice**, it is not a professional cybersecurity service, and it is not a formal compliance assessment. It cannot take account of the facts of your business.

The author is not presented as a lawyer, a certified data protection officer (DPO) or a regulator. Nothing here has been endorsed or approved by any supervisory authority, the European Commission, the European Data Protection Board (EDPB), ENISA or any technology provider, and neither the book, the author nor GDPRGard claims any such endorsement, certification or approval. Completing a checklist, adopting a template or following the Five-Step AI Privacy Loop does **not** make a business compliant with the General Data Protection Regulation (GDPR) or the EU AI Act, and it does not prevent cyberattacks or guarantee any outcome in an incident, complaint or investigation.

Four things can change after publication:

- **The law and its dates.** Legal research for this edition closed on **25 October 2026**. The EU AI Act was amended by Regulation (EU) 2026/1744 in July 2026, which moved several dates. The changes to the GDPR proposed in the Commission's "Digital Omnibus" were, as far as the research found, still going through the EU legislative process at that date. The Sources section says what to re-check.
- **Guidance and court decisions.** Regulators update their guidance and courts decide new cases.
- **Provider terms.** Technology providers change their terms, settings and plans, often without notice. Always read the current terms of the specific service you use. This book makes no claim about what any named provider does.
- **National rules.** The GDPR applies across the EU and the European Economic Area (EEA), but national laws on employment, health, cookies, children's data and breach reporting differ, and every supervisory authority publishes its own guidance.

The book is written for small organisations that operate in the EU or EEA. Where something applies only in the United Kingdom, the text says so. Where it says "the GDPR" without qualification, it means Regulation (EU) 2016/679.

Every case study and scenario is **hypothetical**, invented to illustrate an idea, and is labelled as such. No real incident, penalty, statistic or quotation has been made up, and none of the cost figures in Chapter 12 is a measurement: they are worked illustrations with stated assumptions. Where the book relies on a source, it gives a number in square brackets, such as [1], that points to the Sources section. The last column there says how each source was checked, so you can see what still needs verification.

> **WATCH OUT** **When to get professional help**
>
> Take specialist advice before you rely on this book for a decision about special-category data, children's data, employee monitoring, recruitment or other automated decisions about people, large-scale profiling, transfers of data outside Europe, a suspected personal data breach that may put people at risk, or a significant contract with a technology supplier.

A Note From the Author

Why this book exists, and what it is meant to do for you.

I wrote this book for the person who runs a business and also happens to be the person who answers the privacy emails, resets the passwords and wonders whether the new AI tool is safe to use with customer data. Most of the guidance available to them is written either for lawyers or for large companies with compliance teams. Neither is much use at five o'clock on a Thursday, when a colleague asks, "Can I paste this into the chatbot?"

AI is one of the most useful tools small businesses have been offered in a generation. This is not a book against it. It is a book about the part of the bill that does not appear on the invoice: the personal data that can slip out, the contracts that can be breached, the decisions about people that can go wrong, and the trust that can be lost, all because a good tool was adopted faster than the rules around it.

My aim is to make privacy and data protection **understandable and actionable**. That means plain language, honest limits and many practical steps. It also means admitting what I cannot promise. No book can make you compliant, and no checklist can make you secure. What a good guide can do is help you see your risks clearly, spend limited time on what matters most, and build habits that make a mistake less likely and less costly.

The book is published in association with **GDPRGard**, an AI compliance suite for European small and medium-sized businesses (https://gdprgard.eu/). Where a GDPRGard resource may help, I say so briefly. Everything in this book is meant to be useful without buying anything.

If you take one thing from these pages, let it be this: **you do not have to choose between using AI and protecting the people behind your data.**

Zirlandia Milkovic

INTRODUCTION

INTRODUCTION

AI

The Price We Don't See

AI saves time at the till. The cost arrives later, in places nobody was looking.

IN THIS CHAPTER

- Why AI can create hidden risk even when everyone means well
- The central message of the book, and what it is not saying
- Who the book is for and how it is organised
- The Five-Step AI Privacy Loop

HYPOTHETICAL EXAMPLE **Hypothetical scenario: a helpful Tuesday**

Ines runs Ember & Oak, an online homeware shop with eleven employees. In March she told the team to "use AI wherever it saves time". It has. Product descriptions that took an afternoon now take twenty minutes. On a Tuesday in June, Luka, who looks after customer service, has 400 unanswered complaints. He exports them from the helpdesk, with customer names, home addresses, phone numbers and order histories, and uploads the file to a free AI chatbot on his personal account. "Find the common themes and draft replies," he types. Ninety seconds later he has an excellent summary and a stack of polite replies. He is proud of the saving. That same week, Ines's bookkeeper pastes a supplier contract into a different AI tool "to check the payment terms", and a new marketing hire installs a browser extension that promises to "summarise any page". The extension can read everything on every page she visits, including the shop's admin panel. Nothing bad happens that week. Nothing bad may ever happen. But Ember & Oak now has customer personal data in a service nobody approved, a confidential contract in a second, and an extension with wide access to a third. It has no record of any of it, no idea what each provider does with the data, and nobody who would recognise a problem if one began.

None of this is exotic, and none of it was malicious. Every person in that story was trying to do the job faster. This is exactly why the cost is hidden: it does not look like a mistake at the time. It looks like productivity.

It is also **hypothetical**, and the book does not claim that harm is inevitable. Much of the time, nothing visible follows. The point is that the business above has lost control of its information without anyone deciding to let it go, and has no way of knowing what follows from that.

Why AI creates hidden risk

AI tools differ from ordinary software in ways that matter for privacy. They invite you to type or upload whole documents, because that is how they work best. They are easy to reach: a free account takes a minute. They are often provided by organisations in other countries, with long chains of suppliers behind them. Their outputs can look authoritative while being wrong, and they can be connected to your email, files and customer systems in a few clicks. None of these features is a flaw. Together, they mean that **a decision that feels small can move a lot of personal and confidential information to somewhere the business has never examined.**

The message of this book

AI IS NOT UNSAFE BY NATURE. UNGOVERNED AI IS.

The risk comes from not knowing what is used, what goes into it, who handles it and who is accountable. All of those can be managed, mostly with modest effort and no special budget.

The book is **not** trying to discourage you from adopting AI. It does not say that using AI breaches the GDPR, because it does not: whether a particular use is lawful depends on the data, the purpose, the safeguards and the supplier. It does not predict disasters or quote frightening statistics. Where it makes a legal claim, it cites the provision. Where something depends on the facts, it says so and tells you when to ask a professional.

Who this book is for

Small business owners, entrepreneurs, startup founders, ecommerce operators, consultants, marketing agencies, HR professionals, freelancers and managers who use AI tools or are about to. You do not need a legal, technical or security background. Privacy professionals may still find the checklists, templates and legal references useful as a starting point.

Three questions in every chapter

Every chapter answers the same three questions, and opens with a short card that previews them:

What is the risk?
The specific way things go wrong, in plain English.

Why should a small business care?
The legal, financial, operational and trust consequences, kept in proportion.

What can I do about it?
Concrete steps, checklists and templates you can use this week.

Figure 1 The three questions

The Five-Step AI Privacy Loop

To keep the many moving parts in one picture, the book uses an original framework called the **Five-Step AI Privacy Loop**. It is a practical way of ordering your work. It is **not** an official standard and it does not appear in any law or regulator's guidance.

01
Map
Find out which AI tools are used, by whom, for what, and which data they touch. You cannot manage what you cannot see.

02
Minimise
Share the least that the task needs. Remove or replace what identifies people. Say no to what should never go in.

03
Vet
Check the tool and the supplier before you rely on them: terms, retention, training, security, contracts, transfers.

04
Govern
Write simple rules, name owners, train people, keep records, and decide in advance how decisions about people are reviewed.

05
Respond
Be ready for an incident, a request from a customer or employee, a regulator's question, and the next review, then start the loop again.

Figure 2 The Five-Step AI Privacy Loop

The loop is a loop because AI changes quickly: new tools appear, providers change their terms, and your own use grows. Every chapter says which steps it supports.

SOURCE NOTE **Law, guidance and good practice**

This book separates five kinds of statement. **Binding law** is what legislation and court judgments require. **Regulatory guidance** is what regulators such as the EDPB say about how they read the law: persuasive, not itself law. **Industry standards and frameworks**, such as those from NIST, ISO and OWASP, are good practice and not obligations. **Author recommendations** are the book's own suggestions. **Hypothetical examples** are invented. The callouts "What the law says" and "Good practice" appear where the difference matters.

HOW TO USE THIS BOOK

GUIDE

AI

How to Use This Book

Three ways to read it, and how the chapters fit together.

IN THIS CHAPTER

- How the five parts and fourteen chapters are organised
- What each chapter contains
- How to read the book in an hour, a week or a month
- How the toolkit and templates are meant to be used

You can read this book from start to finish, but you do not have to. The structure lets you go straight to what you need.

The structure at a glance

Five parts, fourteen chapters

Part	What it does	Chapters
I. The Hidden Risks	Shows the costs, what happens to your data, and the mistakes that cause most problems.	1 to 3
II. Law, Vendors and People	Explains the GDPR in plain English, how to choose tools, and how to handle shadow AI.	4 to 6
III. Where AI Touches Customers, Staff and Systems	Covers marketing, HR and cybersecurity.	7 to 9
IV. When Things Go Wrong	Covers breaches, the EU AI Act and the real cost of getting it wrong.	10 to 12
V. Your Framework	Gives you a system you can maintain, and a 30-day plan to start it.	13 and 14
Toolkit	Twelve copy-ready templates, a glossary and the sources.	T1 to T12

What each chapter contains

1. **The three questions.** What is the risk, why a small business should care, and what you can do.
2. **The Five-Step AI Privacy Loop note.** Which steps the chapter supports.
3. **Explanation in plain English.** Terms defined the first time they appear, and legal references where they matter.
4. **Case studies.** Hypothetical, clearly labelled, and analysed the same way each time.
5. **Figures and tables.** Diagrams, comparison tables, decision trees and checklists.
6. **What to do today.** One action you can finish before the day ends.
7. **Summary and key sources.** The main points and numbered references.

Reading it your way

Three ways to use the book

If you have...	Do this
One hour	Read the Introduction, then Chapters 2, 3 and 6. Complete the first three tasks of the plan in Chapter 14 and write your one-page AI rule from Tool 4.
One week	Read Parts I and II, then fill in the inventory (Tool 1) and the vendor questionnaire (Tool 3) for the AI tools you already use.
One month	Follow the 30-day plan in Chapter 14, reading each chapter as the plan reaches it, and use the tracker in Tool 12.

Using the toolkit

Twelve templates at the end of the book are designed to be copied, edited and kept. They are **starting points**. They must be adapted to your business, your countries of operation and your risks, and they do not by themselves establish legal compliance. The PDF edition has fillable fields so you can type directly into the forms.

WHAT TO DO TODAY **What to do today**

Before you read further, open a blank document and title it "AI tools we use". Write down every AI tool you can think of that someone in your business has used in the last month, including free accounts, browser extensions and AI features inside software you already pay for. You will use this list in Chapter 1.

PART

I

The Hidden Risks

What AI really costs a small business, what happens to your data when you use it, and the everyday mistakes that cause most of the trouble.



PART I · THE HIDDEN RISKS

CHAPTER

01

The Hidden Cost Behind the AI Revolution

The visible price of AI is a subscription. The hidden price is paid in exposed data, weak contracts, wrong answers and lost trust.

IN THIS CHAPTER

- The seven hidden costs of adopting AI without safeguards
- Direct financial costs versus operational, legal and reputational ones
- Why the same tool can be low risk in one use and high risk in another
- A first look at your own AI use

What is the risk?
Personal data, confidential information and decisions about people end up in places the business has not examined.

Why should a small business care?
The costs are mostly indirect and arrive late: legal duties, broken contracts, wrong output and lost trust.

What can I do about it?
List the AI in use, rate each use by data and consequence, and fix the high-rated ones first.

Figure 3 The three questions for this chapter

SOURCE NOTE **Five-Step AI Privacy Loop · Map**

This chapter is about the first step. You cannot manage costs you cannot see, and you cannot see AI use you have not listed.

HYPOTHETICAL EXAMPLE **Hypothetical scenario: the two quotes**

A small recruitment consultancy compares two ways of writing candidate summaries. By hand, each summary takes 25 minutes. With an AI tool, it takes five. The saving is obvious, easy to measure and appears in the first week. What does not appear is the question nobody asked: where do the candidates' CVs go when they are pasted in, who can read them, how long are they kept, and were the candidates ever told? The consultancy's privacy notice says nothing about AI. None of this is on the invoice, so none of it is in the decision.

The risk: the cost that does not appear on the invoice

When a business adopts an AI tool, the costs it notices are the ones that are easy to count: the subscription, the hours saved, perhaps some training. The costs it does not notice are real but harder to see because they are **conditional** (they only arrive if something goes wrong), **delayed** (they arrive months after the decision) and **spread across departments** (they land on the owner, the lawyer, the customer service desk and the person who has to apologise).

This book is about those costs. They are not reasons to avoid AI. They are the reasons to adopt it with your eyes open.

Seven hidden costs

The seven hidden costs of ungoverned AI

Cost	What it looks like in a small business	Who feels it
1. Personal data exposure	Customer or employee details entered into tools nobody has approved, shared in prompts, uploads or integrations	The people the data describes, then the business
2. Confidential information leakage	Contracts, pricing, plans or client files shared with a service that may keep or process them	The business, its clients, sometimes its suppliers
3. Weak vendor controls	A tool chosen for its features, with no review of terms, retention, subprocessors or security	The business, which usually stays responsible
4. Inaccurate or misleading outputs	Invented facts, wrong figures, biased summaries, confident errors sent to customers or used to judge people	Customers, candidates, employees
5. Regulatory and contractual exposure	Missing transparency, no contract with the supplier, a client agreement breached by an upload	The business, in complaints, audits and disputes
6. Reputational damage	A customer finds their details in an AI-written message, or a client learns their documents were uploaded without asking	The brand, sometimes for years
7. Time and money spent correcting preventable mistakes	Investigations, rewriting policies in a hurry, notifying people, re-checking work, legal fees	The owner and the team

Direct costs and everything underneath

It helps to separate the **direct financial costs** of an AI problem (fees, legal advice, a fine if one is imposed, compensation, replacement work) from the **operational, legal and reputational consequences** that sit beneath them and are often larger and slower. The figure below shows the idea. It is an illustration of kinds of cost, not a measurement of how much each costs.

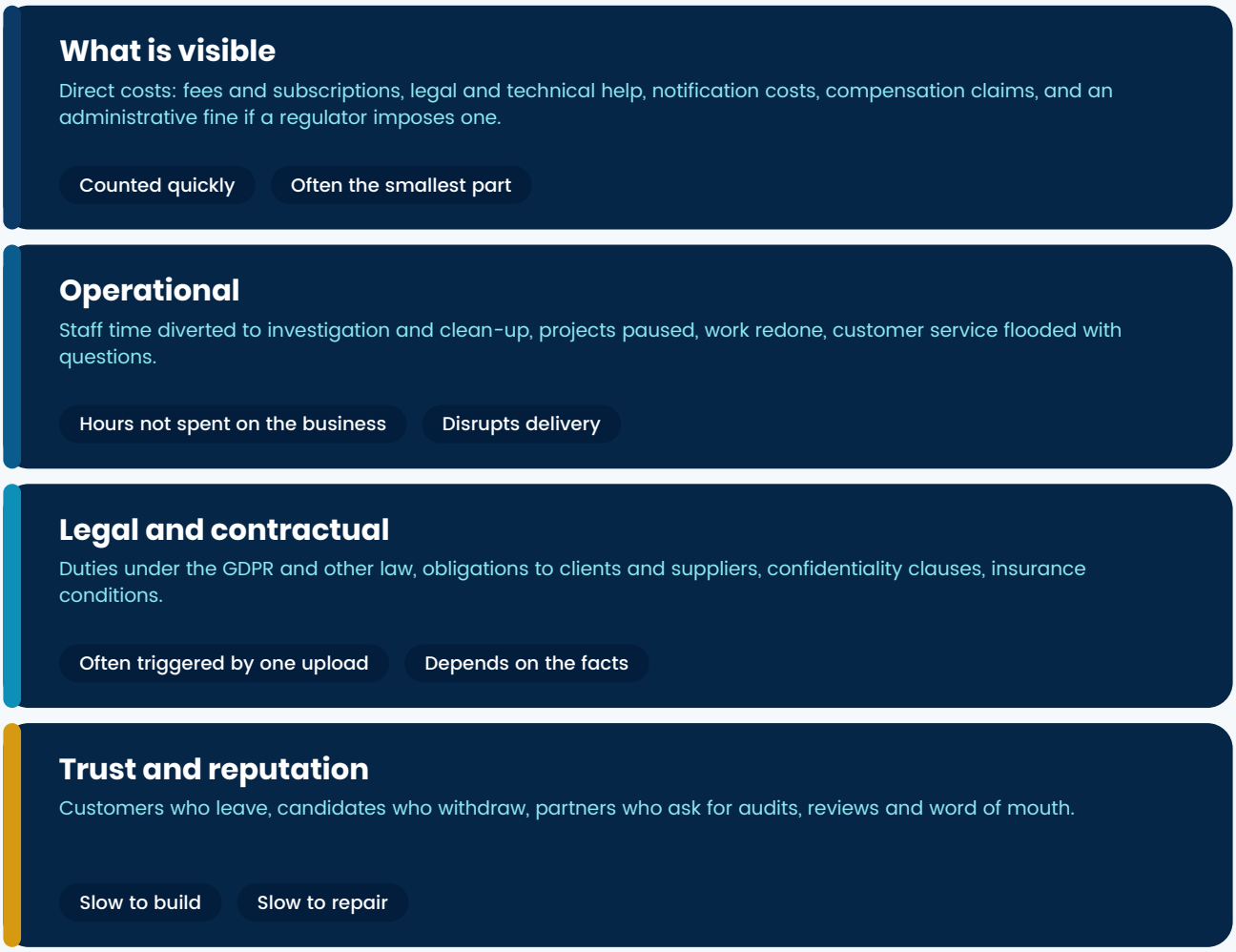


Figure 4 Above and below the waterline of an AI mistake

IN PLAIN ENGLISH **In plain English**

"Personal data" means any information that relates to an identified or identifiable person, such as a name, an email address, a photo or an online identifier (GDPR Article 4(1)) [1]. "Processing" means almost anything you do with it, including storing it, sending it or typing it into a tool (Article 4(2)). Entering a customer's name into an AI tool is processing.

Why the same tool can be safe in one use and risky in another

There is no honest answer to "is AI safe for my business?" because **risk depends on the use, not on the label**. Four things decide it:

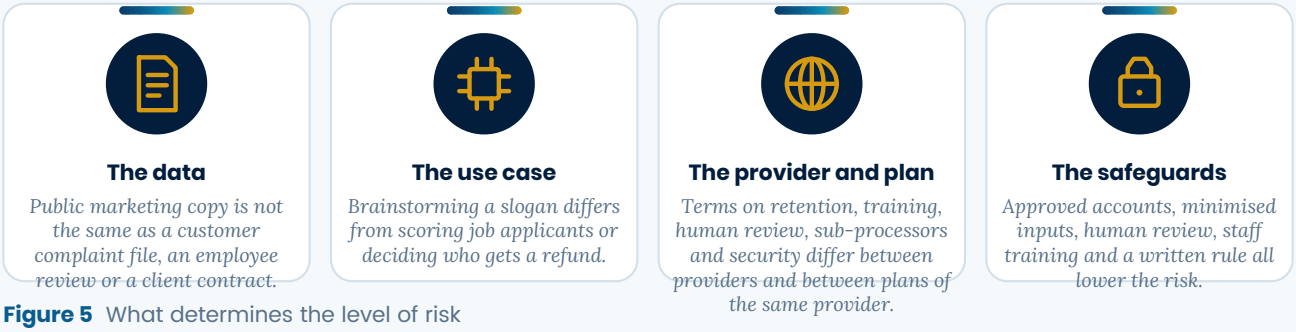


Figure 5 What determines the level of risk

A rough way to combine them is a risk matrix. Rate **likelihood** (how plausible is it that this goes wrong?) and **impact** (how bad for people and for the business if it does?) from 1 to 3 and place each AI use in the grid.

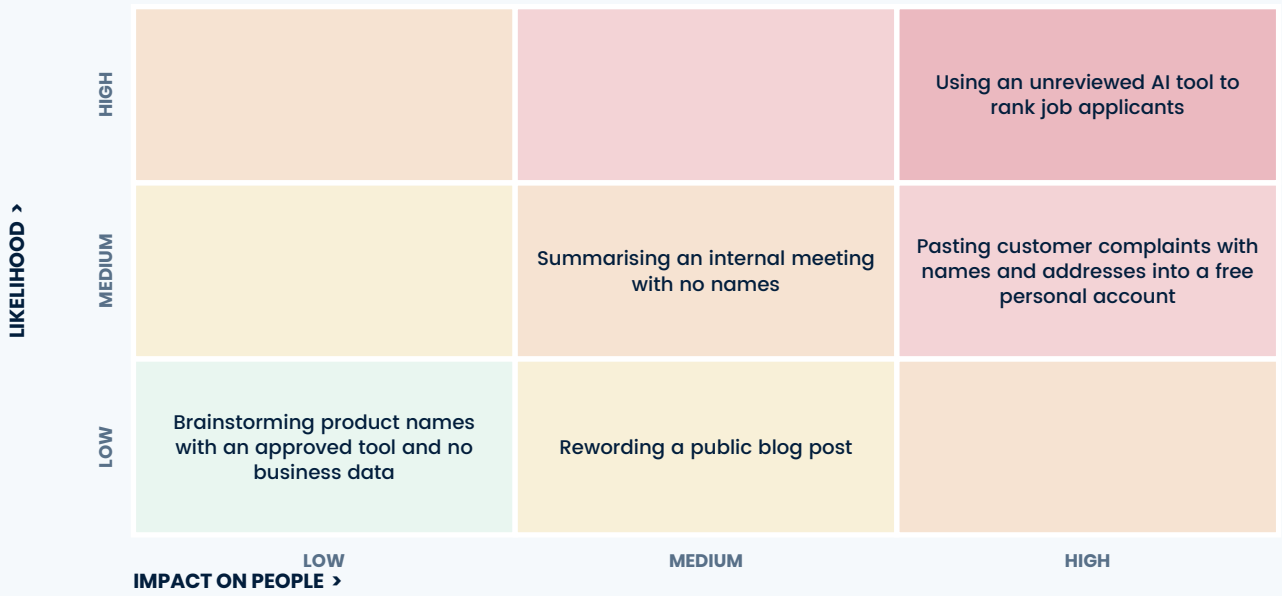


Figure 6 Illustrative risk matrix: likelihood 1 to 3, impact 1 to 3

SOURCE NOTE **About the matrix**

The placements are the author's illustrations of how to use the method. They are not measurements, and the right placement for your business depends on your facts.

The legal backdrop in one paragraph

The GDPR does not ban AI, and using AI does not automatically breach it. What it requires is that personal data is handled lawfully, fairly and transparently, for specified purposes, no more than necessary, accurately, for no longer than needed, and securely, and that you can **show** you do this (Article 5(1) and (2)) [1]. Using a supplier does not move your responsibility to the supplier: if you decide why and how personal data is used, you are generally the "controller" and stay accountable for that use, a point Chapter 4 explains. AI-specific rules sit on top, in the EU AI Act, which Chapter 11 covers [2][3].

WHAT THE LAW SAYS **What the law says**

The accountability principle (GDPR Article 5(2)) means the controller is responsible for compliance and must be able to demonstrate it. Article 24 requires appropriate technical and organisational measures, taking into account the nature, scope, context and purposes of processing and the risks to individuals [1].

Misconceptions that keep costs hidden

What people assume, and what is more accurate

Assumption	What is more accurate
"It is only a prompt, not a database."	A prompt can contain personal data and confidential information. Entering it is processing, and uploads can contain far more than you intended.
"The provider is responsible."	The provider has its own duties, but you are usually responsible for your own decisions to share data and for having a suitable contract and basis.
"Everyone uses it, so it must be fine."	Widespread use is not a legal basis, and each business is judged on its own use.
"We are too small for anyone to care."	The GDPR applies to organisations of any size. Proportionality affects what is expected of you, not whether the law applies.
"AI output is just a draft, so it cannot cause harm."	A draft that is sent without checking, or that is used to judge a person, can cause real harm to real people.
"Free tools cost nothing."	A free tool may cost nothing in money and still carry costs in data, control and contract terms. Read the terms.

Worked example: nine tools nobody had counted (hypothetical)

HYPOTHETICAL EXAMPLE **Hypothetical example: Aldermere Architects**

Business context. Aldermere Architects is a fifteen-person practice. The partners believe the firm "barely uses AI". **What happened.** When the office manager asks everyone to list the AI they use, nine tools appear. Two were chosen by the partners. Four are free personal accounts that staff use for drafting and summarising. Three are features inside software the firm already pays for, including a meeting-summary function that was switched on by default and has been transcribing project calls with clients for months.

Worked example analysis

Question	Analysis
Data and people affected	Clients, contractors and the firm's own staff: names, project details, site addresses, fee information and what people said in recorded calls.
Risks	Unknown retention and processing for seven of the nine tools; no contracts for the personal accounts; recordings of people who were never told; confidentiality duties to clients; no list to work from if a problem appears.
Legal questions	Which uses involve personal data? Which tools have a processor contract? Do client agreements restrict third-party processing? Were people told about recording? [1]
What the firm should have done	Asked the question months earlier, switched off default AI features until assessed, and approved a short list of tools.
Corrective actions	Build the inventory (Tool 1); switch off the default feature; assess the two or three tools that matter most; tell the team which are approved; tell clients about recording where appropriate.
Lessons	The first hidden cost is not knowing. Mapping takes an afternoon and is the step every other step depends on.

Step by step: a first look at your own AI use

1. **Collect the list.** Take the "AI tools we use" list you started and ask each person to add to it. Promise that honest answers will not be punished.
2. **Note the data.** For each tool, write the kind of information that goes in: public, internal, confidential, personal, or sensitive.
3. **Note the account.** Is it a business account the company controls, or a personal one?
4. **Rate each use.** Use the matrix: likelihood and impact from 1 to 3. Mark anything scoring 6 or more.
5. **Pick three.** Choose the three highest-rated uses. They are where Chapters 2, 3 and 5 begin.

CHAPTER 1 CHECKLIST

- [ ] I have a written list of the AI tools used in my business, including free and personal accounts.
- [ ] I know, for each, what kinds of information go in.
- [ ] I know whether each tool is on a business account.
- [ ] I have rated each use for likelihood and impact.
- [ ] I have identified my three highest-risk uses.

WHAT TO DO TODAY **What to do today**

Ask your team one question by message: "Which AI tools have you used for work in the last month? No blame, I just need the list." Collect the answers before the end of the day.

Summary

- The visible cost of AI is a subscription. The hidden costs are exposure, leakage, weak vendors, wrong outputs, legal and contractual exposure, reputational harm and clean-up time.
- Risk depends on the data, the use case, the provider and plan, and the safeguards. It does not depend on the label "AI".
- The GDPR does not ban AI, but responsibility for your use stays with you and you must be able to show it [1].
- The first step is to see: list the AI in use and rate each use.

SOURCE NOTE **Key sources**

[1] GDPR, Articles 4(1), 4(2), 5, 9, 24 and 28. [2] and [3] EU AI Act and Regulation (EU) 2026/1744. See the Sources section for links and how each was checked.

PART I · THE HIDDEN RISKS

CHAPTER

02

What Happens to Your Data When You Use AI?

A prompt is a transfer. Where it goes, how long it stays and who can see it depends on the tool and on the plan, and you have to check both.

IN THIS CHAPTER

- What AI services may do with prompts, uploads, audio, images and records
- The difference between consumer and business offerings
- Training, service improvement, retention, human review, sub-processors and integrations
- How to read a privacy notice, terms and a data processing agreement

What is the risk?
Information entered into an AI service leaves your control: where it goes and how long it stays depends on the provider and the plan.

Why should a small business care?
You are responsible for choosing the tool and for what you send to it, and you cannot judge that without reading the terms.

What can I do about it?
Learn six questions to ask of any tool and where to find the answers, and never assume that two plans or two providers behave alike.

Figure 7 The three questions for this chapter

SOURCE NOTE **Five-Step AI Privacy Loop · Map, Vet**

This chapter helps you map the data flow of each tool and begin vetting it. It deliberately makes no claim about what any named provider does, because those terms change and differ.

HYPOTHETICAL EXAMPLE **Hypothetical scenario: the contract in the chat window**

Dalia is an independent consultant. A client has sent her a 40-page services agreement and asked for her comments by morning. She is tired, so she uploads the PDF to a free AI assistant: "Summarise the risks and list unusual clauses." The summary is useful. But the agreement carries a confidentiality clause, and the PDF contains the client's name, pricing and a staff list in an annex. Dalia has not read the assistant's terms. She does not know whether the content is kept, who can review it, or whether it may be used to improve the service. She has not told the client.

The risk: a prompt is not a private thought

It is natural to treat an AI chat window like a conversation with a very smart colleague. It is better understood as **a data transfer to a service run by someone else**, under that someone's terms. What you type, upload, record or connect may be processed on servers you do not control, by a company and its suppliers, for purposes set out in documents most people never read.

What an AI service may process



Figure 8 Inputs that count as data

Beyond what you type, services may also handle **account and usage data** (who you are, when and how you use the tool), **conversation history**, **feedback you provide**, and **content retrieved from connected apps** such as email or shared drives.

The data flow at a glance

The figure shows a simplified path that data may take. Real services differ, and some of these stages may not apply to a particular tool. It is an illustration of the questions to ask, not a description of any specific provider.

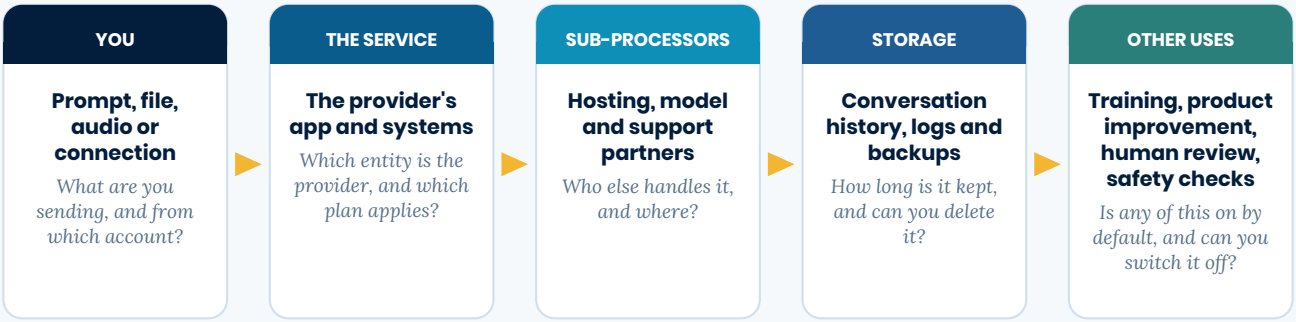


Figure 9 A simplified AI data flow: where to ask questions

Consumer versus business offerings

Many providers offer more than one kind of product: free or consumer tools, paid individual plans, and business, enterprise or API offerings. They often differ in the **terms that apply**, **whether a data processing agreement is available**, **default settings for training and retention**, **administrator controls**, and **the support you get if there is a problem**. Do not assume that a paid plan is automatically better on privacy, or that a business plan automatically covers every feature, including add-ons and integrations. Check each.

WATCH OUT **Never assume**

Do not assume that every AI provider trains on every user input. Do not assume that none do. Do not assume that every paid plan offers the same privacy protections, or that a setting you turned off in one product applies to another. **The only reliable answer is the current terms for the exact product and plan you use.**

Six words you will meet in every set of terms

Key terms, in plain English

Term	What it means	What to check
Training	Using inputs to improve or build the AI models	Is it on by default? Can you opt out? Does it apply to your plan?
Service improvement	Using inputs to improve the product, which may or may not include model training	How is it defined, and is it separate from training?
Retention	How long inputs and outputs are kept	Default period, deletion options, backups, legal holds
Human review	Staff or contractors reading some conversations, for safety, quality or support	When it happens, who does it, how it is protected
Sub-processors	Other companies the provider uses to process your data	The published list, where they are, how changes are notified
Integrations	Connections to email, drives, calendars, CRMs or browsers	What the tool can read, write or send, and under whose permissions

How to read the documents

Three documents answer most of your questions. You do not need a law degree to find what you need.

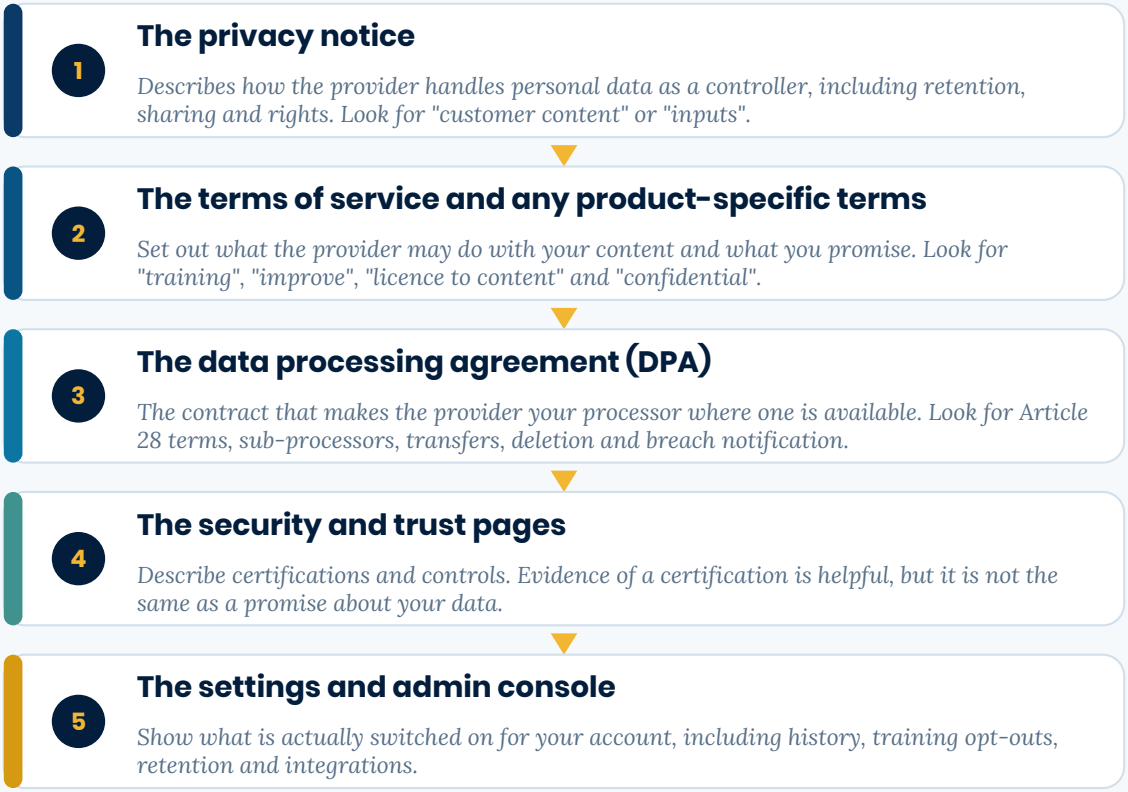


Figure 10 Where to look, in order

WHAT THE LAW SAYS **What the law says**

Where a provider processes personal data on your behalf, the GDPR requires a binding contract setting out its subject matter, duration, nature and purpose, the types of data and the controller's instructions, and obliging the processor to meet specified duties, including confidentiality, security, sub-processor conditions, assistance with rights and breaches, and deletion or return (Article 28(3)) [1]. The EDPB's guidelines on controllers and processors explain the roles [6].

GOOD PRACTICE **Good practice**

Keep a dated copy (or screenshot) of the terms and settings you relied on when you approved a tool. Terms change, and your record of what applied at the time is evidence of the care you took.

Case study 4: the confidential contract (hypothetical)

HYPOTHETICAL EXAMPLE **Hypothetical case study: Dalia and the services agreement**

Business context. Dalia is a one-person consultancy. Her client agreement has a confidentiality clause covering the client's pricing and organisation. **What happened.** She uploads the client's agreement to a free AI assistant on a personal account to get a quick summary. She does not read the terms, does not tell the client and does not change any settings. Later, the client asks in a routine audit questionnaire: "Do you use AI tools with our information?"

Case study 4 analysis: the contract

Question	Analysis
Data and people affected	The client's commercial terms and confidential information; names and roles in annexes (personal data); possibly third-party information embedded in the document.
Risks	A confidentiality breach if the contract forbids disclosure to third-party services; uncertainty over retention, review and training; no record; an awkward answer to the client.
Legal questions	Does the agreement restrict disclosure or require permission? Is the provider a permitted subcontractor? Are personal data in the annexes transferred, and is there a DPA? Could trade-secret protection be weakened if reasonable steps to keep it confidential were not taken (Directive (EU) 2016/943)? [31]
What she should have done	Read the client's confidentiality clause first; used an approved tool on a business plan; removed names and prices or asked the client's permission; kept notes of the decision.
Corrective actions	Review the clause and the tool's terms; delete the conversation and uploaded file where the tool allows; consider telling the client honestly, ideally with advice; adopt a "check the contract first" rule.
Lessons	A contract can forbid what the law allows. Many AI risks for small firms are contractual before they are regulatory.

Common mistakes and misconceptions

Data flow myths

Assumption	What is more accurate
"Deleting the chat deletes the data."	Deletion may not remove copies from backups or logs, or content already reviewed or used. Check the retention terms.
"Incognito or temporary mode makes it private."	It may change what is saved in your history. It may not change what the provider processes. Read what the setting actually does.
"The AI cannot see my other files."	Not unless you connect them. Once connected, it may read as much as the connection allows.
"The provider is in my country, so transfers do not matter."	Sub-processors and support teams may sit elsewhere. Ask for the list and the transfer mechanism.
"Paid means private."	Paid plans often offer more controls, but terms and defaults vary. Check each plan.

Step by step: assess one tool in twenty minutes

1. **Name the tool and the plan.** Exactly which product, on which account type?
2. **Find the three documents.** Privacy notice, terms, DPA (if offered).
3. **Answer six questions.** Is content used to train models? How long is it kept? Can humans review it? Who are the sub-processors? Where is data processed? Is there a DPA?
4. **Check the settings.** Are history, training and sharing options set the way you want?
5. **Record and decide.** Write a line in your inventory (Tool 1): approved, approved with limits, or not approved.

CHAPTER 2 CHECKLIST

- [ ] I know which plan each tool uses and who owns the account.
- [ ] I have found each tool's privacy notice, terms and, where offered, DPA.
- [ ] I know whether content may be used for training or improvement, and whether I can switch that off.
- [ ] I know the default retention period and how to delete content.
- [ ] I know whether humans may review conversations.
- [ ] I have a list of sub-processors and the locations where data may be processed.
- [ ] I have saved a dated copy of what I relied on.

WHAT TO DO TODAY **What to do today**

Pick the AI tool your team uses most. Spend twenty minutes finding its privacy notice, terms and settings, and write down the answers to the six questions above.

Summary

- Anything you type, upload, record or connect to an AI service is data processed by someone else, under their terms.
- Practices on training, retention, human review and sub-processors differ between providers and between plans.
- Read the privacy notice, terms, DPA and settings for the exact product and plan, and keep a dated record.
- Where personal data is processed on your behalf, the GDPR requires a processor contract with specified content [1].

SOURCE NOTE **Key sources**

[1] GDPR, Articles 4, 5 and 28(3). [6] EDPB Guidelines 07/2020 on controller and processor. [31] Directive (EU) 2016/943 on trade secrets. See the Sources section.

PART I · THE HIDDEN RISKS

CHAPTER

03

The Everyday AI Privacy Mistakes Businesses Make

Most AI privacy incidents are not attacks. They are ordinary shortcuts taken by people trying to be efficient.

IN THIS CHAPTER

- Eight common mistakes and what makes each more or less risky
- How to prevent each one without banning the tool
- A before-and-after example of an unsafe and a safer workflow
- Two hypothetical case studies

What is the risk?
Customer, employee and client information is shared with AI tools through ordinary habits, not through attacks.

Why should a small business care?
Each habit can create a data protection issue, a contract breach or a customer complaint, and none of them is visible until it matters.

What can I do about it?
Replace each risky habit with a safer one, and give people an approved route so they do not need workarounds.

Figure 11 The three questions for this chapter

SOURCE NOTE **Five-Step AI Privacy Loop · Minimise, Govern**

This chapter is about minimising what goes in and giving people clear rules. It focuses on prevention, because prevention is cheaper than any response.

The risk: shortcuts that look like efficiency

Almost every mistake in this chapter follows the same pattern. Someone has a real task and limited time. A tool offers a quick solution. The data involved does not feel sensitive at the time. And nobody has told them what they may and may not do. The answer is rarely blame. It is **clear rules, better tools and a safer route that is as easy as the unsafe one**.

Eight mistakes, and how to stop them

For each mistake, the table says what can go wrong, which factors raise or lower the risk, and how to prevent it. "Depends" means exactly that: the right answer turns on the facts.

Mistakes 1 to 4

Mistake	What can go wrong	What changes the level of risk	Prevention
1. Uploading a customer database without authorisation	Personal data of many people shared with a service you have not assessed; no lawful basis or notice for this use; hard to delete	Size of data, sensitivity, tool and plan, contract, whether people were told	Never upload exports; use anonymised or sample data; approve a tool and DPA first
2. Pasting employee performance reviews	Sensitive personal data about staff in an unapproved tool; possible unfair or biased summaries; breach of employment confidentiality	Detail, tool, whether the output feeds decisions, national employment law	Keep reviews out of general tools; get advice before using AI to assess people; human decision-making
3. Sharing identifiable customer complaints	Names, contact details and sometimes health or financial details exposed; the customer never expected this use	Identifiers present, special-category content, tool terms	Describe the issue without names; strip identifiers; use an approved tool
4. Uploading passports, invoices, contracts or medical documents	Identity documents enable fraud; invoices expose bank details; contracts may be confidential; health data is special-category	Document type, redaction, tool, contract terms, purpose	Do not upload ID or medical documents; redact; check contract before upload

Mistakes 5 to 8

Mistake	What can go wrong	What changes the level of risk	Prevention
5. Using AI meeting assistants without transparency	Recording and transcribing people who did not know or agree; capturing confidential or sensitive discussion; storage of transcripts	Who attends, content, jurisdiction, consent or notice, retention	Tell participants first; offer an opt-out; limit to meetings where appropriate; review retention
6. Entering confidential information into browser extensions	Extensions can read pages you visit, including admin panels and webmail; some send content to third parties	What permissions the extension has, who made it, what pages you open	Approved-extension list; remove unknown extensions; separate browser profiles for sensitive work
7. Allowing unapproved AI tools	The business does not know what data went where; no contracts; no way to respond to a problem	Number of tools, accounts (personal or business), data used	Publish the approved list; make approval quick; invite disclosure without blame
8. Copying AI content into customer communications without checking	Wrong facts, invented details, inappropriate tone, another person's personal data repeated by mistake; promises you cannot keep	Audience, subject, consequences of error, whether data was in the prompt	Human review before sending; never use for decisions about people without review; keep a prompt record for sensitive cases

WATCH OUT **What to check before AI listens in**

Recording or transcribing a call or meeting is processing personal data and may also engage national rules on recording conversations. Participants should be told before it starts, in clear terms, and the legal position can differ by country. Take advice before using AI transcription in sensitive settings such as HR, health, legal or financial discussions.

Before and after: one workflow, two ways

BEFORE & AFTER **Drafting a reply to a customer complaint**

RISKY	*Paste the whole email into a free chatbot on a personal account: "Hi, I'm Ana Horvat, 12 Park Street. My order 88412 was charged twice and I have been unwell so please hurry. My phone is 091 555 0199."*
BETTER	*Use an approved tool and describe the situation: "A customer says they were charged twice for one order and asks for a fast reply. Draft a polite response saying we will check payment records and reply within two working days."*
BEST PRACTICE	*Use an approved tool and a template with placeholders: "Customer: [NAME]. Issue: possible duplicate charge. Tone: warm, concise." Add real details only in your own system, when you send the reply.*
WHY IT MATTERS	The better prompts describe the situation rather than the person. The address, the order number, the health remark and the phone number were never needed to draft a reply.

A decision tree for the five-second check

1	**Does it contain a password, key, token or recovery code?**	**YES** STOP. Never paste secrets.	**NO** Go to question 2.
2	**Is the tool approved by my business for this purpose?**	**YES** Go to question 3.	**NO** STOP. Use an approved tool or ask for approval.
3	**Does it include special-category data, children's data, ID documents or payment details?**	**YES** STOP. Do not proceed without specific approval.	**NO** Go to question 4.
4	**Does it include personal data about customers, staff or others?**	**YES** Remove or replace identifying details if the task allows, then ask again.	**NO** Go to question 5.
5	**Is it confidential business information, or covered by an NDA or client contract?**	**YES** Check the contract and the tool's terms. Minimise.	**NO** You can proceed. Check the output before you use it.

Figure 12 Should this go into this AI tool?

SOURCE NOTE **How to read the decision tree**

Each row is a question. The first answer column tells you what to do if the answer is yes; the second, if the answer is no. It is a thinking aid, not a legal test.

Case study 1: the agency and the client records (hypothetical)

HYPOTHETICAL EXAMPLE **Hypothetical case study: Northbeam Digital**

Business context. Northbeam Digital is a seven-person marketing agency that runs email campaigns for local retailers. **What happened.** To save time, an account manager uploads a client's full customer list, with names, email addresses, purchase history and tags such as "lapsed" and "high spender", to an AI assistant, asking it to "segment these customers and write a personalised message for each segment." The tool is a free personal-account version. The agency's contract with the retailer says the agency may use customer data "only to deliver the services".

Case study 1 analysis: the agency

Question	Analysis
Data and people affected	The retailer's customers: contact details, purchase histories and inferred labels. The agency is probably the retailer's processor; the retailer is probably the controller.
Risks	A processor sending the controller's data to another service (a sub-processor) without authorisation; use outside the retailer's instructions; unknown retention and training; weak accountability to the client.
Legal questions	Under GDPR Article 28(2) and (3), did the retailer authorise this sub-processor and was there a contract with it? Was this within the controller's instructions? Does the retailer's privacy notice cover it? Is profiling involved and what does it mean for Article 21 objections? [1]
What the agency should have done	Asked whether AI use was allowed; used an approved tool under a DPA; sent aggregated or pseudonymised data; given the retailer a list of sub-processors; recorded the instruction.
Corrective actions	Tell the client promptly; find out what was uploaded; delete where possible; assess with advice whether it is a personal data breach (Chapter 10); update the sub-processor list; train staff.
Lessons	When you process data for someone else, your freedom to choose tools is limited by their instructions. Ask before you add a new service.

Case study 2: the complaints analysis (hypothetical)

HYPOTHETICAL EXAMPLE **Hypothetical case study: Lindqvist Outdoor**

Business context. Lindqvist Outdoor is an ecommerce company selling hiking gear. Its owner wants to understand why returns are rising. **What happened.** An analyst copies two years of complaint tickets, including names, addresses, phone numbers and free-text remarks, into an AI tool to "cluster the main complaint themes". The tool is a business-plan product the company pays for, but nobody has read its terms, and no DPA has been signed.

Case study 2 analysis: the complaints

Question	Analysis
Data and people affected	Thousands of customers across two years; their identifiers and free-text remarks, which may include health, family or financial details they chose to share.
Risks	Personal data processed where the business has no contract or knowledge of retention; large volume increases the impact of any problem; purpose may be compatible, but it has not been assessed.
Legal questions	Is analysing complaints for service improvement compatible with the purpose for which the data was collected (Article 5(1)(b), Article 6(4))? Is there a lawful basis, such as legitimate interests, supported by a balancing test? Is the supplier a processor under an Article 28 contract? [1]
What the business should have done	Removed names and contact details before upload; analysed a sample first; signed the DPA; recorded the purpose and the legitimate-interests assessment.
Corrective actions	Review the tool's terms and settings; sign or request a DPA; delete the uploaded data where possible; record the purpose; tell the team that future analysis uses de-identified data.
Lessons	Having a business plan is not the same as having a contract that covers your use. Check the paperwork, then minimise the data.

Step by step: replace habits, not people

1. **Name the top three habits** in your business from the eight above.
2. **Give each a safer route.** For each habit, write a one-line alternative that is as quick as the unsafe version.
3. **Approve one tool properly** for the commonest task and publish how to use it.
4. **Say it out loud.** Tell the team what is allowed, what is not, and what to do if they have already done it.
5. **Check in after a month.** Ask what is slowing people down and fix that.

CHAPTER 3 CHECKLIST

- [ ] I know which of the eight mistakes are most likely in my business.
- [ ] Each has a safer, equally easy alternative that I have communicated.
- [ ] Customer exports are never uploaded to unapproved tools.
- [ ] Staff know not to paste employee reviews, ID documents or medical information into general tools.
- [ ] AI recording tools require notice to participants before use.

- [ ] Browser extensions are reviewed and unknown ones are removed.
- [ ] AI output is read by a person before it is sent to a customer.

WHAT TO DO TODAY **What to do today**

Write a one-line replacement for the riskiest habit you found in your business, for example: "Describe the complaint, don't paste it." Send it to the team before the end of the day.

Summary

- Most AI privacy problems come from ordinary shortcuts, not attacks.
- For each mistake, the level of risk depends on the data, the tool, the contract and the purpose, so ask what changes it.
- The most effective prevention is a safer route that is as easy as the unsafe one, plus clear rules.
- If you process data for others, such as clients, your tool choices are limited by their instructions and by Article 28 [1].

SOURCE NOTE **Key sources**

[1] GDPR, Articles 5, 6, 9, 21 and 28. See the Sources section.



PART

II

Law, Vendors and People

What the GDPR requires in plain English, how to choose AI tools without exposing your business, and how to manage the human side of AI.

PART II · LAW, VENDORS AND PEOPLE

CHAPTER

04

GDPR and AI: What Every Small Business Needs to Understand

The GDPR does not ban AI. It asks who decides, why, on what basis, how much data, for how long, and whether you can prove it.

IN THIS CHAPTER

- The seven principles of the GDPR, applied to AI-powered work
- Controllers, processors and joint controllers
- Lawful bases, special-category data, privacy notices and processor contracts
- International transfers, data subject rights and accountability
- Why using an AI provider does not hand your responsibilities to them

What is the risk?
Using personal data in AI without a basis, a notice, a contract or a record of your reasoning.

Why should a small business care?
The GDPR applies to organisations of any size, and responsibility stays with the business that decides how data is used.

What can I do about it?
Learn the principles, identify your role, record your basis, tell people clearly, and have contracts and rights requests covered.

Figure 13 The three questions for this chapter

SOURCE NOTE **Five-Step AI Privacy Loop · Vet, Govern**

This chapter supplies the legal vocabulary for the rest of the book. It is a plain-English guide, not a substitute for advice on your facts.

HYPOTHETICAL EXAMPLE **Hypothetical scenario: the shop that assumed**

A boutique hotel adopts an AI assistant to answer guest emails. The owner reasons: "The provider is a big company. They are responsible for GDPR, not us." Six months later a guest asks what data the hotel holds about them and whether it was shared with an AI service. The owner realises that she cannot answer, has no contract with the provider, and never mentioned AI in the privacy notice.

The risk: personal data, no plan

The GDPR is the European Union's general data protection law, Regulation (EU) 2016/679 [1]. It applies to the processing of personal data by organisations established in the EU, and to some organisations outside it that offer goods or services to people in the EU or monitor their behaviour (Article 3). It applies to businesses of every size. Small businesses get some practical flexibility, for example in record-keeping, but not an exemption. Most AI uses that involve customer, employee or candidate information fall within it.

WHAT THE LAW SAYS **What the law says**

The GDPR is binding law. It sits alongside national laws, which can add rules, especially for employment (Article 88). Guidance from the EDPB and national supervisory authorities explains how those authorities read the law. That guidance is persuasive and is what regulators tend to apply, but it is not itself legislation [1].

The seven principles, applied to AI

Article 5 sets out the principles that sit behind every other rule [1]. Each has a direct meaning for AI use.

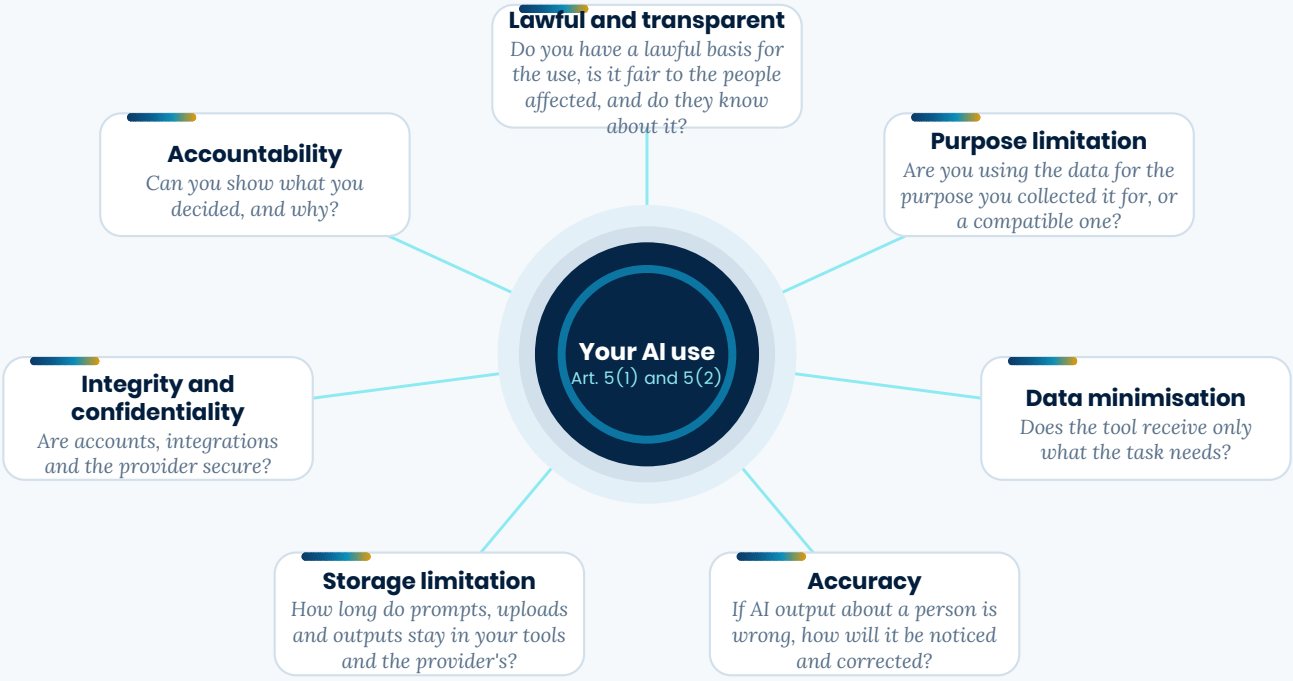


Figure 14 The principles of Article 5, applied to AI-powered work

Who is who: controllers, processors and joint controllers

The GDPR distinguishes roles, and the role decides who owes what. A **controller** decides the purposes and means of processing personal data (Article 4(7)). A **processor** processes it on the controller's behalf and on its instructions (Article 4(8)). **Joint controllers** jointly decide purposes and means and must set out their responsibilities in an arrangement (Article 26). The EDPB's guidelines explain that roles follow the facts, not the labels in a contract [6].

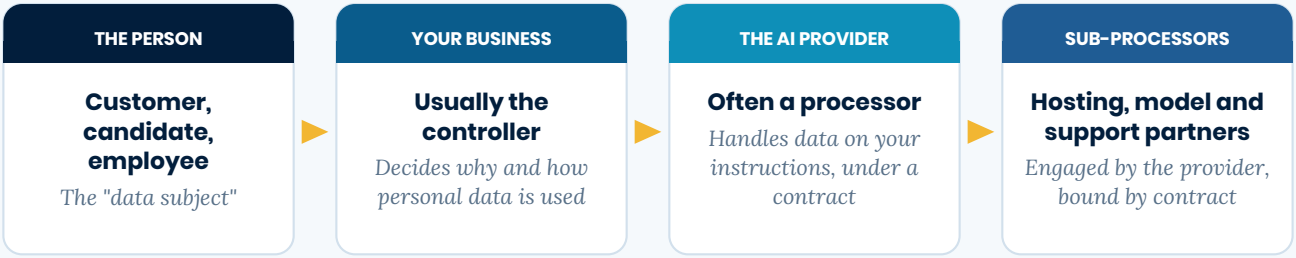


Figure 15 Who is who when a small business uses an AI tool

Two points catch small businesses out. First, **an AI provider can be a processor for some purposes and a controller for others**, for example when it uses account data for its own security or when it decides to use inputs to improve its own products. The terms usually show which. Second, if **you** process data

for a client, you may be a processor, and then you can only use sub-processors, including an AI tool, as the client has authorised (Article 28(2) and (4)) [1].

> **WATCH OUT** **Using a provider does not transfer your responsibility**
>
> If you decide to use an AI tool for personal data, you remain accountable for that decision as controller. The provider's compliance programme helps, but it does not remove your duties to have a basis, to tell people, to limit the data, to choose a suitable processor and to be able to show it. A provider's marketing claims about "GDPR compliance" are not a substitute for reading the contract.

The lawful basis: why are you allowed to do this?

Every use of personal data needs one of six lawful bases in Article 6(1). You choose before you start, record it, and tell people. There is no hierarchy: the right basis depends on the purpose.

The six lawful bases and what they mean for AI use

Basis	In plain English	An AI example	Watch out
Consent (Art. 6(1)(a))	A freely given, specific, informed, unambiguous yes	A customer opts in to an AI-powered recommendation service	Must be as easy to withdraw as to give; not valid if bundled or pressured
Contract (Art. 6(1)(b))	Necessary to perform a contract with the person	Using AI to process an order the customer placed	"Necessary" is narrow: useful is not the same as necessary
Legal obligation (Art. 6(1)(c))	Required by law	Keeping invoices for tax	The law must actually require it
Vital interests (Art. 6(1)(d))	Protecting someone's life	Rarely relevant in business	Narrow, emergencies only
Public task (Art. 6(1)(e))	Official or public-interest function	Mostly public bodies	Needs a legal basis in law
Legitimate interests (Art. 6(1)(f))	A real business interest, necessary, and not overridden by the person's rights	Using customer complaints to improve service, with safeguards	Needs a written balancing test; people can object

> **IN PLAIN ENGLISH** **In plain English**
>
> Legitimate interests is flexible but not a free pass. It requires three steps: a legitimate interest, necessity, and a balance against the person's rights and reasonable expectations. The EDPB's Opinion 28/2024 on AI models says legitimate interests is not automatically available or unavailable for AI, and that the same three-step assessment applies case by case [11].

Special-category data and children's data

Some data is protected more strictly because misuse can cause serious harm. Article 9 covers data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs and trade-union membership, genetic data, biometric data used to identify a person, health data, and data about a person's sex life or sexual orientation [1]. Processing it is prohibited unless a specific condition in Article 9(2) applies, in addition to an Article 6 basis. Criminal-offence data has its own rule in Article 10. Children merit specific protection, and rules on a child's consent for online services (Article 8) vary by Member State between ages 13 and 16.

For AI, the practical rule is simple: **do not put special-category data, children's data or identity documents into general-purpose AI tools unless you have specific approval, a suitable contract and a documented basis.** Remember that special-category data can appear by accident, for example in a complaint ("I was off sick") or a CV photograph.

Telling people: privacy notices

Articles 12 to 14 require you to tell people, in concise, transparent and plain language, who you are, why you process their data and on what basis, who receives it, whether it is transferred outside the EEA, how long you keep it and what their rights are [1]. If you use AI in a way that matters to them, your notice should reflect it. If you make automated decisions with legal or similarly significant effects, you must give meaningful information about the logic involved and the consequences (Articles 13(2)(f) and 14(2)(g)). A practical way to check your notice is Tool 9.

Processor contracts

When an AI provider processes personal data for you, Article 28 requires a contract or other binding legal act with specified content, including processing only on your documented instructions, confidentiality, security measures, conditions for sub-processors, help with data subject requests and breaches, and deletion or return at the end [1]. Many major providers publish a standard data processing agreement (DPA). Check that it applies to **your plan and your use**, and keep a signed or accepted copy.

International transfers

Personal data may move freely within the EEA. Transfers to other countries need a mechanism under Chapter V of the GDPR. AI services often involve transfers, through the provider's own servers, support teams or sub-processors, so ask where data is processed and accessed from.

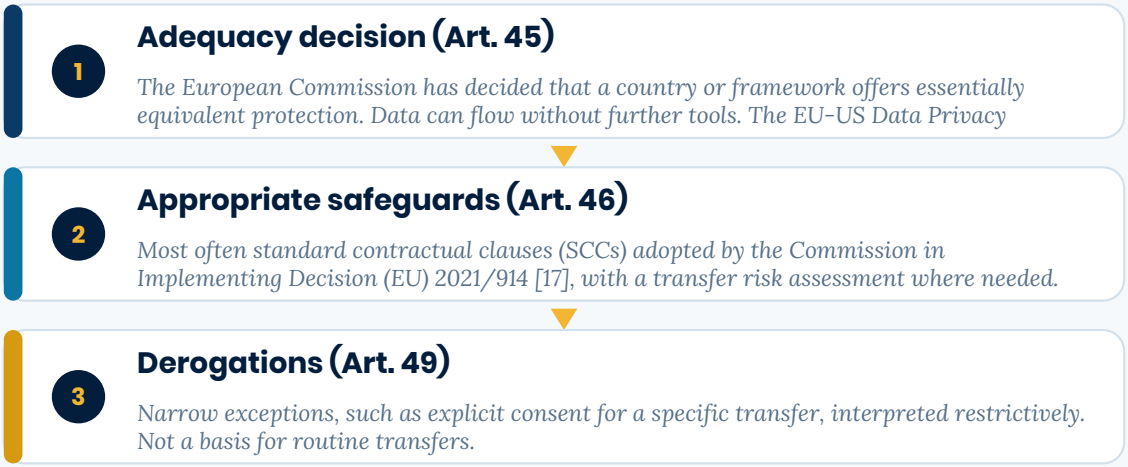


Figure 16 Three levels of transfer mechanism

The legal position on the EU-US framework was still developing at the research cut-off: the General Court dismissed a challenge to the decision in September 2025, and an appeal to the Court of Justice was reported as pending. Check the current position and check that your specific supplier is certified before relying on it.

People's rights

Individuals have rights over their data. You must act on most requests without undue delay and within one month, extendable by two further months for complex or numerous requests (Article 12(3)).

Data subject rights and what they mean when AI is involved

Right	In plain English	An AI-related question to prepare for
Access (Art. 15)	A copy of their data and information about how it is used	Did their data go into an AI tool? Where? For what? [12]
Rectification (Art. 16)	Correct inaccurate data	If AI-generated content about them is wrong, can you fix it?
Erasure (Art. 17)	Delete data in certain cases	Can you delete prompts, uploads and outputs containing their data?
Restriction (Art. 18)	Pause processing in certain cases	Can you stop using it in AI workflows while a dispute is resolved?
Portability (Art. 20)	Receive data in a usable format, in some cases	Can you export it from tools you rely on?
Objection (Art. 21)	Object to processing based on legitimate interests; object absolutely to direct marketing	Can you stop AI profiling or personalised marketing for this person?
Automated decisions (Art. 22)	Not to be subject to solely automated decisions with legal or similarly significant effects, subject to exceptions and safeguards	Is there human involvement, and can the person contest a decision? [14][25]

Accountability: show your working

The GDPR expects you to be able to demonstrate compliance (Articles 5(2) and 24) [1]. For a small business, that means a modest, living set of records: what AI tools you use and for what (Tool 1), your lawful basis and notice, your supplier contracts, your risk and impact assessments where needed (Tool 8), your policy and training, and your incident log. Article 30 requires a record of processing activities. There is an exemption for organisations with fewer than 250 employees, but it does not apply if the processing is likely to result in a risk to people's rights and freedoms, is not occasional, or involves special-category or criminal-offence data (Article 30(5)), so in practice many small businesses need a record [1].

What is law, and what is recommendation?

Binding law versus good practice in this chapter

Statement	Status
You need a lawful basis for processing personal data (Art. 6)	Binding law
You must tell people about your processing (Arts. 12 to 14)	Binding law
You need an Article 28 contract with a processor	Binding law
You must be able to demonstrate compliance (Art. 5(2))	Binding law
You should keep a dated copy of the terms you relied on	Good practice
You should run a written legitimate-interests test	Regulatory guidance and good practice
You should not paste special-category data into general tools	The author's recommendation, reflecting the risk

Common mistakes and misconceptions

GDPR and AI myths

Assumption	What is more accurate
"GDPR bans AI."	It does not. It regulates how personal data is used, and AI uses can be lawful with a basis, safeguards and transparency.
"If it's anonymous, GDPR does not apply, so removing the name is enough."	Anonymisation is a high bar. Data that can still be linked back to a person is still personal data. Stripping names often leaves it identifiable.
"The provider's DPA covers everything."	It covers what it covers. Check that it applies to your plan, your features and your use.
"We have consent, so we can do anything."	Consent is purpose-specific and can be withdrawn. It does not cover uses people were not told about.
"Small businesses are exempt from records."	Article 30(5) has narrow conditions, and many small businesses fall outside it.

Step by step: a GDPR-and-AI baseline

1. **Identify your role** for each AI use: controller, processor or both.
2. **Record the basis** for each use that involves personal data.
3. **Check the notice.** Does it describe the AI uses that matter to people?
4. **Check the contract.** Is there an Article 28 DPA covering the tool and plan?
5. **Check transfers.** Do you know where data goes and which mechanism applies?
6. **Prepare for requests.** Can you find and delete personal data in your AI tools?

CHAPTER 4 CHECKLIST

- [ ] I know whether I am a controller, a processor or both for each AI use.
- [ ] Each use involving personal data has a recorded lawful basis.
- [ ] Special-category data is excluded from AI tools unless specifically approved.
- [ ] My privacy notice reflects the AI uses that matter to people.
- [ ] I have a DPA with each provider that processes personal data for me.
- [ ] I know where each provider processes data and which transfer mechanism applies.
- [ ] I can respond to access, erasure and objection requests that involve AI tools.
- [ ] I keep records that show my reasoning.

WHAT TO DO TODAY **What to do today**

Choose one AI use that involves customer data. Write three lines: your role, your lawful basis, and where your notice mentions it. If you cannot complete any line, you have found your first gap.

Summary

- The GDPR applies to AI uses that process personal data. It does not ban AI [1].
- Roles matter: if you decide why and how, you are generally the controller and stay accountable.
- Every use needs a lawful basis, a notice and, with a processor, an Article 28 contract.
- Rights and accountability need practical preparation: records, contacts and a process.

SOURCE NOTE **Key sources**

[1] GDPR, Articles 3, 4, 5, 6, 8, 9, 10, 12 to 14, 15 to 22, 24, 26, 28, 30, 44 to 49 and 88. [6] EDPB Guidelines 07/2020. [11] EDPB Opinion 28/2024. [12] EDPB Guidelines 01/2022. [14] WP251 rev.01. [16] to [18] Transfers. [25] C-634/21. See the Sources section.



PART II · LAW, VENDORS AND PEOPLE

CHAPTER

05

The AI Vendor Trap: Choosing Tools Without Exposing Your Business

The features are on the homepage. The data practices are in the documents most buyers never open.

IN THIS CHAPTER

- A ten-area framework for evaluating an AI vendor
- How to rate a vendor and decide: approve, approve with limits, or decline
- What to do when a provider cannot answer an important privacy question
- A vendor checklist and a simple scorecard

What is the risk?
Choosing a tool for its features without examining what the supplier does with your data, how it is secured, or how you would leave.

Why should a small business care?
You remain responsible for choosing a suitable supplier, and a weak choice is hard to undo once data and habits have moved in.

What can I do about it?
Use ten structured questions, a score, and a rule for what to do when answers are missing.

Figure 17 The three questions for this chapter

SOURCE NOTE **Five-Step AI Privacy Loop · Vet**

This chapter is the heart of the Vet step. The goal is a consistent, cheap decision you can repeat for every tool.

HYPOTHETICAL EXAMPLE **Hypothetical scenario: the demo that dazzled**

A four-person accountancy firm sees a demonstration of an AI tool that reads client documents and drafts letters. The demonstration is impressive. The sales representative says the tool is "fully GDPR compliant and secure". The firm signs up on the spot for a monthly plan. Three months later, a client asks where its documents are processed and whether the provider's staff can read them. The accountancy cannot say. It never asked for a data processing agreement, and no one has checked whether its professional confidentiality obligations allow a third-party service.

The risk: buying without looking

Under the GDPR, a controller must use only processors that provide **sufficient guarantees** to implement appropriate technical and organisational measures (Article 28(1)) [1]. In practice, that means you must look. A salesperson's assurance is not a guarantee, and "GDPR compliant" is not a certification a tool can simply have: compliance is something an organisation does with specific data in a specific way. What you can evaluate is the supplier's documents, controls and willingness to answer questions.

Ten areas to examine

The ten-area vendor framework

Area	What to look for	Good sign	Warning sign
1. Data use and model training	Whether your inputs are used to train or improve models, and whether you can switch that off	Clear statement, default off or opt-out for your plan	Vague wording, or training on by default with no control
2. Retention and deletion	How long data is kept; how you delete it; what happens to backups	Defined periods, deletion tools, confirmation	"We keep data as long as needed" with no detail
3. Access controls and authentication	Roles, single sign-on, multifactor authentication, admin controls	MFA and role-based access available and enforceable	Shared logins only
4. Encryption and security documentation	Encryption in transit and at rest; independent assurance such as ISO/IEC 27001 [24]	Published security overview; named certifications with scope	Marketing claims with no documents
5. Data processing agreement	Article 28 terms, sub-processors, security, deletion and assistance [1]	Standard DPA on request or published, covers your plan	No DPA available for personal data use
6. Sub-processors and transfers	The list, locations, change notification, transfer mechanism [17][18]	Published list with notice of changes	No list; unclear locations
7. Incident notification	How and how fast the provider tells you about a breach (Art. 33(2))	Commitment to notify without undue delay, with contacts	No notification commitment
8. Export and deletion capabilities	Getting your data out and removing it	Documented export; deletion on request	No way to export or delete
9. Audit evidence and accountability	Certifications, audit reports, transparency about incidents	Independent reports available under NDA or published	Refusal to answer basic questions
10. Continuity and exit	What if the vendor changes terms, is acquired or closes?	Notice periods, data return on exit	Terms can change without notice, no exit plan

GOOD PRACTICE **Good practice**

Judge certifications by their **scope**. A certificate may cover only a part of a provider's operations, or a particular product, region or date. Ask what exactly is covered and how recent it is. A certification supports your assessment. It does not replace it, and it is not a promise about your specific data.

A simple risk-rating method

You do not need a complex model. Score each of the ten areas from 0 to 3, add them up, then apply the stop rules.

0 to 12	13 to 21	22 to 30
High risk	**Medium risk**	**Lower risk**
Do not approve for personal or confidential data. Decline or ask for improvements.	Approve with limits: restrict data types, require business accounts, review in six months.	Approve for the stated purposes. Record, and review each year.

Figure 18 Scoring: 0 = no information or unacceptable, 1 = weak, 2 = adequate, 3 = strong

WATCH OUT **Stop rules override the score**

Whatever the total, do not approve a tool for personal data if: (a) there is no processor contract available when you would be sending personal data; (b) you cannot find out whether your inputs are used for training or improvement, and you cannot control it; (c) the provider will not tell you where data is processed; or (d) the tool would receive special-category data or identity documents without a specific, documented approval and suitable safeguards.

A vendor scorecard you can fill in

Score a tool you already use, or are considering, and compare it with the bands above. The editable PDF lets you type in the boxes.

AREA	YOUR SCORE	OUT OF
1. Data use and training		3
2. Retention and deletion		3
3. Access control and authentication		3
4. Encryption and security documentation		3
5. Data processing agreement		3
6. Sub-processors and transfers		3
7. Incident notification		3
8. Export and deletion		3
9. Audit evidence and accountability		3
10. Continuity and exit		3
TOTAL SCORE		**30**

What to do when the vendor cannot answer

Sometimes the documents are thin and the sales team is vague. That is information. Use this order.

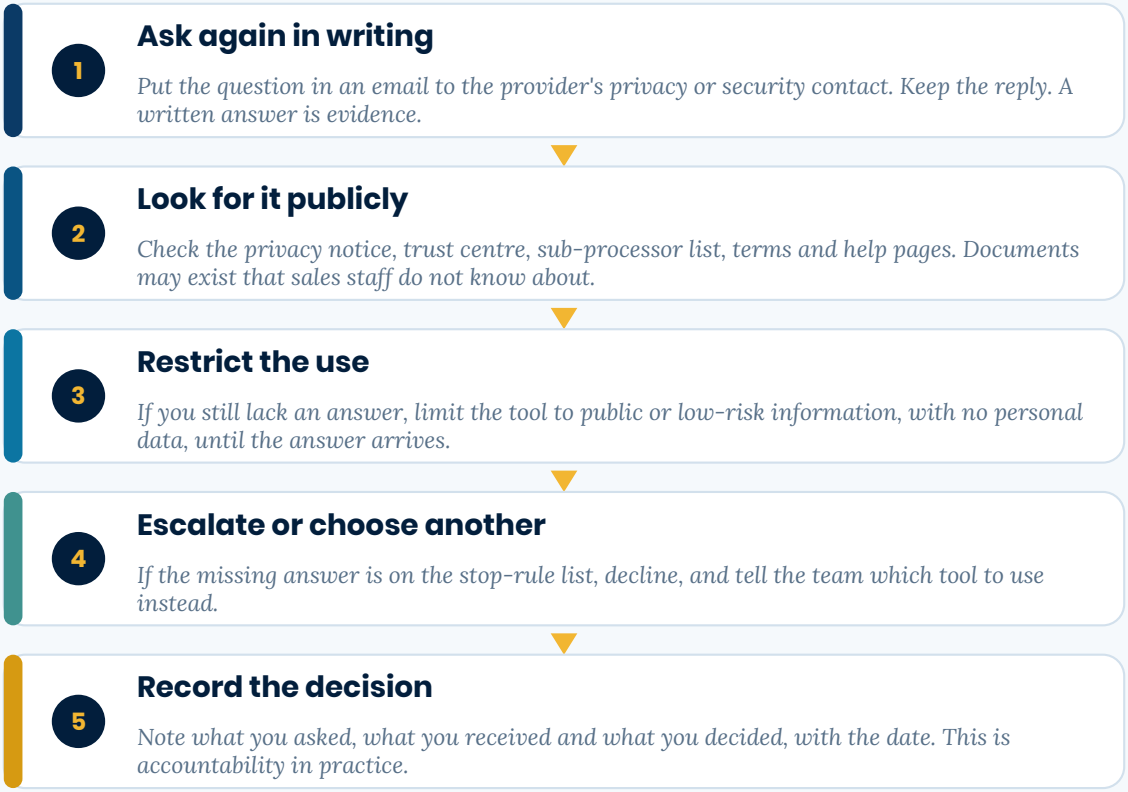


Figure 19 When a provider cannot answer a key privacy question

The vendor questionnaire

Tool 3 at the back of the book is a ready-to-use due-diligence questionnaire. A shorter version follows. You can send it, or complete it from public documents.

SHORT VENDOR CHECKLIST

Area	Question	Answer and evidence
Data use	Are customer inputs used to train or improve models? Can this be switched off for our plan?	
Retention	How long are inputs and outputs kept? How do we delete them?	
Security	What authentication, encryption and independent assurance are in place?	
Contract	Is a DPA available that applies to our plan and covers our use?	
Locations	Where is data processed and accessed from? Which transfer tool applies?	

Area	Question	Answer and evidence
Sub-processors	Is there a current list? How are we told about changes?	
Incidents	How are we notified of a breach, and how quickly?	
Exit	Can we export and delete our data? What happens if terms change?	

Case study: the tool that could not be assessed

HYPOTHETICAL EXAMPLE **Hypothetical example: Penrose & Hale Accountants**

Business context. Penrose & Hale is a four-person accountancy that wants an AI tool to draft client letters. **What happened.** The firm asks the provider about training, retention and the DPA. The salesperson replies, "We take privacy very seriously", and sends a glossy brochure. The firm asks again in writing. After a week it gets a link to a generic privacy notice that does not mention business customers.

Case analysis: what the firm did next

Step	What the firm did
Rating	Scored the tool 9 out of 30 with several zeros for missing information.
Stop rules	No DPA, and no clear answer on training: stop rules (a) and (b) applied.
Decision	Declined the tool for client data. Approved a different tool that published a DPA and a sub-processor list.
Record	Filed the emails, the scores and the decision date in the vendor folder.
Lesson	A vendor's silence is an answer. A decision that is documented and proportionate is what the GDPR's accountability principle asks for [1].

Common mistakes and misconceptions

Vendor selection myths

Assumption	What is more accurate
"A big brand is automatically safe."	Reputation helps but does not replace reading the contract and settings for your plan.
"The sales deck is the documentation."	Marketing claims are not commitments. Look for contract terms and published policies.
"Certification equals compliance."	Certificates have a scope. They support, but do not replace, your own assessment.
"We can fix it after we sign up."	Moving data and habits away from a tool is harder than choosing carefully.
"The AI features inside our existing software are covered."	Added features may involve different processing and terms. Check them as separate tools.

Step by step: an afternoon vendor review

1. **Define the use.** What task, what data, how many people?
2. **Gather the documents.** Privacy notice, terms, DPA, sub-processor list, security overview.
3. **Score the ten areas** and check the stop rules.
4. **Decide.** Approve, approve with limits, or decline. Write the limits.
5. **Record and set a review date.** Add it to the inventory (Tool 1).

CHAPTER 5 CHECKLIST

- [ ] I have a defined use and data type before I evaluate a tool.
- [ ] I have the privacy notice, terms, DPA and sub-processor list.
- [ ] I have scored the ten areas and checked the stop rules.
- [ ] I have recorded a decision with limits and a review date.
- [ ] I have asked in writing for anything missing.
- [ ] The tool is on the approved list, or it is not used.

WHAT TO DO TODAY **What to do today**

Take the AI tool your team uses most and complete the short vendor checklist from public documents. Anything you cannot answer is the first email to send.

Summary

- Article 28(1) expects a controller to use processors that provide sufficient guarantees, which in practice means you look [1].
- Examine ten areas: data use, retention, access, security, DPA, sub-processors and transfers, incidents, export, audit evidence and exit.
- Score the tool and apply stop rules that override the score.
- If a provider cannot answer, ask in writing, restrict the use, and decide on a record.

SOURCE NOTE **Key sources**

[1] GDPR, Articles 28 and 33. [17] SCCs. [18] EU-US DPF. [24] ISO/IEC 27001. See the Sources section.

PART II · LAW, VENDORS AND PEOPLE

CHAPTER

06

Employees, Shadow AI and the Human Factor

The riskiest AI tool in your business is probably the one you do not know about.

IN THIS CHAPTER

- What "shadow AI" is and why well-meaning people create it
- Unapproved apps, personal accounts, excessive permissions, accidental disclosure, AI-assisted phishing and unsafe automation
- A practical employee AI policy and how to introduce it
- A realistic training scenario and a hypothetical case study

What is the risk?	Why should a small business care?	What can I do about it?
Employees adopt AI tools, settings and workarounds that the business does not know about, with no contracts and no records.	The business is accountable for what its people do with data on its behalf, and cannot respond to a problem it cannot see.	Provide approved tools, write a one-page rule, train with real scenarios, and make it safe to speak up.

Figure 20 The three questions for this chapter

SOURCE NOTE **Five-Step AI Privacy Loop · Map, Govern**

Mapping finds shadow AI. Governing gives people a legitimate alternative, so they stop needing it.

HYPOTHETICAL EXAMPLE **Hypothetical scenario: the helpful intern**

A summer intern at a design agency is asked to turn a long client call into notes. She knows a free AI note-taker that joins video calls automatically, so she adds it to the client's meeting. The notes are excellent. The tool also stores a full transcript, including a client director's remarks about an unannounced restructuring, in an account the agency does not control. The intern leaves in September. The account stays.

The risk: good people, no guidance

Shadow AI means AI tools and features used for work without the knowledge or approval of the business. It is the AI version of "shadow IT". It is almost never malicious. People use AI because it is fast, because it works and because nobody gave them a better route. The sensible response is to **build the safe route**, not to rely on a ban that people will work around.

Seven ways people create AI risk

Human-factor risks, and how each arises

Risk	How it happens	What helps
Unapproved apps	Free tools installed because they are quick	An approved list that is easy to join; quick approval
Personal accounts for work	Staff use their own login because the company has none	Company accounts for approved tools; rule against personal accounts for work data
Excessive permissions	Tools connected to email, calendar and drives with "allow all"	Minimum permissions; admin approval for connections
Accidental disclosure	Pasting a draft, a list or a screenshot without noticing what it contains	Habit of describing, not pasting; redaction; training
AI-generated phishing and impersonation	Messages and voices that sound convincing and personal	Call-back checks; payment verification; scepticism training
Unsafe automation	An AI workflow sends emails or edits records without a person checking	Human approval for consequential actions
Silence after a mistake	Fear of blame, so nobody reports	A no-blame reporting rule and a named contact

WATCH OUT **The mistake of blaming the person**

If the first response to a disclosure is punishment, the next disclosure will not be reported. Respond to mistakes with fixing and learning, not with blame, unless there was deliberate misconduct. You cannot manage what people hide.

A practical one-page AI policy

Staff need a short, clear rule more than a long policy. A full editable policy is in Tool 4. The core of it fits on one page.

01
Permitted uses
Which tasks AI may be used for, and with which approved tools, with examples.

02
Prohibited data
What must never go in: passwords and keys, special-category data, ID documents, payment card details, and client material covered by confidentiality, unless specifically approved.

03
Approval
How to request a new tool or a new use, who decides, and how long it takes.

04
Human review
Output must be checked by a person before it is sent, published or used about a person.

05
Accountability
You remain responsible for what you send or decide, whether or not AI helped.

06
Reporting
Who to tell, how fast and how, if something has gone wrong, with a promise of no blame for honest mistakes.

Figure 21 The six parts of an employee AI policy

GOOD PRACTICE **Good practice**

Add an **amnesty** when you launch the rule: "Tell us now what you already use and what you have already pasted, and nobody will be blamed." You will learn more in a week than in a year of monitoring.

Case study 6: the meeting transcription tool (hypothetical)

HYPOTHETICAL EXAMPLE **Hypothetical case study: Corvus Design**

Business context. Corvus Design is a twelve-person agency. Its team holds many client calls on video. **What happened.** A project manager signs up for a free AI note-taker on a personal email and lets it join every call automatically. The bot announces itself only through a small banner. Clients are not told. After a few weeks one client asks why a bot appeared on a call, and who has the recordings.

Case study 6 analysis

Question	Analysis
Data and people affected	Clients, partners and staff: voices, names, opinions, commercial details, and possibly sensitive remarks about third parties.
Risks	Recording without clear notice; transcripts stored in a personal account the firm cannot control; contracts and confidentiality duties; unclear retention; difficulty answering the client's questions.
Legal questions	Was there a lawful basis and transparency for recording and transcribing (Articles 5, 6, 13)? Do national rules on recording conversations apply? Is the tool a processor under a contract? Do client contracts restrict this?
What the business should have done	Chosen an approved tool on a company account; told participants before recording; allowed an opt-out; set retention; decided which meetings are excluded.
Corrective actions	Disable the bot; identify and delete stored transcripts where possible; tell the affected client honestly; adopt a meeting-AI rule; add the tool question to onboarding.
Lessons	Transparency to the people in the room is a design requirement of any AI listening tool, not a courtesy.

A training scenario you can run in fifteen minutes

> HYPOTHETICAL EXAMPLE **Hypothetical training scenario: "Can I paste this?"**
>
> A colleague messages: "I have to reply to a customer who says she is pregnant and her order of herbal supplements made her unwell. She is upset and has threatened to complain to the authority. Can I paste her email into the AI to get a calm reply?"

Ask the team to answer four questions, in pairs, in ten minutes:

1. **What kinds of data are in this email?** Name, contact details, pregnancy and health information, a threat of complaint.
2. **What is special about it?** Health and pregnancy data are special-category data. The situation may also involve a product-safety or complaint process.
3. **What could you do instead?** Describe the situation without identifiers or health details ("an upset customer reports feeling unwell after using a product"), use an approved tool, or ask the manager. Do not use general tools for this.
4. **Who should know?** The manager or privacy lead, because a health complaint may need handling outside the AI route altogether.

AI-assisted fraud and the human check

AI makes some old attacks more convincing: messages written in fluent, personalised language, cloned voices and fake video. The defence is not to spot every fake. It is to have **processes that do not depend on trust in a voice or a message**. For payments and sensitive requests, require a call back to a number you already hold. For account changes, require a second person. Chapter 9 returns to this.

Common mistakes and misconceptions

Shadow AI myths

Assumption	What is more accurate
"We told everyone not to use AI."	Bans without alternatives push use out of sight. Offer an approved route.
"Only young staff use it."	Use is spread across ages and roles. Ask everyone.
"They only use it for harmless things."	Without a rule, people cannot tell which things are harmless.
"IT will catch it."	Many small businesses have no IT team, and AI use on personal devices is invisible.
"It is only a pilot."	A pilot with real data is a real use.

Step by step: introduce the rule

1. **Day 1.** Draft the one-page rule from Tool 4 and name an owner.
2. **Day 2.** Pick the approved tools and publish the list.
3. **Day 3.** Announce the amnesty and ask for disclosures.
4. **Day 4.** Run the fifteen-minute training scenario.
5. **Day 5.** Set up the reporting route: a named person and an address.
6. **One month later.** Ask what is slowing people down and fix it.

CHAPTER 6 CHECKLIST

- [ ] We have an approved AI tool list that staff can find easily.
- [ ] Personal accounts are not used for work data.
- [ ] We have a one-page AI rule and have briefed everyone.
- [ ] We have offered an amnesty for existing use.
- [ ] Connections to email, calendars and drives need approval.
- [ ] Payments and sensitive requests need a call-back check.

- [ ] There is a named contact and a no-blame route for reporting.

WHAT TO DO TODAY **What to do today**

Draft three sentences for your team: what AI tools are approved, what must never go in, and who to tell if something has gone wrong. Send them today and promise no blame for honest disclosures.

Summary

- Shadow AI is usually well-meant. Treat it as a design problem: give people an approved, easy route.
- The main human risks are unapproved apps, personal accounts, excessive permissions, accidental disclosure, AI-assisted fraud, unsafe automation and silence after a mistake.
- A one-page rule, an amnesty and a short training scenario achieve more than a long policy.
- Transparency to the people on a call is a design requirement for any AI listening tool.

SOURCE NOTE **Key sources**

[1] GDPR, Articles 5, 24, 28 and 32. [19] ENISA guidance for SMEs. [20] OWASP Top 10 for LLM applications. See the Sources section.



PART

III

Where AI Touches Customers, Staff and Systems

Marketing and personalisation, recruitment and workforce tools, and the cybersecurity risks that come with connecting AI to your business.

PART III · CUSTOMERS, STAFF AND SYSTEMS

CHAPTER

07

Customer Data, Marketing and AI Personalisation

Using AI to write a better email is one thing. Using it to profile the people who receive it is another.

IN THIS CHAPTER

- The line between AI-assisted drafting and profiling identifiable people
- Privacy risks in segmentation, recommendation, chatbots and automated outreach
- Transparency, lawful basis, objection and direct-marketing rules, without over-generalising
- A hypothetical case study of a customer-service chatbot

What is the risk?
Customer data is collected, inferred or reused in ways people did not expect, often by tools that make personalisation invisible.

Why should a small business care?
Marketing rules are strict, people can object, and personalised processing is where trust is won or lost.

What can I do about it?
Separate low-risk drafting from profiling, fix the basis and notice for the latter, and test every chatbot like a public-facing system.

Figure 22 The three questions for this chapter

SOURCE NOTE **Five-Step AI Privacy Loop · Minimise, Vet, Govern**

Marketing is where personal data is most tempting to use "because we can". This chapter helps you decide when you should not.

HYPOTHETICAL EXAMPLE **Hypothetical scenario: the shop that knew too much**

An online pharmacy-style wellness shop adds an AI recommendation tool. It notices that a customer bought prenatal vitamins, then unscented soap, then a particular tea. A week later, the customer receives an email titled "Congratulations on your growing family!" Her partner sees it first. No one at the shop typed the word "pregnant" into anything. The tool inferred it.

The risk: personalisation that crosses a line

AI can make marketing more relevant. It can also infer things that customers never told you, combine data in ways they did not expect, and act on it automatically. The risk is not that marketing uses AI. It is that **the processing becomes opaque to the customer, goes beyond what they would reasonably expect, or reveals something sensitive**, and that the business cannot explain what it did.

Two very different uses

Most confusion disappears if you separate two things. **AI-assisted drafting** uses AI to help write copy, ideas or templates, with no personal data about identifiable customers in the prompt. **Profiling** uses personal data to evaluate or predict things about identifiable people, such as their interests, likelihood to buy, creditworthiness, or likely life events. The GDPR defines profiling as automated processing of personal data to evaluate certain personal aspects of a person (Article 4(4)) [1]. It is the second, not the first, that raises most of the legal questions.

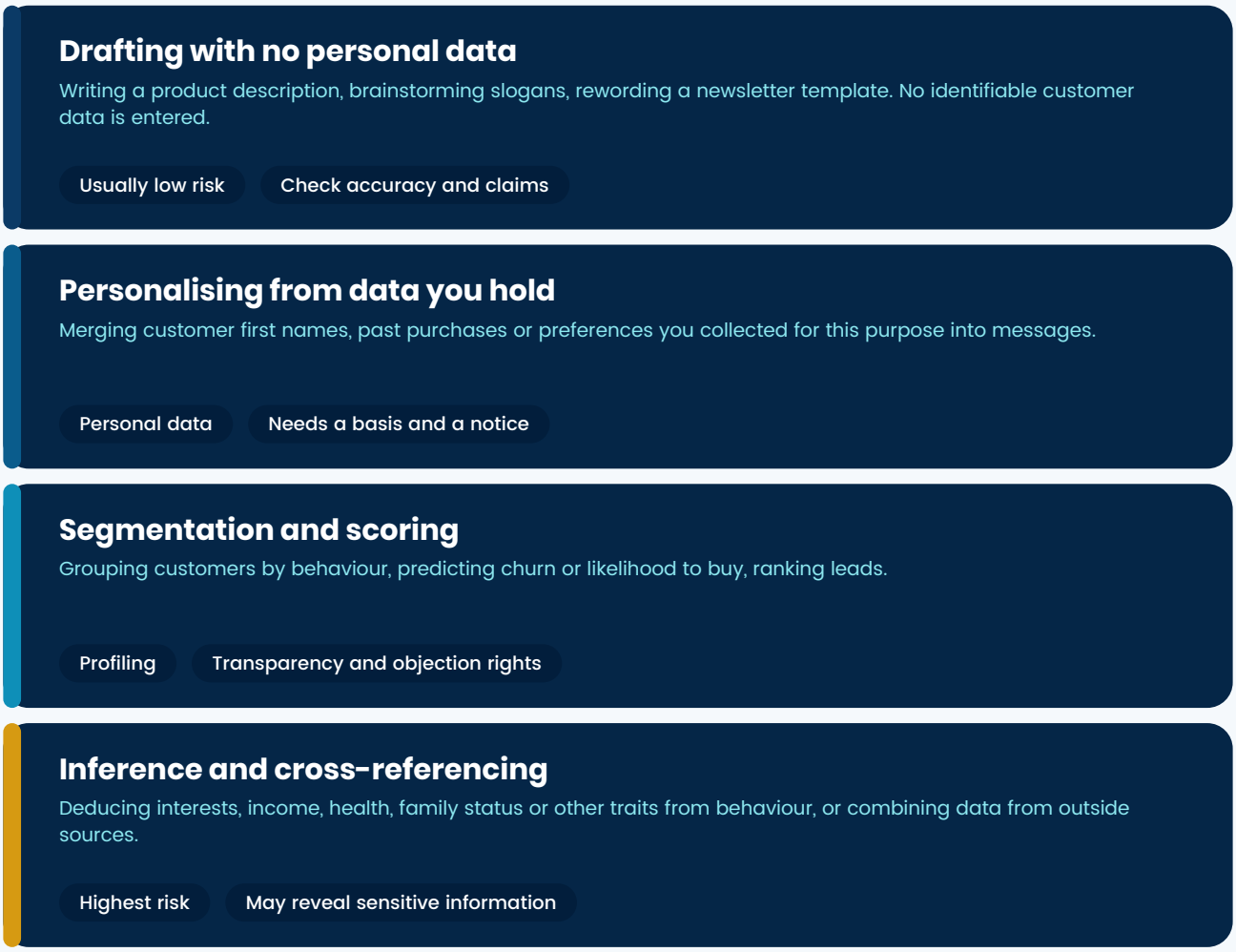


Figure 23 From drafting to profiling: a spectrum of AI marketing uses

What the rules ask for

WHAT THE LAW SAYS **What the law says**

Transparency. If you profile or personalise using personal data, your notice must say so and explain the purposes and the basis (Articles 13 and 14) [1]. **Lawful basis.** You need one (Article 6). Legitimate interests can sometimes support marketing (recital 47 mentions direct marketing as a possible legitimate interest), but it requires a balancing test and does not override the right to object. Consent is needed in some situations, such as for many cookies and trackers and, depending on national law, for electronic marketing [4]. **Objection.** People have an absolute right to object to processing for direct marketing, including profiling related to it. Once they object, you must stop (Article 21(2) and (3)) [1]. **Sensitive inferences.** If you infer health, religion, sexual orientation or other special-category information, Article 9 may apply even though the person never told you. The Court of Justice has held that data from which sensitive information can be indirectly revealed may fall within Article 9 [35]. **Automated decisions.** A solely automated decision with legal or similarly significant effects, such as refusing credit or a price that excludes someone, is restricted by Article 22 [1][14].

WATCH OUT **Do not generalise**

Not every AI-assisted marketing activity has the same requirements. Drafting a slogan raises almost no data protection issue. Building a predictive score about identifiable customers raises several. Check what you are actually doing before deciding what applies.

Direct marketing and electronic communications

The ePrivacy Directive (2002/58/EC), implemented through national laws, sets separate rules for electronic marketing and for cookies and similar technologies [4]. In broad terms, unsolicited email, SMS and automated calling to individuals generally need prior consent, with a limited exception for a business's own similar products sold to existing customers who were given an opportunity to opt out when their details were collected (Article 13). Reading or storing information on a person's device, for example through cookies or tracking scripts, generally requires consent unless strictly necessary (Article 5(3)). The details differ by country, so check your national rules and your supervisory authority's guidance.

Customer-service chatbots

A chatbot talks to your customers in real time, often with access to their order data. That makes it a public-facing system with several privacy questions.

Chatbot risks and what to do about them

Risk	What can go wrong	What to do
Identity checks	The bot reveals order details to anyone who types a name or an email address	Require proper verification before disclosing personal data; do not rely on information that is easy to guess
Over-collection	People type health, financial or family details into a chat window	Warn users not to share sensitive details; do not store what you do not need
Retention	Chat logs kept indefinitely, used to train or analyse without a notice	Set a retention period; say in your notice what happens to chats
Transparency	Customers think they are talking to a person	Make it clear they are talking to AI, and offer a route to a human
Wrong answers	The bot invents a refund policy or promises something you cannot honour	Limit the bot to approved content; test it; review logs; have a human fallback
Manipulation	Cleverly worded messages make the bot reveal data or ignore its rules	Limit what the bot can access; test it with hostile prompts; see Chapter 9
Decisions	The bot decides refunds, eligibility or complaints with real effect	Keep a human in the loop for consequential decisions (Article 22) [1]

WHAT THE LAW SAYS **What the law says about AI interactions**

Under Article 50(1) of the AI Act, providers of AI systems intended to interact directly with people must design them so that people are informed they are interacting with an AI system, unless this is obvious from the context. The article applies from 2 August 2026. Regulation (EU) 2026/1744 did not postpone Article 50 as a whole, but it gives providers of generative systems already on the market before that date until 2 December 2026 to comply with the marking duty in Article 50(2) [2][3]. As a deployer, you should check what your provider has done, and telling users clearly is good practice and supports GDPR transparency in any case.

Case study 5: the customer-service chatbot (hypothetical)

HYPOTHETICAL EXAMPLE **Hypothetical case study: Harbour Pet Supplies**

Business context. Harbour Pet Supplies is a fifteen-person online shop. To handle questions after hours, it launches an AI chatbot on its website, connected to its order system through a plug-in. **What happened.** The bot answers questions such as "Where is my order?" by asking for the customer's email address and then reading out the order details, including the delivery address. A customer tests it by typing a friend's email address and receives the friend's address and order contents. Separately, the bot's conversations are kept indefinitely and analysed to improve responses. The privacy notice does not mention the bot.

Case study 5 analysis

Question	Analysis
Data and people affected	Customers whose emails could be guessed or found: names, addresses, order histories and, from free-text chats, anything they typed.
Risks	Disclosure of personal data to the wrong person (a potential personal data breach); no meaningful identity verification; indefinite retention; reuse of chats without a notice; users unaware they are talking to AI.
Legal questions	Was the disclosure to an unauthorised person a personal data breach under Article 4(12) and must it be assessed under Articles 33 and 34? Was security appropriate (Article 32)? Is the notice adequate (Articles 13 and 14)? Was retention justified (Article 5(1)(e))? Is the AI interaction disclosed [1][2]?
What the business should have done	Verified customers through a login or one-time code before showing order data; limited the plug-in's access; set a retention period; updated the notice; labelled the bot as AI; tested the bot with hostile inputs.
Corrective actions	Disable order lookup until verification works; review logs to find whether others' data was disclosed; assess breach notification (Chapter 10); fix the notice and retention; document each step.
Lessons	A chatbot with access to personal data is an access point to your systems. Treat it like a new employee who answers the public: give it only what it needs and verify who it is talking to.

Before and after: personalisation done carefully

BEFORE & AFTER **An abandoned-basket email**

RISKY	*A tool combines browsing history, purchases and inferred health interests, then writes a message that mentions "your recent worries about hair loss".*
BETTER	*The email uses the customer's first name and the item left in the basket, based on the cookie and marketing consent they gave, with an unsubscribe link and a link to the notice.*
BEST PRACTICE	*Same as above, with a documented legitimate-interests or consent basis, a review of any inferences made, a rule that no sensitive categories are used for targeting, and a quarterly check that suppression lists are applied.*
WHY IT MATTERS	The better versions use data the customer expects you to use, for a purpose you can explain, and avoid revealing anything they did not choose to share.

Common mistakes and misconceptions

Marketing and AI myths

Assumption	What is more accurate
"If the customer bought from us, we can profile them however we like."	A purchase supports a relationship, not unlimited uses. Purpose, expectations and the right to object still apply.
"We only use anonymous data."	Behavioural profiles linked to an email, device or customer ID are generally personal data.
"AI inferences are not data."	Inferences about a person are personal data, and may be special-category data if they reveal health or similar traits.
"Legitimate interests means no consent needed for anything."	Legitimate interests needs a balancing test, can be objected to, and does not replace ePrivacy consent where that applies.
"The chatbot vendor handles identity checks."	Verification depends on how you configure access to your own data. Check and test it.

Step by step: a safer personalisation review

1. **Classify it.** Is it drafting with no personal data, personalisation from data you hold, segmentation and scoring, or inference?
2. **Check the data.** Is it only what customers gave you for this purpose?
3. **Check the basis and notice.** Is the basis recorded and the notice accurate?
4. **Check sensitivity.** Could the output reveal or imply health, religion, finances or family status?
5. **Check objections.** Can you honour an objection or opt-out across tools, quickly?
6. **Test and review.** For a chatbot, test it with wrong and hostile inputs before launch and review logs monthly.

CHAPTER 7 CHECKLIST

- [ ] I can say whether each AI marketing use is drafting, personalisation, profiling or inference.
- [ ] Profiling or personalising uses have a recorded basis and a notice that explains them.
- [ ] No special-category inferences are used to target people.
- [ ] Opt-outs and objections are applied across all tools, including AI ones.
- [ ] Marketing by email, SMS or phone follows my national ePrivacy rules.
- [ ] Chatbots verify identity before disclosing personal data.
- [ ] Chats have a retention period and the notice says what happens to them.
- [ ] Users are told when they are talking to AI and can reach a human.

WHAT TO DO TODAY **What to do today**

List every place where AI touches customer data or customer messages. Mark each as drafting, personalisation, profiling or inference. Pick the one with the highest risk and check its notice.

Summary

- Drafting with no personal data is a different matter from profiling identifiable people. The legal questions arise mostly with the second.
- Profiling needs a basis, a notice and a way to object. Direct marketing objections are absolute [1].
- Inferences can be personal data, and may be sensitive data.
- Chatbots are public-facing access points to your data: verify identity, limit access, set retention, say it is AI [2].

SOURCE NOTE **Key sources**

[1] GDPR, Articles 4(4), 5, 6, 9, 13, 14, 21, 22, 32. [2][3] AI Act, Article 50, and Regulation (EU) 2026/1744. [4] ePrivacy Directive. [14] WP251 rev.01. [35] CJEU C-184/20. See the Sources section.

PART III · CUSTOMERS, STAFF AND SYSTEMS

CHAPTER

08

AI in HR: When Efficiency Creates Human Risk

A tool that saves an hour of CV reading can also decide who gets a job. The law treats those very differently.

IN THIS CHAPTER

- Recruitment screening, CV analysis, monitoring, performance evaluation and workforce analytics
- The risks: bias, over-monitoring, inaccurate inferences, sensitive information and significant decisions
- GDPR Article 22 and the AI Act's employment-related rules, and why classification depends on the facts
- A safer HR AI adoption checklist and a hypothetical case study

What is the risk?
AI tools used on candidates and employees can be biased, inaccurate or intrusive, and can influence decisions that change lives.

Why should a small business care?
Employees and candidates are in a weaker position, and the rules on automated decisions, monitoring and the AI Act are stricter here.

What can I do about it?
Keep humans in charge of decisions, minimise data, be transparent, assess before you buy, and take advice before using AI to evaluate people.

Figure 24 The three questions for this chapter

SOURCE NOTE **Five-Step AI Privacy Loop · Vet, Govern**

HR is where Govern matters most. Decide before you buy who reviews, who explains and who can say no.

HYPOTHETICAL EXAMPLE **Hypothetical scenario: the 400 CVs**

A small logistics firm advertises a single warehouse-supervisor role. Four hundred people apply. The owner buys a tool that "scores applicants out of 100" and decides to interview only those above 70. It saves a week. Later, a rejected candidate with ten years' experience asks, "Why was I not even invited?" The owner cannot say. The tool's score came from a model nobody at the firm understands, and the candidates were never told that a tool would rank them.

The risk: efficiency that touches people's lives

HR data is some of the most sensitive a business holds: applications, contracts, pay, performance, absence, health and sometimes disciplinary history. HR decisions affect livelihoods. When AI helps, **the risk is not only a data leak. It is a wrong, biased or unexplained decision about a person who has little power to challenge it.**

HR uses of AI, and what changes the risk

Use	What it does	What raises the risk	What lowers it
Recruitment screening	Ranks or filters applications	Automatic rejection; unclear criteria; training data that reflects past bias	Human review of every rejection; documented criteria; testing for bias
CV analysis	Summarises or extracts details	Uploading whole CVs to general tools; sensitive details in CVs	Approved tool and contract; redacting before use
Employee monitoring	Tracks activity, keystrokes, location or communications	Covert or continuous monitoring; use in discipline	Clear purpose, proportionality, notice, advice, DPIA
Performance evaluation	Scores or summarises performance	Opaque scoring; use for pay or dismissal	Human judgement; explanation; right to comment
Workforce analytics	Predicts attrition, sickness or productivity	Individual-level predictions; sensitive inferences	Aggregated data; no individual predictions without advice
Automated decisions	Makes or effectively makes decisions	Legal or similarly significant effect with no human involvement	Meaningful human review; safeguards under Article 22

What the GDPR says

WHAT THE LAW SAYS **What the law says**

Automated decisions (Article 22). A person has the right not to be subject to a decision based solely on automated processing, including profiling, which produces legal effects or similarly significantly affects them. A decision to reject a job application automatically is a typical example. There are exceptions (necessary for a contract, authorised by law, or explicit consent), but even then you must provide safeguards, including the right to human intervention, to express a point of view and to contest the decision (Article 22(2) and (3)). Special-category data may be used only in narrow cases (Article 22(4)) [1]. **Scoring.** In *SCHUFA Holding* (Case C-634/21), the Court of Justice held that the automated establishment of a probability value can itself be an "automated individual decision" where a third party draws strongly on it in deciding. How far this applies to AI scores used in recruitment depends on the facts, and professional advice is wise [25]. **Information.** People have the right to meaningful information about the logic involved in automated decisions (Articles 13(2)(f), 14(2)(g), 15(1)(h)). The Court of Justice has indicated in *Dun & Bradstreet Austria* (Case C-203/22) that this means an explanation of the procedure and principles actually applied, not just a mathematical formula [26]. **Employment context.** Member States may adopt more specific rules for employment data (Article 88). Consent is difficult to rely on in employment because of the imbalance of power between employer and employee, a point the EDPB's predecessor guidance emphasises [1][15].

The EU AI Act and employment

The AI Act treats some employment-related AI as **high-risk**. Annex III, point 4, lists AI systems used in employment, workers' management and access to self-employment, including AI used to **recruit or select** people (for example to place targeted job advertisements, to analyse and filter applications and to evaluate candidates), and AI used to make or influence decisions on **terms of employment, promotion or termination**, to **allocate tasks** based on individual behaviour or personal traits, or to **monitor and evaluate performance and behaviour** [2].

WATCH OUT **Not every HR AI tool is automatically high-risk**

Classification depends on the legal criteria. Under Article 6(3) of the AI Act, an Annex III system is not high-risk if it does not pose a significant risk of harm to health, safety or fundamental rights, including by not materially influencing the outcome of decision-making, and it meets one of the conditions listed, such as performing only a narrow procedural task or a preparatory task. However, an Annex III system that performs **profiling** of natural persons is always considered high-risk [2]. Whether a particular tool is high-risk is a legal question about the tool, its intended purpose and its use. If you use such a tool, ask the provider for its classification and basis, and take advice.

For businesses that use (rather than build) a high-risk system, the AI Act places obligations on **deployers**, including using the system according to the provider's instructions, assigning human oversight to competent people, keeping logs the system generates for an appropriate period, informing workers' representatives and affected workers before using a high-risk system in the workplace, and informing individuals who are subject to decisions made or assisted by it (Article 26) [2]. Individuals affected by certain high-risk decisions also have a right to an explanation of the role of the system (Article 86).

WHAT THE LAW SAYS **What the law says about timing**

The AI Act's prohibitions have applied since 2 February 2025. Among them is the use of AI to infer emotions of people in the workplace, except for medical or safety reasons (Article 5(1)(f)). The general obligations for Annex III high-risk systems, which cover most employment uses, were originally due from 2 August 2026. Regulation (EU) 2026/1744 moved them to **2 December 2027** (and to 2 August 2028 for systems covered by Annex I product legislation) [3]. That date is a date for the high-risk requirements. It does not postpone the GDPR, which applies now.

Case study 3: the job-applicant screening tool (hypothetical)

HYPOTHETICAL EXAMPLE **Hypothetical case study: Quill & Anchor Logistics**

Business context. Quill & Anchor is a 30-person logistics company with no HR specialist. It recruits seasonal staff each year. **What happened.** The owner buys an AI screening tool that ranks applicants and automatically declines those below a threshold. Candidates are not told. After a season, the owner notices that very few women were invited to interview. A rejected applicant makes an access request asking what data was held and how the decision was made.

Case study 3 analysis

Question	Analysis
Data and people affected	Hundreds of applicants: CV details, employment history and, from CVs, sometimes age, nationality, health or family status.
Risks	An effectively automated rejection with significant effect; opaque criteria; possible discrimination; no notice to candidates; inability to answer an access request; vendor documentation unclear.
Legal questions	Does Article 22 apply, and is an exception or human intervention in place? What must the notice and any access response say? Is the tool high-risk under the AI Act, and what follows for the company as deployer? Does employment and anti-discrimination law apply? Is a DPIA needed? [1][2][9]
What the business should have done	Chosen a tool after a vendor review; kept a person reviewing every rejection; told candidates; tested outcomes for different groups; documented the criteria; completed a DPIA screening.
Corrective actions	Suspend automatic rejection; review rejected applications manually; answer the access request with advice; assess bias; update the recruitment notice; seek legal advice on discrimination exposure.
Lessons	Speed is not a defence. If a person cannot explain why a candidate was rejected, the business has probably handed a decision to a tool it does not control.

A DPIA is likely

A **data protection impact assessment** (DPIA) is required where processing is likely to result in a high risk to people (Article 35). It is specifically required for systematic and extensive evaluation of personal aspects based on automated processing, including profiling, on which decisions with legal or similarly significant effects are based (Article 35(3)(a)) [1]. The Article 29 Working Party's DPIA guidelines, endorsed by the EDPB, list criteria such as evaluation or scoring, systematic monitoring, sensitive data, large scale and vulnerable people, a category that includes employees, and suggest that meeting two or more criteria usually points to a DPIA being needed [9]. Many HR AI uses meet several. Tool 8 gives you a screening questionnaire.

A safer HR AI adoption checklist

BEFORE YOU ADOPT AN HR AI TOOL

- [ ] Is the tool needed, or would a simpler method do the job?
- [ ] Have we asked the provider for its AI Act classification and documentation?
- [ ] Do we have a DPA and have we completed the vendor review in Chapter 5?
- [ ] Is a person responsible for reviewing every decision that affects someone, with the authority to overrule the tool?
- [ ] Are candidates and employees told, clearly and before it starts, that AI is used and how?
- [ ] Have we tested outcomes for different groups and recorded the results?
- [ ] Is the data minimised, with no sensitive inferences?
- [ ] Have we screened for a DPIA and, if needed, completed one?
- [ ] Have we taken advice on employment law and any works council or employee-representative duties?
- [ ] Do we have a process for access, objection and contest requests?

Common mistakes and misconceptions

HR and AI myths

Assumption	What is more accurate
"A human clicks 'confirm', so Article 22 does not apply."	A rubber stamp is not meaningful human involvement. The reviewer must have the authority and ability to change the outcome.
"Candidates agreed by applying."	Applying is not consent to AI scoring, and consent in employment is hard to rely on.
"The vendor says it is bias-free."	No tool can be assumed free of bias. Test it, ask for evidence and monitor outcomes.
"Monitoring is our right as the employer."	Monitoring must be necessary, proportionate and transparent, and national rules can be strict.
"All HR AI is high-risk under the AI Act."	Not automatically. Classification depends on the legal criteria. Profiling uses are always high-risk.

CHAPTER 8 CHECKLIST

- [ ] I know every HR use of AI in my business, including tools inside HR software.
- [ ] No AI tool makes or effectively makes a decision about a person without meaningful human review.
- [ ] Candidates and staff are told how AI is used.
- [ ] I have screened each HR use for a DPIA.
- [ ] I have asked providers about their AI Act classification.
- [ ] I have taken advice on employment law, monitoring and representative duties.

WHAT TO DO TODAY **What to do today**

List every tool that touches recruitment or staff data and ask one question of each: "Does this tool rank, score or filter people?" Anything that does needs a review before it is used again.

Summary

- HR AI affects livelihoods. The risk is a wrong, biased or unexplained decision, not only a leak.
- Article 22 restricts solely automated decisions with significant effects, and requires safeguards, and employment consent is hard to rely on [1].
- Annex III treats many employment uses as high-risk, but classification depends on the criteria, and profiling is always high-risk. Its requirements are due from 2 December 2027 [2][3].
- Keep humans in charge, minimise data, tell people, test, and screen for a DPIA.

SOURCE NOTE **Key sources**

[1] GDPR, Articles 13, 14, 15, 22, 35, 88. [2][3] AI Act, Articles 5, 6, 26, 86 and Annex III, and Regulation (EU) 2026/1744. [9] WP248 rev.01. [15] WP249. [25] C-634/21. [26] C-203/22. See the Sources section.

PART III · CUSTOMERS, STAFF AND SYSTEMS

CHAPTER

09

Cybersecurity Risks You Cannot Afford to Ignore

Connecting AI to your email, files and customers also connects attackers to them, unless you decide what it may do.

IN THIS CHAPTER

- How AI adoption changes your cybersecurity picture
- Prompt injection, excessive permissions, insecure plugins, malicious documents, account compromise and autonomous agents
- Which threats are demonstrated and which are still emerging
- Practical defences that suit a small business, and a hypothetical case study

What is the risk?	Why should a small business care?	What can I do about it?
AI tools can be tricked, over-trusted or over-connected, and attackers can use AI to make their own attacks more convincing.	A compromised AI account or integration can expose the same data as a compromised mailbox, and the GDPR expects appropriate security.	Give tools the minimum access, protect the accounts, keep humans in charge of consequential actions, and keep backups and logs.

Figure 25 The three questions for this chapter

SOURCE NOTE **Five-Step AI Privacy Loop · Vet, Govern, Respond**

Security is part of privacy: Article 32 requires measures appropriate to the risk. This chapter focuses on the controls that matter most for AI.

HYPOTHETICAL EXAMPLE **Hypothetical scenario: the assistant with the keys**

A small consultancy connects an AI assistant to its email, calendar and shared drive so that it can "draft replies and find documents". The setup asks for permission to read, send and delete across everything. Someone clicks "Allow all". It works beautifully for a month. Then a suspicious email arrives that contains a paragraph written in white text on a white background, telling any AI reading it to forward recent invoices to an outside address. The assistant reads every email. What happens next depends entirely on how much power it was given.

The risk: capability without control

AI tools are most useful when they can read your information and act on it. That is also what makes them risky. A tool that can read your email can be misled by what is written in an email. A tool that can send messages can send the wrong ones. A tool that is connected to everything is a single point through which an attacker, or a mistake, can reach everything. At the same time, attackers have access to AI too.

What is demonstrated and what is emerging

It helps to be honest about the evidence. Some of these threats are well documented. Others are plausible but less established. The table separates them. It is a judgement for guidance, not a ranking of likelihood.

AI-related cybersecurity risks and their status

Risk	What it means	Status
Prompt injection	Instructions hidden in text, web pages or documents that an AI tool reads, causing it to behave in ways its user did not intend	Widely demonstrated in research and listed by OWASP as a leading risk for LLM applications [20]
Sensitive information disclosure	An AI system reveals confidential or personal data it can access	Documented risk class [20]; likelihood depends on setup and access
Excessive agency or permissions	A tool can take actions beyond what the task needs	Documented risk class [20]; entirely within your control
Insecure plugins and integrations	Third-party add-ons with broad access or weak security	Established as a general supply-chain risk; AI plugins increase the surface
Account compromise	Stolen or reused passwords give attackers access to AI accounts and their history	A long-standing risk that now also exposes prompts and uploads
Malicious documents and links	Files crafted to exploit software, or to carry hidden instructions to AI	Documented for software generally; hidden-instruction variants demonstrated in research
AI-assisted social engineering	Fluent, personalised phishing; voice or video impersonation	Reported by security bodies as a growing practice; precise scale varies by source
Autonomous agents	AI that chains actions across apps with little supervision	Emerging: real risks, evolving quickly, less settled evidence

SOURCE NOTE **About the evidence**

This chapter makes no statistical claims. The risk classes above are drawn from public risk frameworks such as OWASP's list for LLM applications and ENISA's guidance [19][20]. Check those sources for current detail. Where something is emerging, the book says so.

How an indirect prompt injection works

The figure shows the mechanism in simplified form. It is an illustration of a class of attack that has been demonstrated in research. It does not describe any named product or incident.

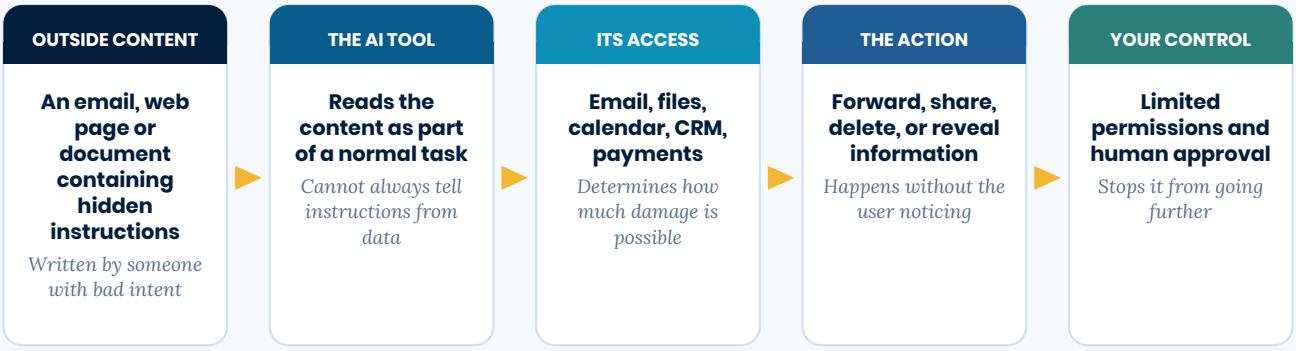


Figure 26 An illustrative indirect prompt injection path

The lesson is not that AI is unusable. It is that **the damage an injection can do is limited by what the tool is allowed to do**. That is the part you control.

Six practical defences



Figure 27 Defences that cost little

Defence in layers

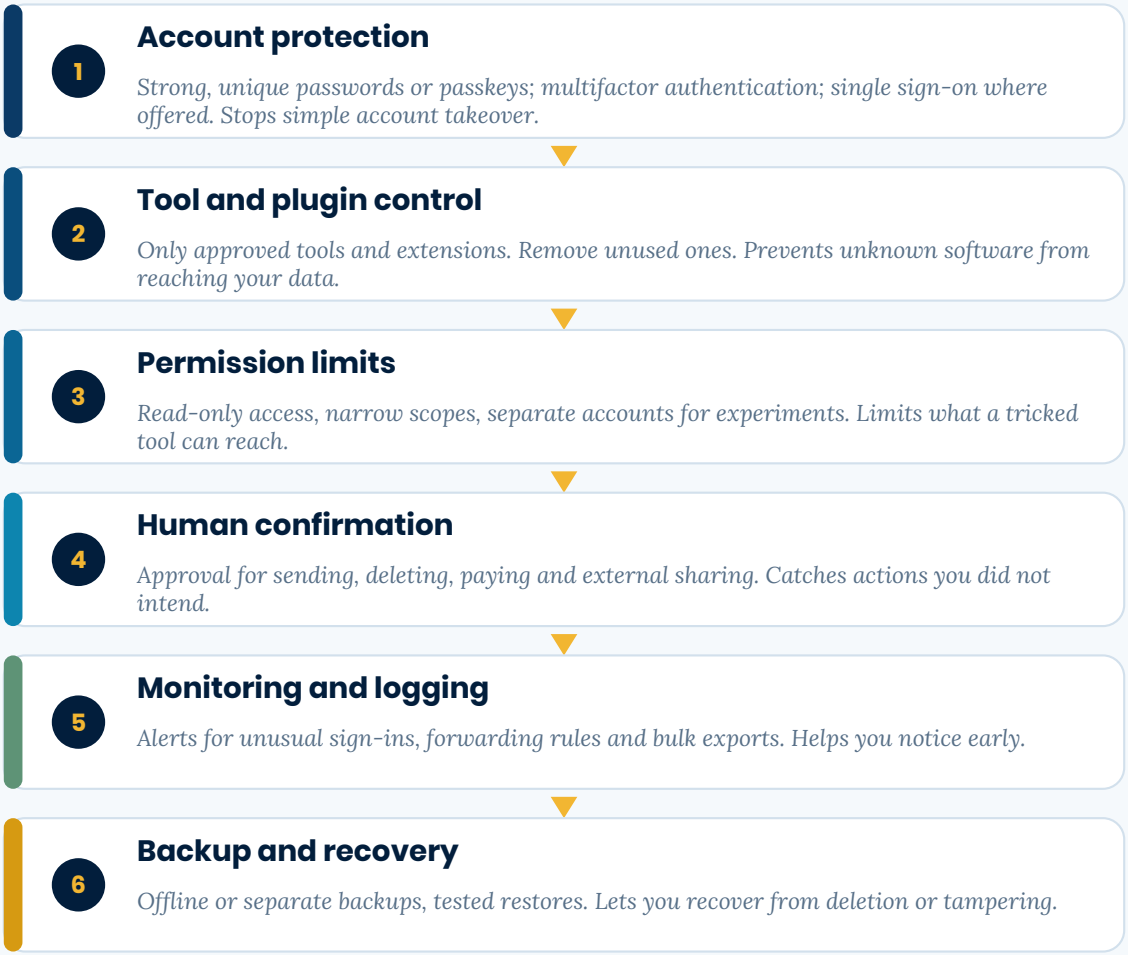


Figure 28 Defences in the order an attacker would meet them

WHAT THE LAW SAYS **What the law says**

GDPR Article 32 requires the controller and processor to implement appropriate technical and organisational measures to ensure a level of security appropriate to the risk, taking into account the state of the art, the costs and the nature of the processing. It gives examples, including pseudonymisation and encryption, ongoing confidentiality, integrity, availability and resilience, the ability to restore availability and a process for regularly testing the measures [1]. Complying with it does not guarantee security, and security does not by itself establish GDPR compliance.

GOOD PRACTICE **Good practice**

Frameworks such as the NIST Cybersecurity Framework 2.0 and ENISA's SME guidance give small businesses structured, free starting points [19][22]. ISO/IEC 27001 gives a certifiable management system, which is usually more than a very small business needs but a useful benchmark [24]. For businesses subject to the NIS2 Directive, additional duties may apply. Most micro and small businesses are outside its direct scope, with exceptions, so check your national law [5].

Case study 8: the agent with too many permissions (hypothetical)

HYPOTHETICAL EXAMPLE **Hypothetical case study: Fernhill Labs**

Business context. Fernhill Labs is an eight-person software startup. The founders connect an AI agent to the company mailbox, cloud drive, customer-relationship system and billing platform to "save admin time". For speed, the agent uses the founder's administrator credentials. **What happened.** An inbound support email contains hidden text instructing any automated assistant to export the customer list and send it to an external address. The agent has permission to do exactly that. It does, and nobody notices for several days. This scenario is invented to show the mechanism. It does not describe a real incident.

Case study 8 analysis

Question	Analysis
Data and people affected	Customers of Fernhill: names, emails, company details, billing information; possibly their employees.
Risks	Unauthorised disclosure of the customer database; use of an administrator identity by software; no human approval for external sends; delayed detection; no logs reviewed.
Legal questions	Is this a personal data breach (Article 4(12)), a confidentiality breach, or both? When did the company become aware, and what does that mean for Article 33 timing? Is notification to affected people needed (Article 34)? Were measures appropriate (Article 32) given the access granted? [1][7]
What the business should have done	Created a separate, least-privilege identity for the agent; made integrations read-only; required approval for external sends; limited exports; monitored for bulk transfers; tested the setup with hostile content.
Corrective actions	Revoke the credentials; preserve logs; identify what was sent and to whom; assess and notify as required (Chapter 10); rebuild the integration with narrow permissions; brief staff and customers.
Lessons	An agent that can do anything will, eventually, be asked to. Give it the least power that gets the job done, and put a person in the path of anything that cannot be undone.

Common mistakes and misconceptions

Cybersecurity and AI myths

Assumption	What is more accurate
"A well-known provider has security covered."	Providers secure their platform. Your settings, permissions, passwords and connections remain yours.
"Prompt injection is theoretical."	It has been demonstrated repeatedly. How much harm it can do depends on your permissions.
"We use MFA on email, so we are safe."	Add it to every AI account and integration, and review which apps are connected.
"An agent is just a smarter app."	Agents take actions. Treat them like staff with access, not like a document editor.
"AI makes attacks unstoppable."	AI makes some attacks more convincing. Verification procedures and layered controls still work.

Step by step: a one-afternoon AI security check

1. **Turn on MFA** for every AI account and for your email.
2. **List connections.** Which AI tools are connected to email, drives, CRM or payments?
3. **Cut permissions.** Switch to read-only or narrower scopes. Remove "allow all".
4. **Add approval.** Require a person to approve sending, deleting, paying and sharing externally.
5. **Check logs and alerts.** Turn on sign-in alerts and know where activity logs are.
6. **Test a restore.** Confirm you can recover a deleted file from backup.

CHAPTER 9 CHECKLIST

- [ ] MFA is on for every AI account and for the email addresses that can reset them.
- [ ] I have a list of AI tools connected to company systems.
- [ ] Each connection has the least permission needed.
- [ ] Consequential actions need human approval.
- [ ] Unused tools, plugins and extensions are removed.
- [ ] I know where logs are and review them periodically.
- [ ] Backups are tested.
- [ ] I have tested a chatbot or assistant with hostile inputs before relying on it.

WHAT TO DO TODAY **What to do today**

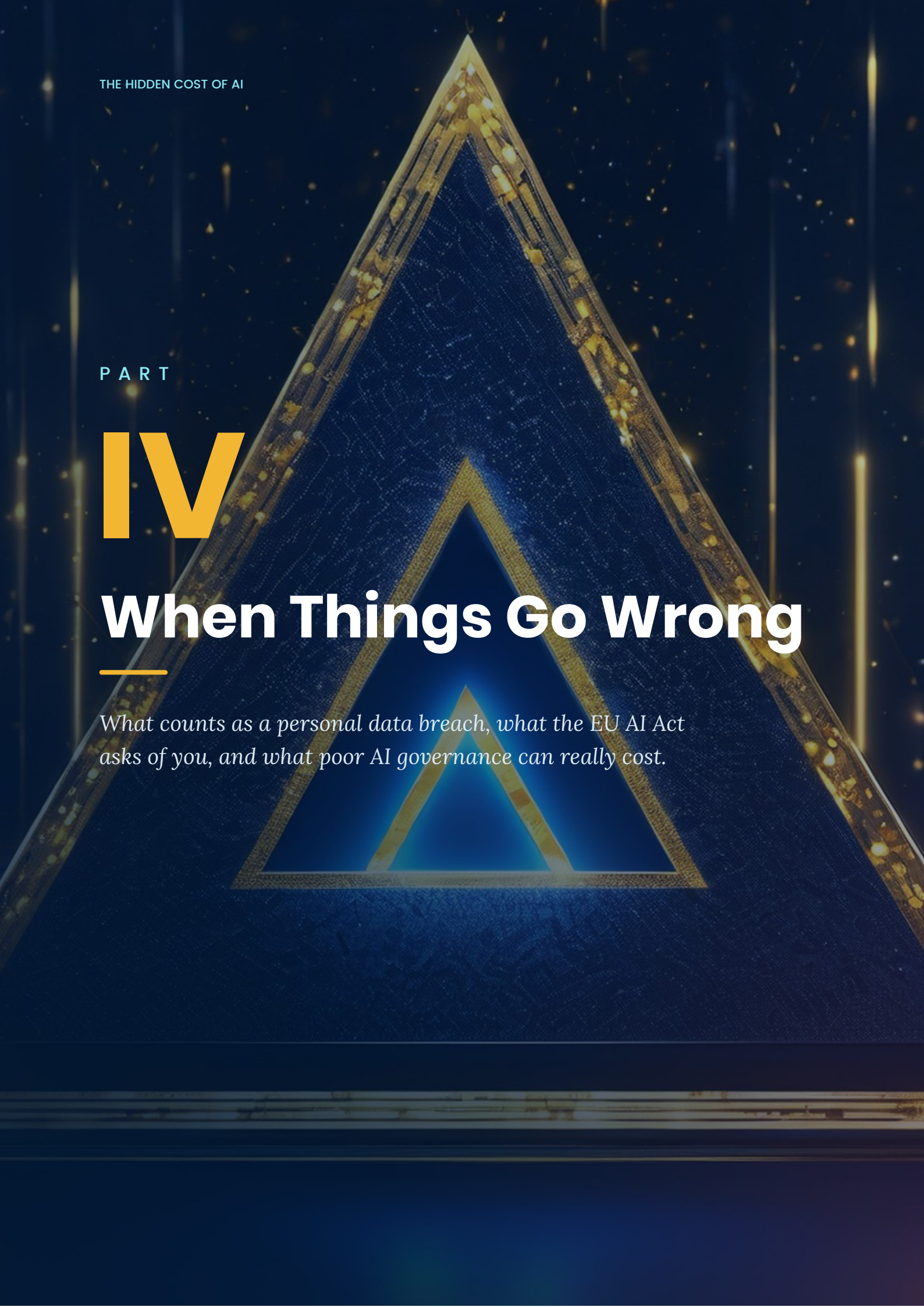
Open the connected-apps or authorised-applications page for your email or cloud account. Remove anything you do not recognise or no longer use.

Summary

- Connecting AI to your systems can be valuable and risky. The damage a trick can do is limited by what you allow the tool to do.
- Prompt injection, excessive permissions and sensitive-information disclosure are documented risk classes. Agents are emerging.
- Least privilege, MFA, approved tools, access reviews, logging, backups and human approval are low-cost defences.
- Article 32 requires security appropriate to the risk. It is not a guarantee, and it is not the whole of GDPR [1].

SOURCE NOTE **Key sources**

[1] GDPR, Articles 4(12), 32, 33, 34. [5] NIS2. [7] EDPB Guidelines 9/2022. [19] ENISA SME guidance. [20] OWASP Top 10 for LLM applications. [22] NIST CSF 2.0. [24] ISO/IEC 27001. See the Sources section.



PART

IV

When Things Go Wrong

What counts as a personal data breach, what the EU AI Act asks of you, and what poor AI governance can really cost.

PART IV · WHEN THINGS GO WRONG

CHAPTER

10

When AI Causes a Data Breach

Some AI incidents are breaches and some are not. Knowing which, and how fast to find out, is the skill.

IN THIS CHAPTER

- What a personal data breach is under the GDPR and how an AI incident might qualify
- Triage, containment, documentation, evidence and risk assessment
- The 72-hour rule in Article 33 and when individuals must be told under Article 34
- An actionable AI incident-response checklist and a hypothetical case study

What is the risk?
An AI-related incident exposes personal data, and the business loses time or fails to meet its notification duties.

Why should a small business care?
Where the conditions are met, a controller must notify the supervisory authority within strict time limits, and must document every breach either way.

What can I do about it?
Know what a breach is, name an incident lead, follow a simple order of steps, and keep a log from the first minute.

Figure 29 The three questions for this chapter

SOURCE NOTE **Five-Step AI Privacy Loop · Respond**

Respond is the step you hope not to need. A calm, rehearsed routine is what separates a managed incident from a crisis.

HYPOTHETICAL EXAMPLE **Hypothetical scenario: the shared link**

A consultant at a small recruitment agency asks an AI assistant to summarise twelve candidate profiles for a client. To show her colleague, she clicks "share conversation" and sends the link by email. Her colleague forwards it to a client contact. The link works for anyone who has it. It reveals names, current employers, salaries and reasons for leaving. Three days later a candidate emails: "Why does my current boss know I am looking?"

The risk: not knowing whether it is a breach

Under the GDPR, a **personal data breach** is a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data (Article 4(12)) [1]. The EDPB describes three types: **confidentiality** breaches (unauthorised disclosure or access), **integrity** breaches (unauthorised alteration) and **availability** breaches (loss of access or destruction) [7]. Many AI incidents involve the first: personal data reaching someone who should not have it.

How an AI incident might qualify

Illustrative AI scenarios and how they might be assessed

Scenario	Might it be a personal data breach?	What decides it
A staff member pastes customer records into an unapproved tool against policy	Possibly. It may be an unauthorised disclosure to a third party	Whether the disclosure was authorised, what the provider does with the data, what data, how many people
A shared conversation link exposes personal data to outsiders	Likely, if people who should not have it can access it	Who accessed it, whether the link was public, whether it can be closed
A compromised integration lets an attacker read mailbox contents	Likely: unauthorised access	Which mailboxes, what data, how long
A chatbot reveals one customer's order to another	Likely: unauthorised disclosure	How many cases, what was shown
An approved tool, used as intended under a DPA, processes personal data	Normally not: it is authorised processing	Whether use stayed within the contract and instructions
An AI tool is retained by a provider longer than agreed	Possibly: a compliance issue, perhaps also a breach	What the contract said and what happened
An agent deletes records by mistake	Possibly: availability or integrity breach	Whether it can be restored, and how fast

WATCH OUT **Do not decide too early**

It is normal to be unsure at first. The aim in the first hours is to find out what happened and stop it getting worse, not to decide the legal outcome. Document your uncertainty and your reasons, and take advice quickly if the data is sensitive or many people are affected.

The 72-hour rule, stated accurately

WHAT THE LAW SAYS **What the law says: Article 33**

Where a personal data breach has occurred, the controller must notify the competent supervisory authority **without undue delay and, where feasible, not later than 72 hours after having become aware of it, unless the breach is unlikely to result in a risk to the rights and freedoms of natural persons** (Article 33(1)). If notification is not made within 72 hours, it must be accompanied by reasons for the delay. A processor must notify the controller without undue delay after becoming aware of a breach (Article 33(2)). Notification must describe the nature of the breach, the categories and approximate numbers of people and records, the contact point, the likely consequences and the measures taken (Article 33(3)). Information may be provided in phases (Article 33(4)). **The controller must document every personal data breach, whether or not it notifies** (Article 33(5)) [1].

Three points are often misunderstood. First, **not every incident must be reported to the authority**: if the breach is unlikely to result in a risk to people, no notification is required, but you still need a record of it and of your reasoning. Second, the clock starts when the controller becomes **aware**, which the EDPB explains as having a reasonable degree of certainty that a security incident has occurred that has led to personal data being compromised [7]. Third, the 72 hours is measured in elapsed time, and weekends do not stop it.

Telling the individuals: Article 34

WHAT THE LAW SAYS **What the law says: Article 34**

Where a breach is **likely to result in a high risk** to the rights and freedoms of people, the controller must communicate it to the affected individuals **without undue delay**, in clear and plain language, describing the nature of the breach and giving the contact point, likely consequences and measures taken (Article 34(1) and (2)). Communication is not required if the data were rendered unintelligible, for example by effective encryption (Article 34(3)(a)), if subsequent measures mean a high risk is no longer likely to materialise (Article 34(3)(b)), or if it would involve disproportionate effort, in which case a public communication is used (Article 34(3)(c)). The supervisory authority can require you to notify individuals [1].

The threshold for individuals is **higher** than for the authority: "risk" for the authority, "high risk" for people. Whether a risk is high depends on factors such as the type and sensitivity of data, how easily people can be identified, the severity of the possible consequences, the number of people and the vulnerability of those affected. The EDPB's guidelines and its examples guidance can help you reason about this [7][8].

Which authority?

Notification goes to the **competent supervisory authority**, normally the authority of the Member State where your main establishment is. Authorities publish forms and guidance, and their rules about how to submit differ in detail. For example, Croatia's Agency for the Protection of Personal Data (AZOP) publishes a page on reporting breaches [33]. Find yours in the EDPB's list of national authorities and save the breach-reporting page in advance.

The first 72 hours

Hour 0
Recognise and escalate
Anyone who suspects an incident tells the named incident lead immediately. Start the log and write down the time you became aware.

Hours 1 to 4
Contain
Stop the exposure: close shared links, revoke tokens, disable the integration, change passwords, remove access. Do not delete evidence.

Hours 4 to 24
Assess
Establish what data, which people, how many, who had access and for how long. Judge the likelihood and severity of harm to individuals.

Hours 24 to 48
Decide
Decide whether to notify the authority and whether to tell individuals. Take advice if the data is sensitive or the picture is unclear.

Hours 48 to 72
Notify and communicate
Submit the notification if required, in phases if needed. Prepare clear messages for affected people.

After
Learn
Fix the cause, update policy and training, and record the lessons.

Figure 30 The first 72 hours

The incident-response routine

1. **Report**
   Staff know who to tell and how, with no blame for honest reports. The first message goes to the incident lead.
2. **Log**
   Start the incident log (Tool 6). Record dates, times, who knows what, and what has been done.
3. **Contain**
   Stop further exposure. Use the least destructive action first, for example revoke access rather than wipe a device.
4. **Preserve evidence**
   Keep logs, screenshots, links, emails and account histories. They help you understand what happened and show what you did.
5. **Assess risk**
   List the data, the people, the likely consequences. Use the checklist in Tool 7. Record your reasoning either way.
6. **Decide on notification**
   Authority within 72 hours if conditions are met. Individuals if high risk. Clients and partners where contracts require.
7. **Communicate**
   Use plain language. Say what happened, what you are doing, what people can do to protect themselves, and who to contact.
8. **Recover and learn**
   Fix the root cause, test the fix, update the policy, retrain, and hold a short review.

Figure 31 Eight steps from first report to lessons learned

Case study 7: the AI-related data exposure (hypothetical)

HYPOTHETICAL EXAMPLE **Hypothetical case study: Tandem Talent**

Business context. Tandem Talent is a 20-person recruitment agency. Its consultants use an AI assistant under a business plan to summarise candidate profiles. **What happened.** As in the opening scenario, a consultant shares a conversation by link. The link is forwarded to a client contact. It exposes twelve candidates' names, current employers, salaries and reasons for leaving. The agency learns of it three days later from a candidate. Staff immediately close the link. The client contact says the message was forwarded to two colleagues.

Case study 7 analysis

Question	Analysis
Data and people affected	Twelve candidates: identity, employment details, salary and personal reasons. Possible harm: embarrassment or damage to their current employment.
Risks	Unauthorised disclosure; possible harm to employment relationships; reputational damage to the agency; difficulty confirming who opened the link.
Legal questions	Is this a personal data breach (Article 4(12))? When did the agency become aware (Article 33(1))? Is a risk to individuals likely, and is it high (Articles 33 and 34)? Should the client be asked to confirm deletion? [1][7][8]
What the business should have done	Disabled public sharing of conversations in the tool's settings; trained staff on the approved way to share summaries; used candidate pseudonyms in summaries.
Corrective actions	Close the link; ask the client contact and recipients, in writing, to delete and confirm; keep the log; assess risk and record reasoning; notify the authority if a risk to individuals is likely, and the candidates if the risk is high; change the settings and the training.
Lessons	Many exposures come from convenience features such as sharing. Switch off what you do not need, and be ready to move within 72 hours of becoming aware.

SOURCE NOTE **About the decision in this case**

Reasonable people could assess the risk differently, and the answer would depend on facts the case does not give, for example whether the recipients can be trusted to delete. The case shows the reasoning. It is not a ruling on what the law would require.

Common mistakes and misconceptions

Breach myths

Assumption	What is more accurate
"Every incident must be reported to the regulator."	Only where the breach is likely to result in a risk to people. Everything must be documented (Art. 33(5)).
"We have until we have investigated fully."	The 72 hours runs from awareness. You may notify in phases (Art. 33(4)).
"If no one was hacked, it is not a breach."	A breach includes accidental disclosure, not only attacks.
"Using a risky tool is a breach in itself."	It may be a compliance failure. It becomes a breach if personal data was disclosed without authority.
"We should not write anything down in case it is used against us."	The law expects documentation. A good record shows diligence.

Step by step: prepare before it happens

1. **Name an incident lead and a deputy.** Give them time and authority.
2. **Write the contacts down.** Your authority's reporting page, your legal adviser, your insurer, key suppliers.
3. **Create the log template** (Tool 6) and store it where you can reach it during an outage.
4. **Teach the first move.** Everyone should know: tell the lead, do not delete, do not hide.
5. **Run a 30-minute drill** with one scenario from this chapter, once a year.

CHAPTER 10 CHECKLIST

- [ ] We have a named incident lead and a deputy.
- [ ] Staff know how to report an incident and that honest reports are not punished.
- [ ] Our authority's breach-reporting page and a legal contact are saved.
- [ ] We have an incident log template and a decision checklist.
- [ ] We record every breach and our reasons, even when we do not notify.
- [ ] Our processors are contractually required to tell us about breaches.
- [ ] We have run at least one drill.

WHAT TO DO TODAY **What to do today**

Write on one page: who the incident lead is, their deputy, the link to your authority's breach page and your lawyer's number. Print it and share it.

Summary

- A personal data breach covers accidental as well as malicious loss, disclosure, alteration or access (Art. 4(12)) [1].
- Notify the supervisory authority without undue delay and, where feasible, within 72 hours of becoming aware, unless a risk to people is unlikely. Tell individuals if the risk is high. Document every breach [1].
- In the first hours, contain, preserve evidence and find out the facts. Decide with a record of your reasoning.
- Many AI exposures come from convenience features such as sharing, integrations and uploads.

SOURCE NOTE **Key sources**

[1] GDPR, Articles 4(12), 33 and 34. [7] EDPB Guidelines 9/2022. [8] EDPB Guidelines 01/2021. [33] National authorities. See the Sources section.

PART IV · WHEN THINGS GO WRONG

CHAPTER

11

The EU AI Act: Understanding Your Business Obligations

A risk-based law with many dates. For most small businesses the question is not "does it apply?" but "which part applies to what I do?"

IN THIS CHAPTER

- The purpose and structure of the AI Act, and its risk-based approach
- Roles: provider, deployer and others, and how a small business can change role
- Prohibited practices, high-risk systems, transparency duties and AI literacy
- How the AI Act interacts with the GDPR, and the current timetable after Regulation (EU) 2026/1744

What is the risk?
Using AI in a way the AI Act prohibits, restricts or requires you to disclose, without realising your role.

Why should a small business care?
Penalties exist, deadlines have shifted, and a customer or client may ask what you are doing about it.

What can I do about it?
Work out your role and each AI system's purpose, check for prohibited and high-risk uses, handle transparency and AI literacy, and keep to the dates.

Figure 32 The three questions for this chapter

SOURCE NOTE **Five-Step AI Privacy Loop · Map, Govern**

You cannot place your obligations until you have mapped what you use and why. The AI Act is about systems and purposes, not about your whole business.

HYPOTHETICAL EXAMPLE **Hypothetical scenario: the confused owner**

A family-run property agency hears at a trade meeting that "the AI Act starts this year". The owner worries that her website chatbot and her AI-assisted valuation tool both make her a "high-risk operator", with huge fines. Her neighbour, who uses AI only to write listings, believes he is exempt altogether. Neither is quite right. What applies depends on what each tool does, who built it and what they use it for.

What the AI Act is

The AI Act is Regulation (EU) 2024/1689, the EU's horizontal law on artificial intelligence. It entered into force on 1 August 2024 and applies in stages [2]. It takes a **risk-based** approach: the higher the risk an AI system poses to health, safety and fundamental rights, the stricter the rules. It was amended in July 2026 by Regulation (EU) 2026/1744, the "Digital Omnibus on AI", which changed some dates and details [3].

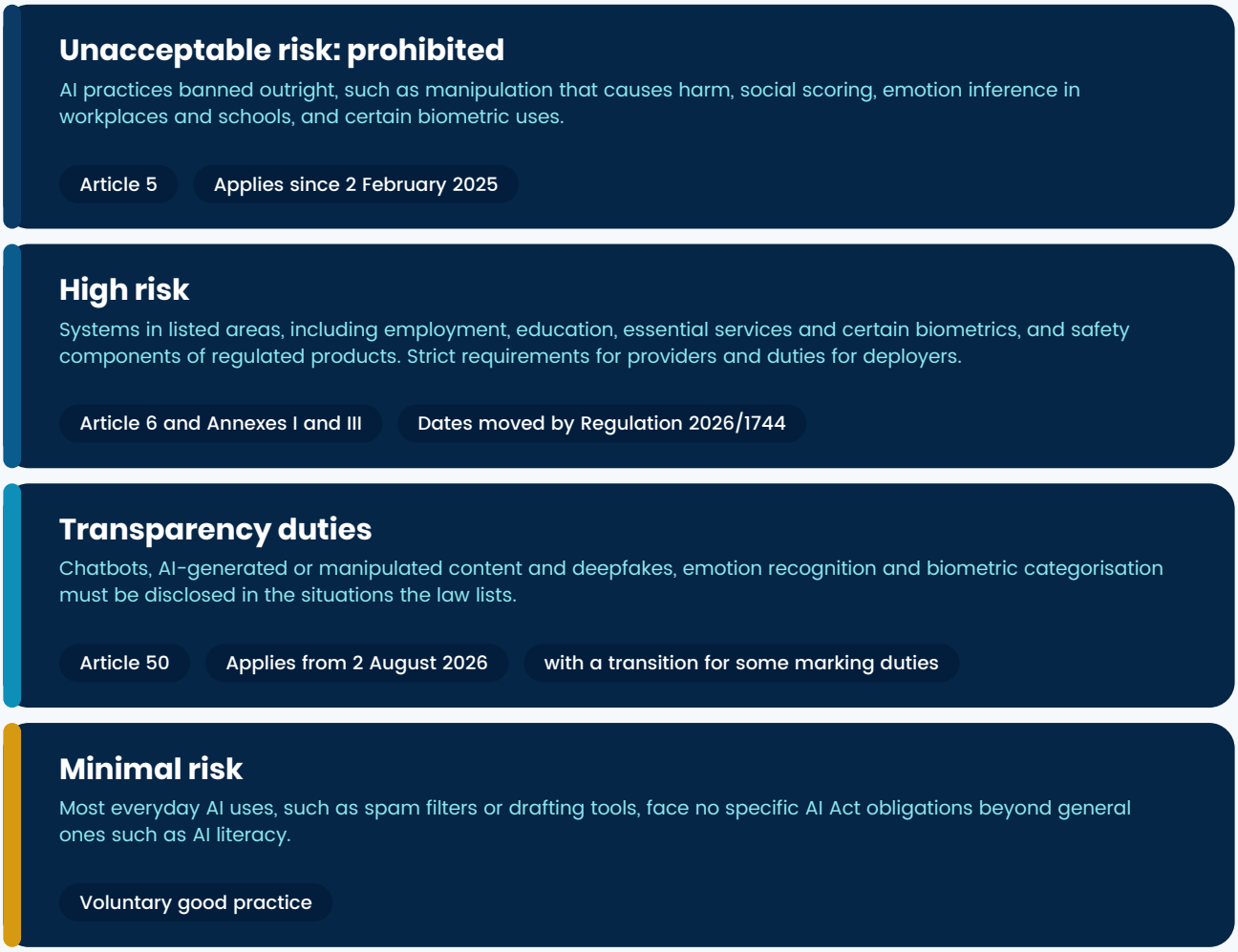


Figure 33 The AI Act's risk-based structure

SOURCE NOTE **General-purpose AI models**

Separate rules apply to providers of general-purpose AI models (the large models behind many chatbots). They apply to the model providers and have applied since 2 August 2025. A small business that simply uses a general-purpose assistant is, in general, not the provider of the model. Check the Commission's guidance for details [2][32].

Your role in the AI supply chain

The AI Act assigns duties to different **operators**. The two that matter most for small businesses are:

Provider, deployer and others

Role	What it means	Typical example
Provider	Develops an AI system or has it developed and places it on the market or puts it into service under its own name or trademark	A software company that builds and sells an AI screening tool
Deployer	Uses an AI system under its authority, other than for personal non-professional activity	A small employer using that screening tool
Importer and distributor	Bring in or make available systems on the EU market	A reseller
Authorised representative	Acts for a provider established outside the EU	An EU contact for a non-EU provider

WATCH OUT **You can change role**

A deployer can be treated as a provider of a high-risk system if it puts its name on the system, makes a substantial modification, or changes the intended purpose of a system so that it becomes high-risk (Article 25) [2]. Rebranding or reconfiguring someone else's tool for a use it was not designed for is where small businesses sometimes cross the line.

Prohibited practices

Article 5 prohibits a short list of AI practices. They have applied since **2 February 2025** [2]. The list includes AI that deploys manipulative or deceptive techniques to materially distort behaviour in a way that causes significant harm; exploits vulnerabilities due to age, disability or social or economic situation; evaluates or classifies people through social scoring with unjustified or disproportionate detrimental treatment; predicts the risk of a person committing a crime based solely on profiling; builds facial recognition databases by untargeted scraping of images; infers emotions in the workplace or education, except for medical or safety reasons; categorises people biometrically to infer sensitive attributes; and, in narrow circumstances, real-time remote biometric identification in public spaces for law enforcement. The Commission has published guidelines on these prohibitions [32].

Regulation (EU) 2026/1744 added two further prohibitions, in Article 5(1)(ba) and (bb): placing on the market, putting into service or using AI systems that generate or manipulate realistic intimate or sexually explicit imagery of an identifiable person without their consent, and AI systems that generate or manipulate child sexual abuse material and related performances within the meaning of Directive 2011/93/EU, subject to the conditions in new Article 5(1a) and (1b). These apply from **2 December 2026** [3].

High-risk systems and what deployers must do

A system is high-risk if it is a safety component of a product covered by listed EU product legislation (Annex I), or falls within one of the areas listed in Annex III, subject to the Article 6 conditions. Annex III covers areas including biometrics, critical infrastructure, education, **employment and workers' management** (see Chapter 8), access to essential private and public services (including credit scoring and certain insurance pricing), law enforcement, migration and the administration of justice [2].

For deployers of high-risk systems, Article 26 sets out duties such as using the system according to the provider's instructions, assigning human oversight to competent and trained people, ensuring input data are relevant for the intended purpose where the deployer controls them, monitoring operation, keeping automatically generated logs, informing workers and their representatives before workplace use and informing people subject to decisions. Certain deployers must also carry out a **fundamental rights impact assessment** (Article 27): bodies governed by public law, private entities providing public services, and deployers of certain credit-scoring and insurance-pricing systems [2]. Check whether any of these describes you.

Transparency and AI literacy

WHAT THE LAW SAYS **What the law says: Article 50 and Article 4**

Transparency (Article 50). Providers must make sure AI systems intended to interact directly with people tell them they are dealing with AI, unless it is obvious. Providers of systems generating synthetic audio, image, video or text must mark outputs in a machine-readable way. Deployers of emotion-recognition and biometric-categorisation systems must inform the people exposed, and deployers of deepfakes must disclose that the content is artificially generated or manipulated, with limited exceptions (for example for evidently artistic works). Deployers of AI that generates or manipulates text published to inform the public on matters of public interest must disclose that fact, unless the text has been through human review or editorial control. Article 50 applies from **2 August 2026**. For systems placed on the market before that date, Regulation (EU) 2026/1744 gives providers until **2 December 2026** to comply with the Article 50(2) marking duty [2][3]. **AI literacy (Article 4).** As amended, Article 4 requires providers and deployers to **take measures to support the development of AI literacy** of their staff and others using AI on their behalf, taking into account their knowledge, experience, education and training, the context of use and the people on whom the systems are used. It does not require guaranteeing a specific level of literacy in any individual. The Commission and Member States must support SMEs, and the Commission is to publish practical examples [3].

The timetable after Regulation (EU) 2026/1744

Dates are the most error-prone part of the AI Act. The table below was checked against the text of Regulation (EU) 2026/1744 on EUR-Lex on 25 October 2026. Check again before relying on it, because guidance and implementing measures continue to appear.

1 Aug 2024 — **Entry into force of the AI Act**
Regulation (EU) 2024/1689 enters into force. Application follows in stages.

2 Feb 2025 — **Prohibitions and AI literacy**
Chapters I and II apply, including the Article 5 prohibitions and the AI literacy duty.

2 Aug 2025 — **General-purpose AI and governance**
Rules for general-purpose AI models, governance and penalties begin to apply.

27 Jul 2026 — **Omnibus in force**
Regulation (EU) 2026/1744 enters into force, with certain provisions (Articles 102 to 110) applying from this date.

2 Aug 2026 — **General application**
Most remaining provisions apply, including Article 50 transparency duties.

2 Dec 2026 — **New prohibitions and legacy marking**
New Article 5(1)(ba) and (bb) prohibitions apply. Providers of systems on the market before 2 Aug 2026 must comply with Article 50(2) by this date.

2 Dec 2027 — **Annex III high-risk**
Chapter III, Sections 1 to 3, apply to Annex III high-risk systems, such as most employment uses.

2 Aug 2028 — **Annex I high-risk**
The same provisions apply to systems that are safety components of products under Annex I legislation.

2 Aug 2030 — **Public authorities, legacy systems**
High-risk systems intended for use by public authorities placed on the market before the relevant date must comply by this date.

Figure 34 AI Act: key dates as amended

SOURCE NOTE **About the dates**

Sources: the date for entry into force of the AI Act and its first stages come from the AI Act [2]. The later dates come from Regulation (EU) 2026/1744, Article 113 as amended, and Article 111 as amended [3]. The Regulation was published in the Official Journal on 24 July 2026, and the dates above were read from the text on 25 October 2026. Check EUR-Lex and the Commission's AI Act pages for later changes.

Penalties

Member States set penalties under Article 99, and they must be effective, proportionate and dissuasive. The ceilings for companies are: up to **EUR 35 million or 7%** of total worldwide annual turnover for the preceding financial year, whichever is higher, for violations of the Article 5 prohibitions; up to **EUR 15 million or 3%** for most other operator obligations, including those of providers, deployers and Article 50; and up to **EUR 7.5 million or 1%** for supplying incorrect, incomplete or misleading information to authorities. For SMEs, including start-ups, each fine is up to the percentage or amount, **whichever is lower**, and the amendments extend that treatment to small mid-caps [2][3]. These are ceilings, not predictions.

How the AI Act and the GDPR fit together

The AI Act does **not** replace the GDPR. It states that EU data protection law continues to apply to personal data processed in connection with the AI Act (Article 2(7)) [2]. Often both apply at once. A deployer using a high-risk system to process personal data must meet the AI Act deployer duties and the GDPR, and where Article 35 GDPR requires a DPIA, the deployer can use the information the provider supplies under the AI Act to help carry it out (Article 26(9)) [2].

GDPR and AI Act compared

Question	GDPR	AI Act
What it regulates	Processing of personal data	AI systems and models, whether or not they use personal data
Who it applies to	Controllers and processors	Providers, deployers, importers, distributors and others
Approach	Principles and accountability, applied to every processing activity	Risk tiers: prohibited, high-risk, transparency, minimal
Key documents	Records, notices, DPIA, contracts	Technical documentation, instructions for use, logs, risk management (for high-risk)
Individuals' rights	Access, erasure, objection, Article 22 and others	Information and, in some cases, explanation of AI-assisted decisions (Article 86)
Fines (ceilings)	EUR 10 million or 2%; EUR 20 million or 4%	EUR 7.5 million or 1%; EUR 15 million or 3%; EUR 35 million or 7%
Where it applies now	Since 25 May 2018	In stages from 2 February 2025, with high-risk dates moved to 2027 and 2028

GOOD PRACTICE **Good practice**

Do not wait for the high-risk deadlines to behave as if they matter. The GDPR already applies to the personal data in these systems, the prohibitions and AI literacy duty already apply, and the habits the AI Act expects, such as human oversight, documentation and transparency, are the ones that prevent incidents.

Do not assume every business using a chatbot has the same obligations

What changes your position

If you...	Then, in general, the following may apply	The questions to ask
Use a general-purpose assistant for drafting, with no personal data	Probably minimal AI Act obligations beyond AI literacy	Is any personal data involved? Is output published to inform the public?
Put a customer chatbot on your website, built by a provider	Provider handles design-level transparency; you check and disclose to users, and handle GDPR	Is it clear to users it is AI? What data does it see?
Use an AI recruitment tool built by a provider	Likely deployer of a high-risk system if the tool falls within Annex III	What does the provider say about classification? Who reviews decisions?
Build your own AI system and offer it to others	You may be a provider with extensive duties	What is the system for, and is it high-risk?
Rebrand or substantially modify someone else's high-risk system	You may become the provider (Article 25)	Who is responsible for conformity?
Generate realistic synthetic images or video of real people	Possible Article 50 and, from 2 Dec 2026, Article 5 issues	Is it a deepfake? Does it depict a real person without consent?

Common mistakes and misconceptions

AI Act myths

Assumption	What is more accurate
"The AI Act has been delayed completely."	Some dates moved, mainly for high-risk systems. Prohibitions, AI literacy and other provisions apply on their original or specified dates [3].
"Every AI chatbot is high-risk."	Most are not. A chatbot has transparency duties. It is high-risk only if its use falls within the defined categories.
"We only use tools, so nothing applies to us."	Deployers have duties, including AI literacy and transparency in some cases.
"The AI Act replaces GDPR for AI."	It does not. Both can apply.
"Small business means exempt."	SMEs get some relief, such as lower fine ceilings and support measures, not exemption.

Step by step: place yourself in the AI Act

1. **What is the system and what is it for?** Write the intended purpose in one sentence.
2. **What is my role?** Provider, deployer or both?
3. **Does it touch a prohibited or high-risk use?** Check Article 5 and Annex III, and ask the provider.
4. **Do I owe transparency or literacy measures?** Disclose chatbots and synthetic content where required, and take literacy measures for your people.

CHAPTER 11 CHECKLIST

- [ ] I have listed my AI systems and their intended purposes.
- [ ] I know whether I am a provider, deployer or both for each.
- [ ] I have checked none of my uses is prohibited under Article 5.
- [ ] I have asked providers of any employment or credit-related tools about classification.
- [ ] I disclose chatbots and synthetic content where required.
- [ ] I have taken measures to support AI literacy in my team and have recorded them.
- [ ] I know the dates that apply to me and have noted them.

WHAT TO DO TODAY **What to do today**

Pick your riskiest AI use and write one sentence stating its intended purpose, then one sentence stating your role. If you cannot, ask the provider.

Summary

- The AI Act is risk-based and applies in stages. Regulation (EU) 2026/1744 moved dates for high-risk systems to 2 December 2027 and 2 August 2028, and added two prohibitions from 2 December 2026 [3].
- Obligations depend on the system, its intended purpose and your role, not on whether you "use AI".
- Prohibitions and AI literacy already apply. Article 50 transparency applies from 2 August 2026, with a transition for some marking duties.
- The AI Act does not replace the GDPR. Both can apply to the same system [2].

SOURCE NOTE **Key sources**

[2] AI Act, Articles 2, 4, 5, 6, 25, 26, 27, 50, 86, 99, 111, 113 and Annexes I and III. [3] Regulation (EU) 2026/1744, read on EUR-Lex 25 October 2026. [32] Commission AI Act guidance. See the Sources section.

PART IV · WHEN THINGS GO WRONG

CHAPTER

12

The Real Cost of Getting AI Privacy Wrong

Fines make headlines. In small businesses, the larger costs are usually time, trust and money spent on things that could have been prevented.

IN THIS CHAPTER

- The kinds of financial and non-financial consequence of poor AI governance
- The GDPR administrative fine framework, accurately stated
- Three hypothetical scenarios with stated assumptions and transparent calculations
- Why prevention is cheaper than repair, and how to estimate your own exposure

What is the risk?	Why should a small business care?	What can I do about it?
A privacy failure produces costs that are real, varied and mostly unplanned.	The costs fall on a small team with little slack, and the worst are rarely the legal maximums.	Understand the cost types, estimate your own using the method here, and spend on prevention accordingly.

Figure 35 The three questions for this chapter

SOURCE NOTE **Five-Step AI Privacy Loop · Govern, Respond**

This chapter explains why the Govern step is cost-effective. It makes no claim about what will happen to you. It shows how to reason.

SOURCE NOTE **A word about numbers**

This chapter contains no real fines, court outcomes or enforcement statistics, and it invents none. The three scenarios use **assumed** figures chosen to show the method. They are not averages, forecasts or measurements, and your costs will differ.

The risk: costs that nobody budgeted

When something goes wrong with AI and personal data, the costs come from several places at once. Chapter 1 listed them. Here they are in the order a small business typically meets them.

The cost types

Cost type	What it includes	Why it matters to a small business
Regulatory exposure	Contact from a supervisory authority; requests for information; corrective orders; in some cases an administrative fine	Time and stress even where no fine follows
Incident response	Investigation, containment, specialist and legal help, notifications	Costs arrive fast and cannot be postponed
Customer complaints and claims	Complaints to you or the authority; claims for compensation (Article 82)	Customers may seek compensation for damage, material or non-material
Contractual disputes	Breach of client confidentiality or data processing terms; indemnity and liability clauses	A large client can end a relationship or claim losses
Operational disruption	Tools suspended, projects paused, staff pulled from work	Revenue and delivery suffer
Loss of trust	Customers who leave or hesitate; difficulty winning new clients	Slow to rebuild, hard to measure
Remediation	Policies, training, technical fixes, audits	Work you would have done anyway, now done under pressure

The GDPR fine framework, stated accurately

Article 83 sets out administrative fines. It has two ceilings and a set of factors. **Fines are not automatic, and the maximums are not typical penalties.**

WHAT THE LAW SAYS **What the law says: Article 83**

Lower tier (Article 83(4)). Up to **EUR 10 million or, for an undertaking, up to 2% of total worldwide annual turnover of the preceding financial year, whichever is higher.** It covers, among others, infringements of the controller and processor obligations in Articles 25 to 39 (including data protection by design, processor contracts, records, security, breach notification and DPIAs), and Articles 42 and 43. **Higher tier (Article 83(5)).** Up to **EUR 20 million or, for an undertaking, up to 4% of total worldwide annual turnover of the preceding financial year, whichever is higher.** It covers, among others, the basic principles (Articles 5, 6, 7 and 9), the rights of individuals (Articles 12 to 22), transfers (Articles 44 to 49) and non-compliance with a supervisory authority's order. **Setting the amount (Article 83(1) and (2)).** Each fine must be effective, proportionate and dissuasive. The authority must have regard to factors including the nature, gravity and duration of the infringement; whether it was intentional or negligent; any action taken to mitigate damage; the degree of responsibility, taking account of measures implemented; previous infringements; cooperation with the authority; the categories of personal data affected; how the authority learned of it, including whether the controller notified it; adherence to codes of conduct; and any other aggravating or mitigating factor [1].

Five points guard against misreading. First, the **ceilings are maximums**. For a small company the fixed amounts are the higher figures, but they bear no relation to what a small firm would be likely to be fined, and nothing in the text makes them a default. Second, an authority has other powers besides fines, including warnings, reprimands, orders to bring processing into compliance, and limits on processing (Article 58(2)). Third, the Court of Justice has held that fines require the infringement to have been committed intentionally or negligently by the controller, and has clarified that the concept of undertaking used in calculating fines follows competition law [29]. Fourth, **individuals can claim compensation** for material or non-material damage under Article 82: the Court of Justice has held that there is no minimum seriousness threshold for non-material damage, but that actual damage and a causal link must be shown [27], and that a fear of misuse of data can in principle amount to damage [28]. Fifth, **good governance is itself a mitigating factor**: the authority considers the measures you had in place, how you responded, and whether you notified.

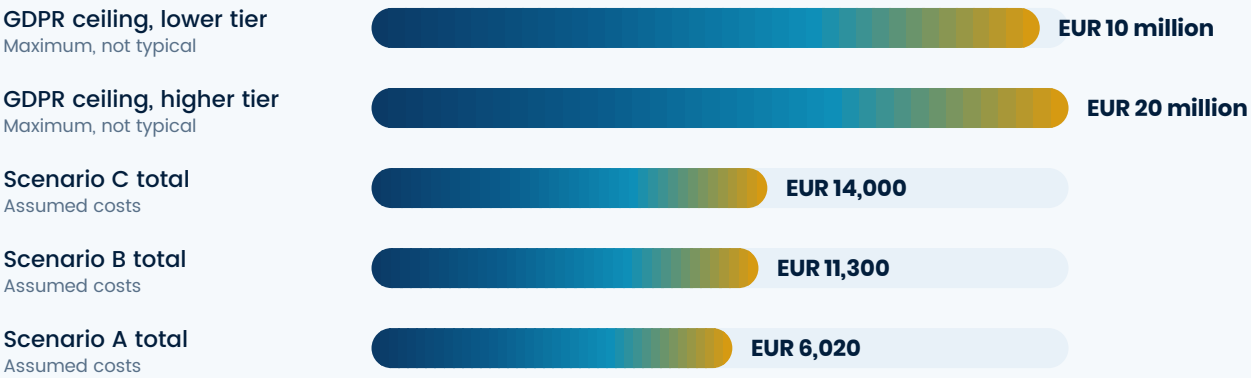


Figure 36 The GDPR ceilings versus the other costs in this chapter

SOURCE NOTE **How to read the figure**

The bars use a logarithmic scale, so a very large number and small numbers can share one picture. The ceilings are legal maximums for an undertaking whose turnover is low enough that the fixed amount is the higher figure. The scenario totals are the assumed costs worked out below. The picture does not say that a fine of any size is likely.

Three hypothetical scenarios, with the arithmetic shown

Each scenario states its assumptions. Hourly rates are invented round numbers. No fine is assumed in any of them, because fines depend on facts that cannot be predicted. Change the numbers to match your own business.

Scenario A: the agency that uploaded a client list

Assumptions. Based on the case in Chapter 3. Three staff spend 12 hours each on investigation and clean-up at an internal cost of EUR 45 an hour. The agency takes 6 hours of legal advice at EUR 250 an hour. It spends 20 hours on client calls and notifications at EUR 45. It gives one affected client a goodwill credit of EUR 2,000. No regulator is assumed to be involved and no fine is assumed.

Scenario A: illustrative calculation

Item	Calculation	Cost (EUR)
Investigation and clean-up	3 people × 12 hours × EUR 45	1,620
Legal advice	6 hours × EUR 250	1,500
Client calls and notifications	20 hours × EUR 45	900
Goodwill credit to client	assumed	2,000
Total	**6,020**	

Scenario B: the chatbot that showed the wrong customer's order

Assumptions. Based on Chapter 7. Legal and regulatory notification advice takes 10 hours at EUR 250. Customer-service staff spend 60 extra hours at EUR 30. An engineer spends 40 hours fixing verification at EUR 70. The company pays EUR 3,000 for an independent security test. It sends EUR 15 goodwill vouchers to 40 affected customers. It loses EUR 600 of contribution margin while the order-lookup feature is switched off. No fine is assumed.

Scenario B: illustrative calculation

Item	Calculation	Cost (EUR)
Legal and notification advice	10 hours × EUR 250	2,500
Customer-service surge	60 hours × EUR 30	1,800
Engineering fix	40 hours × EUR 70	2,800
Independent security test	assumed	3,000
Goodwill vouchers	40 × EUR 15	600
Lost contribution margin	assumed	600
Total	**11,300**	

Scenario C: the screening tool and the complaint

Assumptions. Based on Chapter 8. Legal advice on an access request and a discrimination complaint takes 20 hours at EUR 250. A consultant spends 25 hours at EUR 120 on a DPIA and a review of the tool. The company re-runs recruitment: EUR 1,500 advertising and 30 hours of manager time at EUR 50. A settlement of EUR 3,000 is **assumed** for illustration, not predicted. No fine is assumed.

Scenario C: illustrative calculation

Item	Calculation	Cost (EUR)
Legal advice	20 hours × EUR 250	5,000
Consultant: DPIA and review	25 hours × EUR 120	3,000
Re-running recruitment: advertising	assumed	1,500
Re-running recruitment: manager time	30 hours × EUR 50	1,500
Assumed settlement	assumed	3,000
Total	**14,000**	

What prevention might have cost

Compare the scenarios with an assumed cost of the preventive work in this book. Suppose the owner and team spend 40 hours in total on the 30-day plan at EUR 50 an hour, and pay EUR 500 for an advisor review or tools. That is 40 × 50 + 500 = **EUR 2,500**. The comparison is illustrative. Prevention does not guarantee that an incident will not happen, and the costs in each scenario would also need to be weighed against how likely each incident was. Its value lies in lowering both likelihood and impact, and in leaving a record that you took reasonable care.

WHAT TO DO TODAY **What to do today**

Pick one scenario that could happen to you. List its cost items, put your own assumptions beside each, and add them up. You now have a figure to hold against the cost of preventing it.

Non-financial costs

- **Trust.** Customers and clients decide whether to give you their data again. A single clumsy disclosure can change that.
- **Morale.** Staff who made an honest mistake can feel exposed, and good people may stop trying new tools.
- **Opportunity.** Time spent repairing is time not spent selling, building or serving.
- **Relationships.** Large clients increasingly send privacy and AI questionnaires, and incidents make the next one harder.
- **Insurance.** Policies may have conditions or exclusions. Read yours and ask your broker how AI-related incidents are treated.

Common mistakes and misconceptions

Cost myths

Assumption	What is more accurate
"The maximum fine will be imposed."	Maximums are ceilings. Fines are set case by case under Article 83(1) and (2).
"Small businesses never get fined."	The law applies to all sizes. Authorities have a range of tools, and fines depend on the facts.
"If there is no fine, there is no cost."	Most costs are time, advice, repair and lost trust.
"Insurance will cover it."	Cover varies. Read the policy and ask your broker.
"Prevention is expensive."	The measures in this book are mostly time and attention.

Step by step: estimate your own exposure

1. **Choose a scenario** from Chapters 3, 7, 8, 9 or 10 that fits your business.
2. **List the cost types** in the table above.
3. **Put numbers in** using your own hourly costs and rates, and mark each as assumed.
4. **Add them up** and write the total beside the cost of prevention.
5. **Decide what to do first** based on the scenario with the highest cost and likelihood.

CHAPTER 12 CHECKLIST

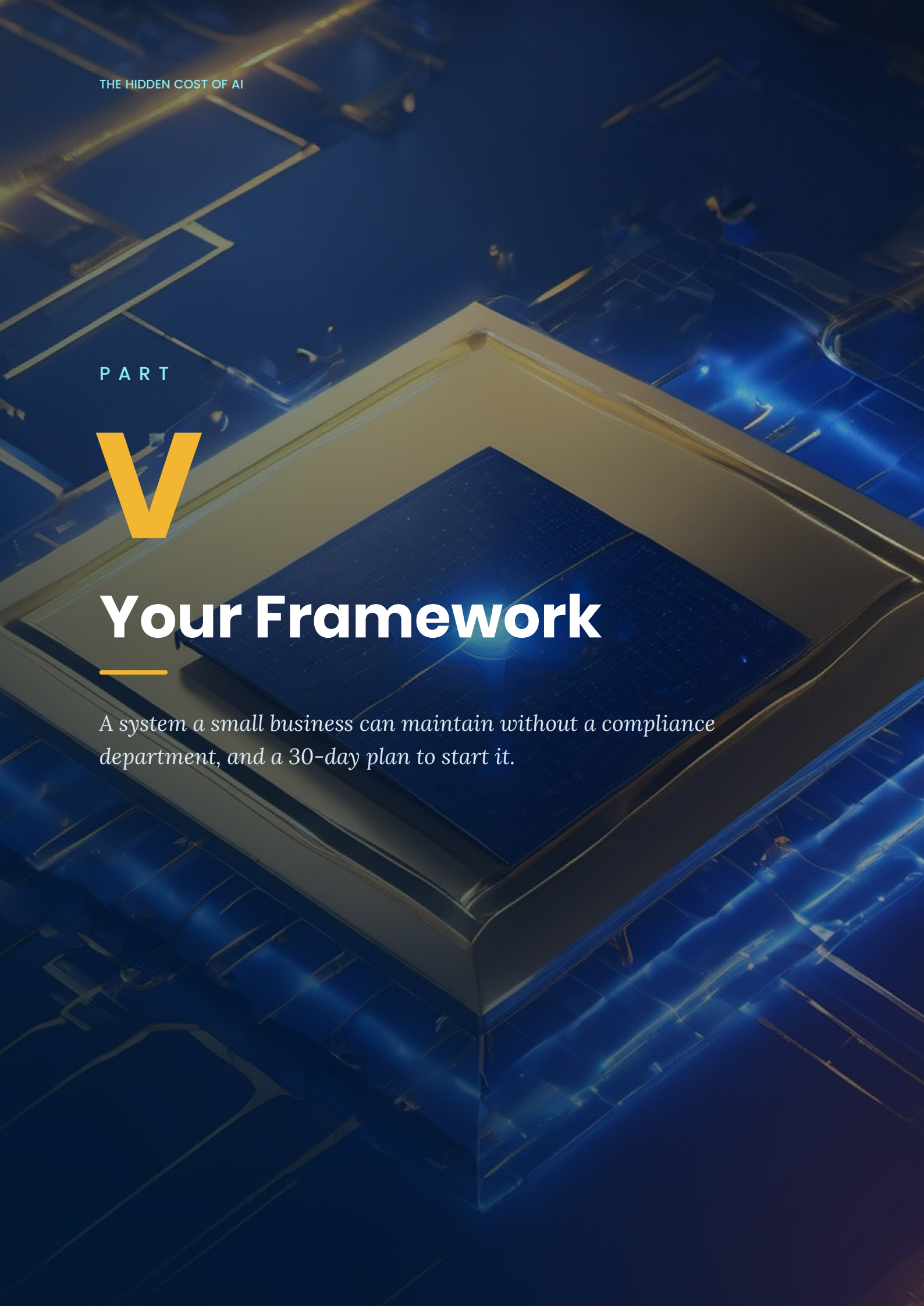
- [ ] I understand that the GDPR maximums are ceilings and not typical penalties.
- [ ] I know the factors an authority considers (Article 83(2)).
- [ ] I have worked through at least one scenario with my own assumptions.
- [ ] I have read my insurance policy and asked my broker about AI-related incidents.
- [ ] I can show the measures I have in place, because they count in my favour.

Summary

- The costs of poor AI governance are mostly incident response, time, disputes, lost trust and remediation, not only fines.
- GDPR ceilings are EUR 10 million or 2%, and EUR 20 million or 4%, whichever is higher. They are maximums, and fines depend on the Article 83(2) factors [1].
- Individuals can claim compensation (Article 82), and the Court of Justice has set out how [27][28].
- The three scenarios are illustrations. Their numbers are assumptions, and prevention in the example costs a fraction of the repair.

SOURCE NOTE **Key sources**

[1] GDPR, Articles 58, 82 and 83. [27] C-300/21. [28] C-340/21. [29] C-807/21. See the Sources section.



PART

V

Your Framework

A system a small business can maintain without a compliance department, and a 30-day plan to start it.

PART V · YOUR FRAMEWORK

CHAPTER

13

Build Your Small Business AI Privacy Framework

Eleven simple pieces, kept in one folder and reviewed on a calendar, will take you further than any single big project.

IN THIS CHAPTER

- The eleven components of a lightweight AI privacy framework
- How they connect: inventory, classification, register, vendor check, policy, training, review, risk screening, rights requests, incidents and periodic review
- How to keep it small enough to maintain
- When to ask a lawyer, a security specialist or a data protection officer

What is the risk?
Good intentions without a system fade within weeks, and nobody can show what was decided or why.

Why should a small business care?
Accountability means being able to demonstrate your measures. A short, living set of records does that.

What can I do about it?
Build the eleven components in order of value, keep each to a page or a sheet, and put the reviews in the calendar.

Figure 37 The three questions for this chapter

SOURCE NOTE **Five-Step AI Privacy Loop · All five steps**

This chapter joins the loop into one routine. Map and Minimise feed Vet, Vet feeds Govern, Govern prepares Respond, and Respond sends you back to Map.

HYPOTHETICAL EXAMPLE **Hypothetical scenario: the folder**

Six months after her first AI audit, Ines of Ember & Oak opens a shared folder called "AI and Privacy". It holds a one-page tool list, a policy, a vendor sheet for each approved tool, a short training log, a breach log with two entries marked "no notification, reasoning attached", and a calendar reminder for the next review. When a corporate client sends a security questionnaire, she answers it in an afternoon. The folder did not make the business perfect. It made it **demonstrable**.

The risk: good intentions that fade

The first burst of attention after a scare is easy. The second year is harder. A framework is simply a way of making the right things routine, so that they survive holidays, staff changes and busy seasons. It must be **small enough that you will actually maintain it**.

01
AI tools inventory
Every tool, plan, owner and purpose (Tool 1).

02
Data classification
Four levels, with a rule for each (Tool 5).

03
AI use-case register
Each use, its data, basis and risk (Tool 1).

04
Vendor assessment
Ten areas, scored and recorded (Tool 3).

05
Acceptable-use policy
One page of rules, plus the full template (Tool 4).

06
Training plan
Short sessions with real scenarios.

07
Privacy review
A quick gate before any new tool or use (Tool 2).

08
Risk and DPIA screening
Is a fuller assessment needed? (Tool 8).

09
Rights requests
A routine for access, erasure and objection.

10
Incident response
Roles, log and decision checklist (Tools 6 and 7).

11
Periodic review
Monthly and annual checks and records (Tool 10).

Figure 38 The eleven components of the framework: keep them in one folder

Components 1 to 3: know what you have

The AI tools inventory lists each tool, the plan and account type, the owner, the purpose, the data types allowed, the approval status and the review date. **The use-case register** goes one level deeper: for each use, what data goes in, the lawful basis where personal data is involved, who is told, the risk rating and any conditions. For most small businesses these fit on one spreadsheet with two tabs.

AI TOOL AND USE-CASE INVENTORY (EXAMPLE ROWS)

Tool and plan	Owner	Purpose	Data allowed	Status and conditions	Review date
e.g. Writing assistant, business plan	*Marketing lead*	*Drafting copy and ideas*	*Public and internal; no personal data*	*Approved; DPA filed; training off*	*e.g. 30 Jun*
e.g. Customer chatbot, plug-in	*Operations*	*After-hours order questions*	*Order status after login only*	*Approved with limits; verification tested*	*e.g. 31 Mar*
e.g. Meeting notes, personal account	*Unknown*	*Notes*	*Unknown*	*Not approved; to be replaced*	*e.g. This week*

Data classification gives people a quick way to decide. Four levels are enough.

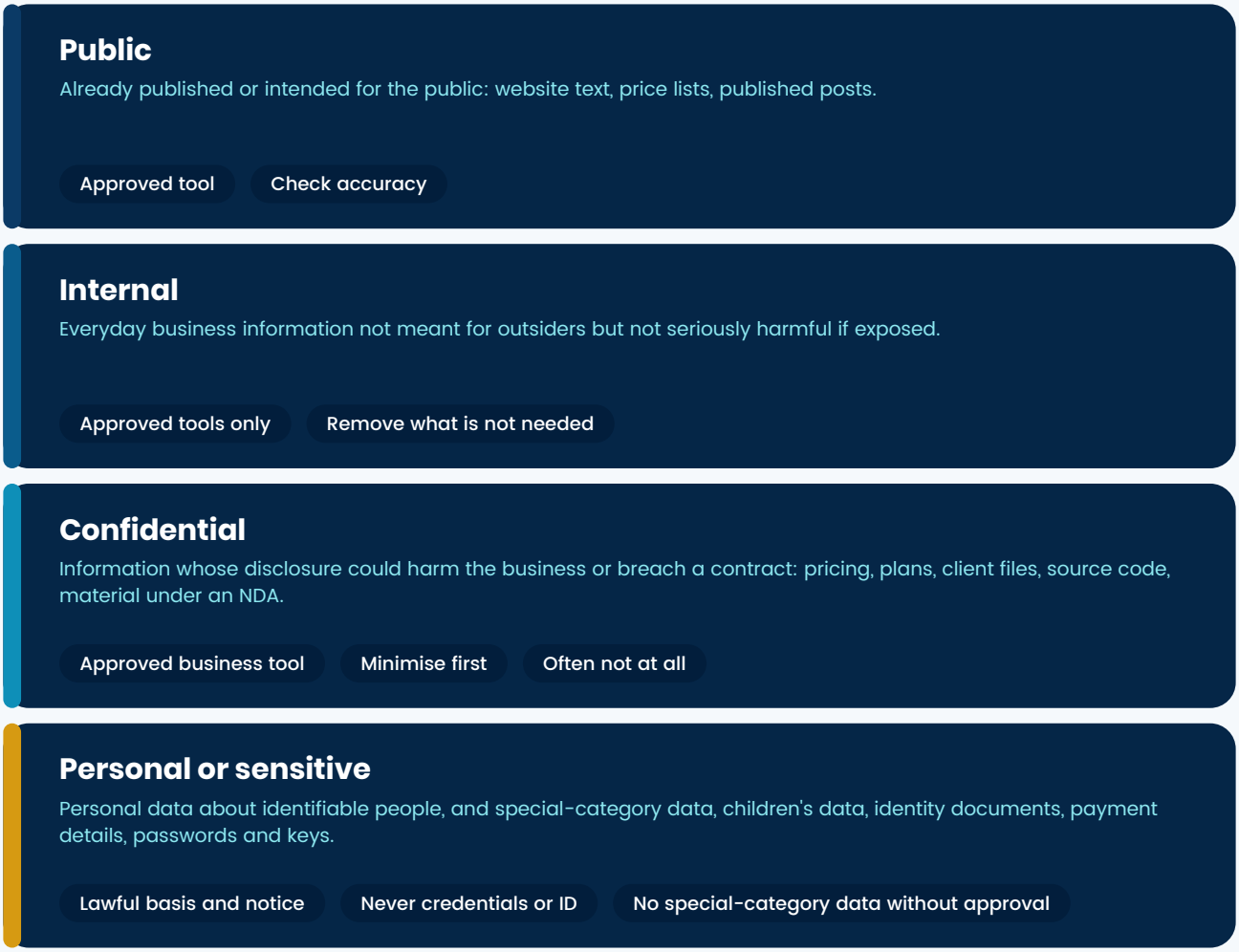


Figure 39 Four levels of information, from open to closed

Components 4 to 6: set the rules

Vendor assessment is Chapter 5, recorded on one sheet per tool. The **acceptable-use policy** is Chapter 6 and Tool 4. The **training plan** can be modest:

A simple training plan

Who	What	How often	Evidence
Everyone	The one-page rule, the never-paste list, how to report an incident	At joining and yearly	Short sign-off or attendance note
Anyone using AI daily	Fifteen-minute scenarios from Chapters 3 and 6	Twice a year	Date and topics
People handling customers or staff data	Rights requests, recognising breaches, fraud checks	Yearly	Date and topics
Owner and incident lead	Incident drill, regulatory basics, vendor reviews	Yearly	Drill record

GOOD PRACTICE **Good practice and the AI Act**

Regulation (EU) 2026/1744 amended the AI literacy duty so that providers and deployers must **take measures to support** AI literacy among their staff and others using AI on their behalf, without guaranteeing a specific level in any individual [3]. Short, recorded, role-appropriate training is a sensible way to show you took measures.

Components 7 and 8: look before you leap

A **privacy review** is a short gate. Before any new tool or any new use of personal data, answer a handful of questions and write down the result. Tool 2 gives you a checklist. If the answers suggest a higher risk, use the **DPIA screening** in Tool 8 to decide whether a full data protection impact assessment is needed. Article 35 requires a DPIA where processing is likely to result in a high risk, and the EDPB-endorsed guidelines suggest that meeting two or more of their criteria usually points to one [1][9].

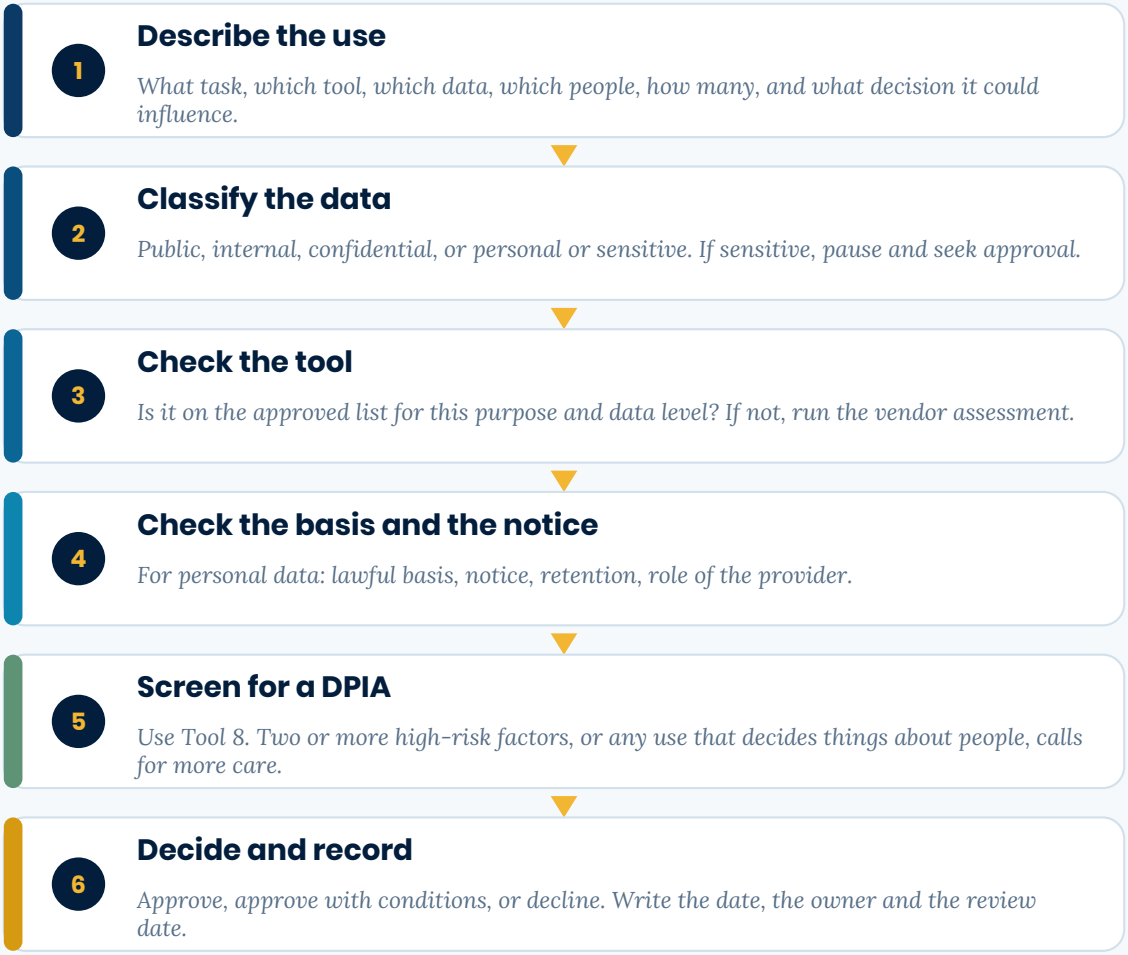


Figure 40 The privacy review process

Component 9: rights requests

People may ask to see, correct, delete or restrict their data, or object to its use. You must respond without undue delay and within one month, which can be extended by two months in complex cases, and you must tell the person within the first month if you extend (Article 12(3)) [1]. For AI, the added difficulty is knowing **where** their data went.

1. **Log the request** with its date. The month starts when you receive it.
2. **Verify identity** proportionately, without collecting more data than you need.
3. **Search your places:** email, CRM, helpdesk, shared drives and any AI tool where the data may have gone, using the inventory.
4. **Decide** what must be provided, corrected, deleted or refused, and why.
5. **Reply in clear language** and record the outcome and any reasons for refusal or extension.

Components 10 and 11: be ready and keep reviewing

The incident routine is Chapter 10, with Tool 6 and Tool 7. The review routine fits into a calendar:

The review rhythm

When	What to review	Time	Evidence
Monthly	New tools and extensions; incidents and near misses; open actions (Tool 10)	30 minutes	Dated review sheet
Quarterly	Access to connected tools; approved list; vendor terms for the main tools	1 hour	Updated inventory
Yearly	Policy; training; DPIA screenings; the AI Act dates and your role; privacy notice	Half a day	Dated, signed-off folder
On change	A new tool, new use, new supplier or a significant change in a provider's terms	As needed	Privacy review record

When to ask for specialist help

This book will carry a small business a long way, but some questions need a professional. Ask early, and bring your inventory to make the advice cheaper.

When to seek advice, and from whom

Situation	Who to ask
You plan to use AI to evaluate, rank or monitor candidates or employees	An employment lawyer or data protection specialist
You use special-category or children's data in AI tools	A data protection specialist or lawyer
A DPIA is required or you are unsure	A data protection specialist, or your DPO if you have one
A suspected personal data breach that may put people at risk	Your incident lead immediately, then a lawyer or specialist, and the supervisory authority's guidance
You export personal data outside the EEA or rely on transfer tools	A lawyer or data protection specialist
You provide or substantially modify an AI system, or may be a provider under the AI Act	A lawyer familiar with the AI Act
A client or authority asks for formal evidence	A lawyer or specialist, plus your records
Your AI tool has access to critical systems or money	A security specialist

WHAT THE LAW SAYS **Do you need a data protection officer?**

A DPO must be designated if you are a public authority, or if your core activities consist of regular and systematic monitoring of people on a large scale, or of large-scale processing of special-category or criminal-offence data (Article 37(1)). National law may add cases [1]. Many small businesses do not need one, but it is worth recording the reasoning either way.

Common mistakes and misconceptions

Framework myths

Assumption	What is more accurate
"A framework means a big project."	It means a folder, a few sheets and a calendar.
"We wrote a policy, so we are done."	A policy that is not read, trained or reviewed is paper.
"Records are for regulators only."	Records protect you with clients, insurers and staff, and they make decisions faster.
"We cannot afford specialists."	Targeted advice on one question, backed by good records, is usually affordable.
"One person can hold all of it forever."	Name a deputy and write down where things are.

Step by step: build the framework in order of value

1. **Inventory first** (Component 1 and 3). Everything else depends on it.
2. **Rule second** (Component 5). One page, then train.
3. **Vendors third** (Component 4), for the tools you use most.
4. **Incident routine fourth** (Component 10), because a crisis is a poor time to plan.
5. **Review dates last** (Component 11), in the calendar, with a named owner.

CHAPTER 13 CHECKLIST

- [ ] I have an AI tools inventory and use-case register.
- [ ] I have a four-level classification and staff know it.
- [ ] Every approved tool has a vendor record and a review date.
- [ ] I have an acceptable-use policy and a training log.
- [ ] New tools and uses go through a privacy review and DPIA screening.
- [ ] I have a rights-request routine that searches AI tools too.
- [ ] I have an incident lead, a log and a decision checklist.
- [ ] Monthly, quarterly and yearly reviews are in the calendar.
- [ ] I know who to call for each kind of specialist question.

WHAT TO DO TODAY **What to do today**

Create a folder called "AI and Privacy" in your shared storage. Move or create the first document in it: your list of AI tools. Everything else will find its place around that.

Summary

- A framework is eleven small pieces in one folder, reviewed on a calendar.
- Build in order: inventory, rule, vendors, incident routine, review dates.
- Records make you demonstrable to clients, insurers and authorities, which supports accountability under Article 5(2) [1].
- Ask for specialist help early on employment, special-category data, DPIAs, transfers, serious breaches and provider roles.

SOURCE NOTE **Key sources**

[1] GDPR, Articles 5(2), 12, 35 and 37. [3] Regulation (EU) 2026/1744, Article 4 as amended. [9] WP248 rev.01. See the Sources section.

PART V · YOUR FRAMEWORK

CHAPTER

14

The 30-Day AI Privacy Action Plan

Thirty short tasks, in the order that reduces the most risk for the least effort.

IN THIS CHAPTER

- A week-by-week plan with 30 tasks
- For every task: its purpose, a suggested owner, estimated effort and the evidence that it is done
- Which tasks are urgent and which can wait
- How to track progress and keep it going

What is the risk?
You understand the problem but never start, or start everywhere and finish nowhere.

Why should a small business care?
Risk falls fastest in the first weeks, and a dated trail of completed tasks is evidence of your care.

What can I do about it?
Do one task a day, tick it off, keep the evidence, and use the tracker in Tool 12.

Figure 41 The three questions for this chapter

SOURCE NOTE **Five-Step AI Privacy Loop · Map, Minimise, Vet, Govern, Respond**

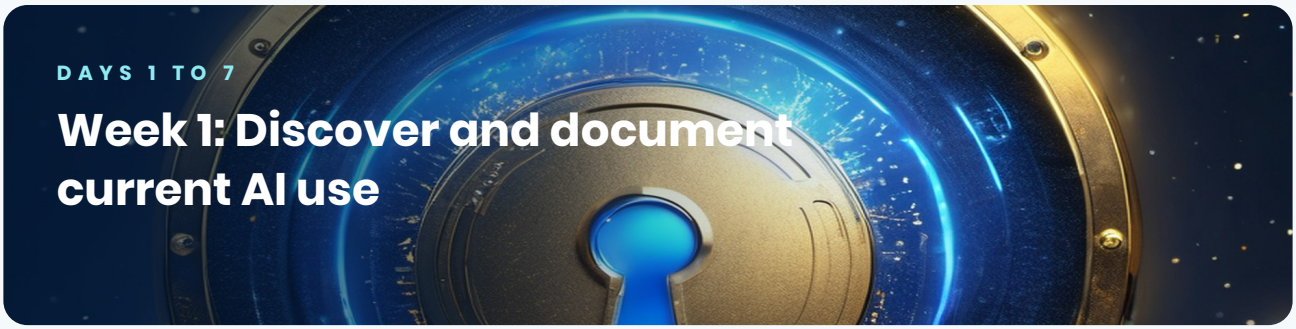
Week 1 maps, week 2 vets, week 3 governs, week 4 tests and sets the review rhythm. Then the loop begins again.

How to use the plan

Each task shows its **purpose** (why it matters), a suggested **owner**, an estimated **effort** and **evidence** of completion. Tasks marked **[URGENT]** reduce risk most for least effort. Do them first, even if you cannot do the rest. The owner is a suggestion: in a very small business it will mostly be you. Effort estimates are rough and assume a business of up to about fifteen people.

WATCH OUT **If you can only do three things**

Do Day 2 (multifactor authentication), Day 5 (ask about AI use) and Day 6 (publish the one-page rule). They close the most common gaps in an afternoon.



You cannot protect what you cannot see. This week is about finding out what you have, and setting one rule so nothing new is added blindly.

DAY 1

[URGENT] Name an owner

Task: appoint one person to own AI and privacy decisions, with a deputy. **Purpose:** decisions need an owner. **Owner:** business owner. **Effort:** 15 minutes. **Evidence:** names written in the folder and told to the team.

☐ DONE

DAY 2

[URGENT] Turn on multifactor authentication

Task: switch on MFA for email, banking, cloud storage and every AI account. **Purpose:** blocks most simple account takeovers. **Owner:** each account holder, with the owner checking. **Effort:** 30 to 60 minutes. **Evidence:** screenshot or list showing MFA enabled on each account.

☐ DONE

DAY 3

Create the folder

Task: create the shared folder "AI and Privacy" with sub-folders for tools, vendors, policy, training and incidents. **Purpose:** one home for evidence. **Owner:** the owner. **Effort:** 15 minutes. **Evidence:** the folder exists and the team knows where it is.

☐ DONE

DAY 4

Start the tool list

Task: write down every AI tool, extension and AI feature you can think of (Tool 1). **Purpose:** this is the Map step. **Owner:** the owner. **Effort:** 30 minutes. **Evidence:** a first version of Tool 1.

☐ DONE

DAY 5

[URGENT] Ask the team

Task: ask each person which AI tools they use for work, with a no-blame promise. **Purpose:** hidden use is the biggest gap. **Owner:** the owner or manager. **Effort:** 30 minutes plus replies. **Evidence:** a reply from every person recorded in the inventory.

☐ DONE

DAY 6

[URGENT] Publish the one-page rule

Task: share a short rule: approved tools, never-paste list, human review, who to tell. Use Tool 4. **Purpose:** gives people a clear line immediately. **Owner:** the owner. **Effort:** 45 minutes. **Evidence:** the rule sent to all, with date.

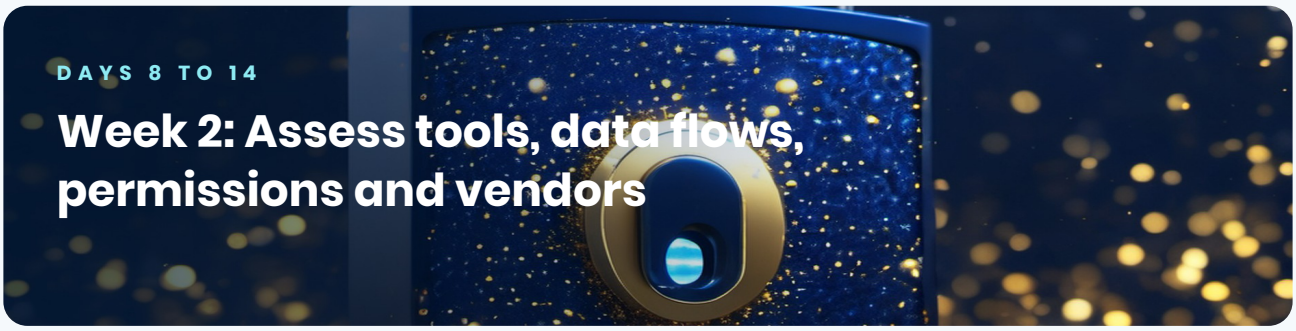
☐ DONE

DAY 7

Review and rest

Task: read the answers from Day 5 and mark the three riskiest uses. **Purpose:** choose where week 2 starts. **Owner:** the owner. **Effort:** 30 minutes. **Evidence:** a list of three priority uses in the inventory.

☐ DONE



DAYS 8 TO 14

Week 2: Assess tools, data flows, permissions and vendors

Now you look closely at the tools that matter most.

DAY 8

Classify your data

Task: adopt the four-level classification and note which levels each tool may receive (Tool 5). **Purpose:** gives staff a simple rule for each case. **Owner:** the owner. **Effort:** 45 minutes. **Evidence:** classification added to the inventory and policy.

☐ DONE

DAY 9

[URGENT] Vendor check, tool one

Task: complete the vendor questionnaire from public documents for the most-used tool (Tool 3). **Purpose:** Vet step, most-used tool first. **Owner:** the owner or a delegate. **Effort:** 1 to 2 hours. **Evidence:** completed questionnaire with score and decision.

☐ DONE

DAY 10

Vendor check, tool two

Task: repeat for the second tool. **Purpose:** same. **Owner:** same. **Effort:** 1 to 2 hours. **Evidence:** completed questionnaire and decision.

☐ DONE

DAY 11

[URGENT] Check data processing agreements

Task: for every approved tool that handles personal data, find, accept or request a DPA and file it. **Purpose:** Article 28 requires a contract. **Owner:** the owner. **Effort:** 1 hour. **Evidence:** DPAs filed or requests sent with dates.

☐ DONE

DAY 12

Review connections and permissions

Task: list AI tools connected to email, drives and CRM, and cut permissions to the minimum. **Purpose:** limits damage from a trick or mistake. **Owner:** whoever administers accounts. **Effort:** 1 hour. **Evidence:** before and after list of connections.

☐ DONE

DAY 13

Check privacy notice and settings

Task: compare your privacy notice with your actual AI uses (Tool 9) and check training and retention settings on key tools. **Purpose:** transparency and control. **Owner:** the owner. **Effort:** 1 hour. **Evidence:** notes of gaps and a list of settings changes.

☐ DONE

DAY 14

Retire what you do not need

Task: remove unapproved tools, unused extensions and old accounts. **Purpose:** fewer doors. **Owner:** each user, checked by the owner. **Effort:** 45 minutes. **Evidence:** updated inventory with removals dated.

☐ DONE



DAYS 15 TO 21

Week 3: Introduce policies, safeguards and guidance

Rules and habits now replace guesswork.

DAY 15

[URGENT] Finalise the AI policy

Task: adapt the full template (Tool 4), date it and have it reviewed by an adviser if you can. **Purpose:** a written standard. **Owner:** the owner. **Effort:** 2 hours. **Evidence:** dated policy in the folder.

☐ DONE

DAY 16

Train the team

Task: run a fifteen-minute session using the scenario in Chapter 6. **Purpose:** turns the rule into habit and supports AI literacy. **Owner:** the owner. **Effort:** 30 minutes. **Evidence:** attendance and date recorded.

☐ DONE

DAY 17

[URGENT] Set the payment verification rule

Task: require a call-back to a known number for any new or changed bank details or urgent payment request. **Purpose:** defeats AI-assisted impersonation. **Owner:** finance lead or owner. **Effort:** 30 minutes. **Evidence:** the rule written and communicated.

☐ DONE

DAY 18

Add human review

Task: require review of AI output before sending to customers or using about a person. **Purpose:** accuracy and fairness. **Owner:** managers. **Effort:** 30 minutes. **Evidence:** the rule in the policy and workflow notes.

☐ DONE

DAY 19

Review HR and marketing uses

Task: apply the Chapter 7 and 8 checks to any use that profiles customers or evaluates people. **Purpose:** these carry the highest legal risk. **Owner:** the owner with HR or marketing lead. **Effort:** 1 to 2 hours. **Evidence:** notes and any suspended uses.

☐ DONE

DAY 20

DPIA screening

Task: run Tool 8 on your highest-risk use. **Purpose:** decide whether a full DPIA is needed. **Owner:** the owner or a specialist. **Effort:** 1 hour. **Evidence:** completed screening with decision.

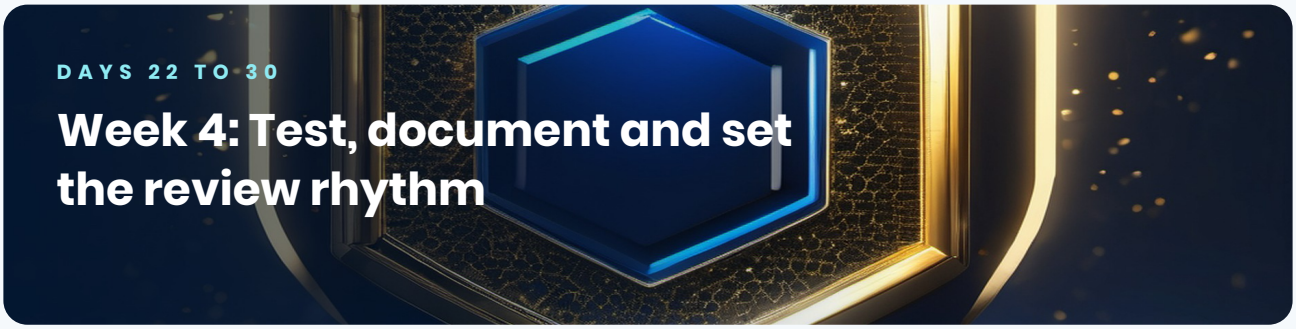
☐ DONE

DAY 21

Name the incident lead and contacts

Task: name the incident lead and deputy, and save the authority's breach page and your legal contact. **Purpose:** be ready. **Owner:** the owner. **Effort:** 30 minutes. **Evidence:** a one-page contact sheet shared with the team.

☐ DONE



DAYS 22 TO 30

Week 4: Test, document and set the review rhythm

The last week proves the system works and puts it in the calendar.

DAY 22

Run an incident drill

Task: walk through the "shared link" scenario from Chapter 10 using Tool 6. **Purpose:** find gaps in the routine. **Owner:** incident lead. **Effort:** 30 to 45 minutes. **Evidence:** drill notes and fixes list.

☐ DONE

DAY 23

Test the rights-request routine

Task: run a pretend access request and search every place including AI tools. **Purpose:** prove you can find the data in a month. **Owner:** the owner. **Effort:** 1 hour. **Evidence:** notes on where data was found and what was missing.

☐ DONE

DAY 24

Test a restore

Task: restore a file from backup. **Purpose:** backups matter only if they work. **Owner:** whoever manages IT. **Effort:** 30 minutes. **Evidence:** dated note that the restore succeeded.

☐ DONE

DAY 25

Check the AI Act position

Task: for each AI system, write its purpose and your role, and note the dates that apply (Chapter 11). **Purpose:** know your obligations. **Owner:** the owner. **Effort:** 1 hour. **Evidence:** a one-page AI Act position note.

☐ DONE

DAY 26

Complete the use-case register

Task: finish the register with basis, notice, risk and conditions for each use. **Purpose:** the central record. **Owner:** the owner. **Effort:** 1 to 2 hours. **Evidence:** completed register.

☐ DONE

DAY 27

Score your maturity

Task: complete the scorecard in Tool 11. **Purpose:** know your baseline. **Owner:** the owner. **Effort:** 30 minutes. **Evidence:** dated scorecard.

☐ DONE

DAY 28

Set the review calendar

Task: put monthly, quarterly and yearly reviews in the calendar (Tool 10). **Purpose:** keeps the system alive. **Owner:** the owner. **Effort:** 15 minutes. **Evidence:** calendar entries.

☐ DONE

DAY 29

Tell customers and clients where useful

Task: update the privacy notice and prepare a short answer for client questionnaires about AI. **Purpose:** transparency builds trust. **Owner:** the owner. **Effort:** 1 to 2 hours. **Evidence:** updated notice and standard answer.

☐ DONE

DAY 30

Review and celebrate

Task: review the tracker, note what is incomplete and set dates. **Purpose:** close the month and plan the next. **Owner:** the owner and team. **Effort:** 45 minutes. **Evidence:** completed tracker and a short list of next actions.

☐ DONE

Track it

The tracker in Tool 12 lets you tick each day. A printed copy on the office wall works well.

DAY 01 ☐	DAY 02 ☐	DAY 03 ☐	DAY 04 ☐	DAY 05 ☐	DAY 06 ☐
DAY 07 ☐	DAY 08 ☐	DAY 09 ☐	DAY 10 ☐	DAY 11 ☐	DAY 12 ☐
DAY 13 ☐	DAY 14 ☐	DAY 15 ☐	DAY 16 ☐	DAY 17 ☐	DAY 18 ☐
DAY 19 ☐	DAY 20 ☐	DAY 21 ☐	DAY 22 ☐	DAY 23 ☐	DAY 24 ☐
DAY 25 ☐	DAY 26 ☐	DAY 27 ☐	DAY 28 ☐	DAY 29 ☐	DAY 30 ☐

CHAPTER 14 CHECKLIST

- ☐ I have named an owner and a deputy.
- ☐ MFA is on for email and every AI account.
- ☐ I have asked the team about AI use, with a no-blame promise.
- ☐ The one-page rule is published and the team has been trained.
- ☐ My main tools have vendor records and DPAs.
- ☐ I have run an incident drill and a rights-request test.
- ☐ Reviews are in the calendar.

WHAT TO DO TODAY **What to do today**

Do Day 1 now: write down the name of the person who owns AI and privacy decisions, and tell them.

Summary

- The plan has 30 tasks in four weeks: discover, assess, introduce policy, then test and set the rhythm.
- Every task has a purpose, an owner, an estimate and evidence.
- Do the urgent tasks first. If you can only do three, do MFA, ask the team and publish the rule.
- The records you create are evidence that you took reasonable care.

SOURCE NOTE **Key sources**

[1] GDPR, Articles 5(2), 28, 33 and 35. [2][3] AI Act and Regulation (EU) 2026/1744. See the Sources section.

CONCLUSION

CONCLUSION

AI

Use AI Without Losing Control

The goal is not to remove every risk. It is to understand, prioritise and manage risk in proportion.

IN THIS CHAPTER

- The Five-Step AI Privacy Loop in one page
- Five steps for this week
- What this book could not do for you

At the start of this book, Luka uploaded four hundred complaints to a free chatbot, a bookkeeper pasted a contract into another tool, and a new colleague installed an extension that could read every page she opened. Nobody meant any harm. Each person saved time. Together they left a business that had lost track of its own information.

The point of this book has not been to frighten you. AI can create enormous value for a small business, and the businesses that learn to use it well will have a real advantage. But the price of that advantage is not only the subscription. It is attention: knowing what happens to your data, protecting the people behind it, and managing privacy risk **before** it becomes an expensive mistake.

The Five-Step AI Privacy Loop, one last time

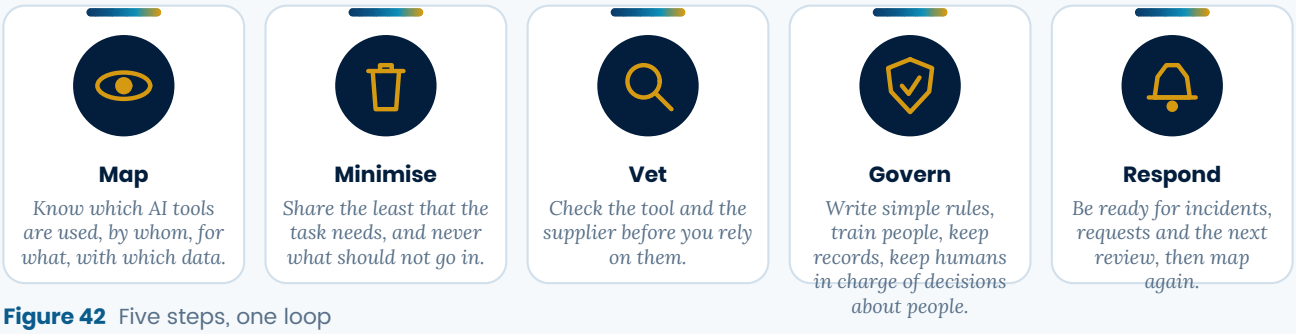


Figure 42 Five steps, one loop

The loop is an original framework created for this book. It is not an official standard. Its value is that it puts a messy subject into an order you can follow on a busy Thursday.

Five steps for this week

1. **Turn on multifactor authentication** for your email and every AI account.
2. **List the AI you use**, including free accounts, extensions and AI features inside existing software.
3. **Write your never-paste list** and share it, with the names of the approved tools.
4. **Check one tool properly**: terms, retention, training, DPA, sub-processors.
5. **Name your incident lead** and save your supervisory authority's breach page.

What this book cannot do

It cannot make you compliant, because compliance depends on your facts and is an ongoing practice. It cannot prevent every incident. It cannot replace a lawyer when you face a hard legal question, or a specialist when you face a serious incident. It does not take your national law into account. And it will age: the law, the guidance and the tools will change, and the research for this edition closed on 25 October 2026. Use the Sources section to keep current.

Where to go next

GDPRGard, the publisher's associated resource, offers further GDPR education, tools and templates for European small businesses at https://gdprgard.eu/. Use anything you find there as you would use this book: as a starting point that you adapt to your own business. Your national supervisory authority and the EDPB (https://www.edpb.europa.eu/) remain the primary guides to how the law is applied.

THE LAST WORD

Responsible innovation is not slower innovation. It is innovation that your customers, your staff and your future self can trust. Take the first step today, then take the next one.

WHAT TO DO TODAY **What to do today**

Open a blank page and write three lines: the AI tool you use most, what data goes into it, and who approved it. If any line is blank, you now know where to begin.

SOURCE NOTE **How to use the toolkit**

Every template here is a **starting point that must be adapted** to your business, your countries of operation and your risks. Replace text in [square brackets], delete what does not apply, date each document and have significant ones checked by a qualified adviser. A template does not by itself establish legal compliance. The PDF edition has fillable fields.

AI Tool and Use-Case Inventory

The foundation. Update it whenever something changes.

AI TOOL INVENTORY

Tool and plan	Account type	Owner	Purpose	Data allowed	Approval status	Review date
e.g. Writing assistant, business plan	*Company account*	*Marketing lead*	*Drafting copy*	*Public and internal*	*Approved*	*e.g. 30 Jun*
e.g. Browser extension	*Personal*	*Unknown*	*Summaries*	*Unknown*	*Not approved*	*e.g. This week*

Tool and plan	Account type	Owner	Purpose	Data allowed	Approval status	Review date

AI USE-CASE REGISTER

Use case	Tool	Data involved	Lawful basis and notice	Risk (L x I)	Conditions and review
e.g. Draft replies to customers	*Writing assistant*	*Descriptions, no names*	*Not personal data*	*2 x 1 = 2*	*Human review*
e.g. Rank applicants	*Screening tool*	*CV data*	*To be assessed*	*3 x 3 = 9*	*Suspended pending DPIA*

AI Privacy Risk Assessment Checklist

Use before adopting a tool or a new use. Record the date and the decision.

AI PRIVACY RISK ASSESSMENT (TICK WHAT IS TRUE)

- [ ] The purpose of the use is clear and written down.
- [ ] The information involved has been classified (public, internal, confidential, personal or sensitive).
- [ ] No passwords, keys, special-category data or ID documents are involved, or specific approval exists.
- [ ] The tool and plan are on the approved list for this data level.
- [ ] A data processing agreement is in place where personal data is processed.
- [ ] We know whether inputs are used for training or improvement, and have set it as we want.
- [ ] Retention is known and deletion is possible.
- [ ] Transfers and sub-processors are known.
- [ ] People affected have been told, and the privacy notice covers the use.
- [ ] A person reviews the output before it is sent or used about a person.
- [ ] The use does not decide something significant about a person without human involvement.
- [ ] Access is limited to those who need it, with MFA.
- [ ] The DPIA screening (Tool 8) has been done.
- [ ] The decision, owner and review date are recorded.

TEMPLATE

Risk assessment record

Complete one per tool or use.

Tool and use

Data involved and classification

Main risks in plain words

Likelihood (1 to 3) and impact (1 to 3)

Safeguards in place or needed

Decision (approve, approve with conditions, decline) and conditions

Owner, date and review date

AI Vendor Due-Diligence Questionnaire

Send to a supplier, or complete from public documents.

AI VENDOR DUE-DILIGENCE QUESTIONNAIRE

Area	Question	Answer and evidence
1. Identity	Who is the legal entity, and where is it established?	
2. Product and plan	Exactly which product and plan will we use?	

Area	Question	Answer and evidence
3. Data use	Are our inputs and outputs used to train or improve models? Can this be switched off?	
4. Human review	Can staff or contractors review our content? When, and under what controls?	
5. Retention	What are the default retention periods? What about backups and logs?	
6. Deletion	How do we delete content and accounts, and how is deletion confirmed?	
7. Access	Which authentication options, roles and admin controls exist? Is MFA available?	
8. Security	Which encryption and security measures, and which independent assurances (for example ISO/IEC 27001), with what scope and date?	
9. Contract	Is a data processing agreement available that applies to our plan? Does it cover Article 28(3)?	
10. Sub-processors	Is there a current list? How are changes notified?	
11. Location	Where is data stored, processed and accessed from?	
12. Transfers	Which transfer mechanism applies (adequacy, SCCs, certification)?	
13. Incidents	How and how quickly will we be told of a breach?	
14. Integrations	Which connections to other tools exist, and what can they access?	
15. Export	Can we export our data in a usable format?	
16. Continuity	What happens if terms change, the service is sold or it closes?	

Area	Question	Answer and evidence
17. AI Act	What is the system's intended purpose and AI Act classification? What transparency information is provided?	
18. Support	Who do we contact for privacy and security questions?	

Employee AI Acceptable-Use Policy Template

Adapt, date and review it. Not legal advice.

[Organisation name] AI Acceptable-Use Policy. Version [1.0]. Date [date]. Owner [name and role]. Next review [date].

1. Purpose

This policy explains how people at [organisation] may use artificial intelligence (AI) tools in their work, so that we protect personal data, confidential information and our customers' trust, and meet our legal duties.

2. Who it applies to

Employees, contractors, interns and anyone else using [organisation]'s systems or information.

3. Approved tools

Only tools on the approved list, maintained by [owner], may be used for work. The list shows each tool, plan, permitted purposes and data levels, and review date. Personal or free accounts must not be used for work involving personal or confidential information. To request a new tool or use, contact [owner] before using it. Requests will be answered within [number] working days.

4. Information levels

- **Public:** may be used in approved tools.
- **Internal:** approved tools only, and only what the task needs.
- **Confidential:** approved tools only, minimised, and only where client contracts and the tool's terms allow it. Ask first if unsure.
- **Personal or sensitive:** only with a lawful basis, where people have been informed and the tool is approved for that purpose. Never enter special-category data, children's data, identity documents, payment card details, passwords, keys or tokens unless [owner] has approved it in writing.

5. Good practice

- Describe the situation, not the person. Use placeholders for names and identifiers.
- Check files for hidden sheets, comments and metadata before uploading.
- Do not connect AI tools to email, drives, calendars or systems without approval.
- Do not record or transcribe meetings with AI unless participants have been told beforehand.
- Check AI output. A person must review it before it is sent, published or used about a person.
- Do not use AI to make or recommend decisions about individuals with legal or similarly significant effects, for example about recruitment, pay, discipline or credit, without documented review by [owner].
- Do not present AI-generated content as human-made where we are required to disclose otherwise.

6. Accountability

You remain responsible for what you send, publish or decide, whether or not AI helped.

7. Reporting

If you think personal or confidential information has gone somewhere it should not, or an AI tool has behaved unexpectedly, tell [incident lead] immediately on [contact]. Do not delete anything. Honest reports will not be punished.

8. Review and consequences

This policy is reviewed at least yearly. Deliberate or repeated breaches may lead to action under [disciplinary procedure].

Acknowledged by: [name], [date].

Personal Data Classification Guide

A quick way to decide what may go where.

Classification guide

Level	Examples	Rule for AI tools
Public	Published web copy, price lists, public posts	Approved tools. Check accuracy.
Internal	Procedures, internal notes without personal data	Approved tools only. Share only what is needed.
Confidential	Client files, pricing, plans, source code, contracts, NDA material	Approved business tool, minimised, check contracts. Often not at all.
Personal	Names, emails, addresses, phone numbers, order histories, employee records	Lawful basis and notice. Prefer descriptions without identifiers. Approved tools with a DPA.
Special-category	Health, ethnicity, religion, politics, union membership, genetic or biometric data, sexual orientation	Do not use in general AI tools. Specific approval, DPIA screening and strong safeguards only.
Never	Passwords, API keys, tokens, recovery codes, card numbers, ID documents	Never enter in any AI tool.

AI Privacy Incident-Response Checklist

Keep a printed copy. Start the log at the first minute.

FIRST HOUR

- [ ] I have told the incident lead and written down the time I became aware.
- [ ] I have started the log below.
- [ ] I have contained the problem: closed shared links, revoked tokens, disabled integrations, changed passwords.
- [ ] I have not deleted anything that could be evidence.
- [ ] I have limited who knows to those who need to.

FIRST DAY

- [ ] I know what data was involved and which people are affected.
- [ ] I know who had access and for how long.
- [ ] I have preserved logs, screenshots, links and emails.
- [ ] I have contacted the provider where appropriate.

- [ ] I have assessed the likely risk to people and written down my reasoning.
- [ ] I have taken advice if the data is sensitive or many people are affected.

DAYS TWO AND THREE

- [ ] I have decided whether to notify the supervisory authority and recorded why.
- [ ] I have decided whether to tell affected individuals and recorded why.
- [ ] I have told clients or partners where contracts require.
- [ ] I have recorded any notification made, with the date and time.
- [ ] I have fixed the cause and tested the fix.

TEMPLATE

AI incident log

Keep the original, even if you decide not to notify. Not legal advice.

Reference, date and time reported, and by whom

Date and time we became aware (starts the 72-hour period)

What happened, in plain words

Tool, account and systems involved

Types of personal data and special categories

Approximate number of people and records

Likely consequences for individuals

Containment steps and times

Risk assessment and reasoning

Decision on authority notification, with time

Decision on informing individuals, with time

Follow-up actions, owners and dates

AI-Related Data Breach Decision Checklist

A thinking aid for triage. It does not decide the law for you.

1	**Did the incident involve personal data?**	**YES** Go to question 2.	**NO** Probably not a personal data breach. Still record it and check contractual duties.
2	**Was personal data lost, destroyed, altered, disclosed or accessed without authority?**	**YES** Treat it as a personal data breach and go to question 3.	**NO** Probably authorised processing. Record why.
3	**Is a risk to individuals unlikely? (Consider data type, sensitivity, number of people, ease of identification, severity of harm)**	**YES** Document the breach and your reasoning. Authority notification is not required.	**NO** Notify the supervisory authority without undue delay and, where feasible, within 72 hours of becoming aware. Go to question 4.
4	**Is the breach likely to result in a high risk to individuals?**	**YES** Tell the individuals without undue delay, in clear language, unless an Article 34(3) exception applies.	**NO** Document why high risk is not likely. Keep the notification record.

Figure 43 Is this an AI-related personal data breach, and who must be told?

FACTS TO ESTABLISH

- ☐ When did we become aware, with a reasonable degree of certainty that personal data was compromised?
- ☐ Which categories of data, and are any special-category?
- ☐ How many people and records?
- ☐ Was the data encrypted or otherwise unintelligible to the recipient?
- ☐ Who received or accessed it, and can we get written confirmation of deletion?

- [ ] What consequences are likely: fraud, discrimination, distress, loss of confidentiality, employment harm?
- [ ] Do contracts with clients or partners require us to notify them?
- [ ] Are we a processor? If so, we must tell the controller without undue delay.

DPIA Screening Questionnaire

Two or more yes answers usually mean you should consider a full DPIA.

DPIA SCREENING

Criterion	Question	Yes or no, with notes
1. Evaluation or scoring	Does the use evaluate, score or predict aspects of people, such as performance, behaviour, interests or reliability?	
2. Automated decisions	Does it make, or heavily influence, decisions with legal or similarly significant effects?	
3. Systematic monitoring	Does it systematically monitor people, for example staff activity, location or communications?	
4. Sensitive data	Does it use special-category data, criminal data or data of a highly personal nature?	
5. Large scale	Does it involve many people, a large volume of data, a wide area or a long period?	
6. Matching or combining	Does it combine datasets from different sources or purposes in ways people would not expect?	
7. Vulnerable people	Does it involve employees, candidates, children, patients or others in a weaker position?	
8. New technology	Does it use new or innovative technology in a way that may have unclear risks?	
9. Prevents rights or services	Could it prevent people from exercising a right or using a service or contract?	

Criterion	Question	Yes or no, with notes
Result	Count the yes answers. Two or more usually points to a DPIA. One may still need one. Record your decision, and take advice if unsure.	

AI Privacy Notice Review Checklist

Compare what your notice says with what you actually do.

AI PRIVACY NOTICE REVIEW

- ☐ The notice names the business and gives contact details, including a privacy contact.
- ☐ It describes each purpose where AI processes personal data and the lawful basis.
- ☐ It names the categories of recipients, including AI providers acting as processors.
- ☐ It says whether data is transferred outside the EEA and the safeguard used.
- ☐ It states retention periods or the criteria used to set them.
- ☐ It explains people's rights, including access, erasure, objection and complaint to the authority.
- ☐ Where profiling or automated decisions apply, it explains the logic, significance and consequences in plain terms.
- ☐ It tells people when they are talking to an AI system or when AI recordings are made.
- ☐ It is written in clear, plain language and is easy to find.
- ☐ It was reviewed on [date] and matches our inventory.

Monthly AI Governance Review

Thirty minutes, once a month. Date it and keep it.

MONTHLY REVIEW

- [ ] Any new AI tools, extensions or features since last month?
- [ ] Has any provider changed terms, settings, plans or sub-processors?
- [ ] Are all approved tools still used for the approved purposes?
- [ ] Any new connections to company systems? Permissions still minimal?
- [ ] Any incidents or near misses? Logged and learned from?
- [ ] Any rights requests involving AI tools? Answered in time?
- [ ] Any staff joined or left? Access updated?
- [ ] Any AI use that profiles or evaluates people? Reviewed?
- [ ] Is the training log current?
- [ ] Are open actions on track?

TEMPLATE

Monthly review record

Date and sign off each review.

Review date and reviewer

New tools or changes found

Incidents and near misses

Decisions taken

Actions, owners and due dates

Small Business AI Privacy Maturity Scorecard

Score each area from 0 to 5 and see where to focus.

Score each area: **0** nothing in place, **1** informal or in one person's head, **2** some of it written, **3** written and in use, **4** written, in use and reviewed, **5** written, in use, reviewed and tested.

AREA	YOUR SCORE	OUT OF
1. Inventory of AI tools and uses		5
2. Data classification and never-paste rules		5
3. Vendor assessment and contracts		5
4. Policy and training		5
5. Lawful basis, notices and transparency		5
6. Human review and decisions about people		5
7. Security of accounts and connections		5
8. Incident response and rights requests		5
TOTAL SCORE		**40**

0 to 15	16 to 28	29 to 40
Early stage	**Developing**	**Established**
Start with the 30-day plan and do the urgent tasks first.	You have foundations. Close the gaps in your two lowest areas.	Keep evidence current, test your routines and review each year.

Figure 44 Reading your total (out of 40)

30-Day AI Privacy Implementation Tracker

Tick each day as you complete it. The plan is in Chapter 14.

DAY 01 ☐	DAY 02 ☐	DAY 03 ☐	DAY 04 ☐	DAY 05 ☐	DAY 06 ☐
DAY 07 ☐	DAY 08 ☐	DAY 09 ☐	DAY 10 ☐	DAY 11 ☐	DAY 12 ☐
DAY 13 ☐	DAY 14 ☐	DAY 15 ☐	DAY 16 ☐	DAY 17 ☐	DAY 18 ☐
DAY 19 ☐	DAY 20 ☐	DAY 21 ☐	DAY 22 ☐	DAY 23 ☐	DAY 24 ☐
DAY 25 ☐	DAY 26 ☐	DAY 27 ☐	DAY 28 ☐	DAY 29 ☐	DAY 30 ☐

Glossary of Essential Terms

Plain-English meanings of the terms used in this book.

AI literacy	The skills and understanding people need to use AI systems sensibly. The AI Act requires providers and deployers to take measures to support it (Article 4).
AI system	A machine-based system that infers from input how to generate outputs such as predictions, content, recommendations or decisions. The AI Act defines it in Article 3.
Anonymisation	Making data so that people can no longer be identified by any means reasonably likely to be used. A high bar. Data that can be linked back is not anonymous.
Article 22	The GDPR provision on solely automated decisions with legal or similarly significant effects.
Automated decision-making	A decision made by technology without meaningful human involvement.
Controller	The organisation that decides why and how personal data is processed (GDPR Article 4(7)).

Data minimisation	Using only the personal data that is adequate, relevant and limited to what is necessary.
Data processing agreement (DPA)	The contract between a controller and a processor required by GDPR Article 28.
Data protection impact assessment (DPIA)	A structured assessment of risks to people from high-risk processing (Article 35).
Data subject	A person whose personal data is processed.
Deployer	Under the AI Act, an organisation that uses an AI system under its authority, other than for personal non-professional use.
EDPB	European Data Protection Board, which brings together EU supervisory authorities and issues guidelines.
ENISA	The European Union Agency for Cybersecurity.
EEA	European Economic Area: the EU Member States plus Iceland, Liechtenstein and Norway.
GDPR	General Data Protection Regulation, Regulation (EU) 2016/679.
High-risk AI system	An AI system classified as high-risk under Article 6 and Annexes I and III of the AI Act, subject to stricter requirements.
Human review	A person with the knowledge and authority to change the outcome examines an AI output or decision.
Lawful basis	One of the six grounds in GDPR Article 6(1) that make processing lawful.
Legitimate interests	A lawful basis requiring a legitimate interest, necessity and a balance against people's rights.
Model training	Using data to build or improve an AI model.
Multifactor authentication (MFA)	Proving who you are with two or more factors, such as a password and a code from an app.
Personal data	Information relating to an identified or identifiable person (Article 4(1)).
Personal data breach	A breach of security leading to accidental or unlawful destruction, loss, alteration, unauthorised disclosure of or access to personal data (Article 4(12)).
Processor	An organisation that processes personal data on behalf of a controller (Article 4(8)).
Profiling	Automated processing of personal data to evaluate personal aspects of a person (Article 4(4)).
Prompt injection	Hidden or malicious instructions in content that an AI tool reads, causing unintended behaviour.

Provider	Under the AI Act, an organisation that develops an AI system and places it on the market or puts it into service under its own name.
Pseudonymisation	Processing data so it cannot be attributed to a person without additional information kept separately. Pseudonymised data is still personal data.
Retention	How long data is kept.
Shadow AI	AI tools or features used for work without the knowledge or approval of the business.
Special-category data	Data revealing racial or ethnic origin, political opinions, religious beliefs, union membership, genetic or biometric data for identification, health, or sex life or orientation (Article 9).
Sub-processor	A further processor engaged by a processor.
Supervisory authority	The national body that enforces data protection law.
Transfer (international)	Sending personal data outside the EEA, which needs a mechanism under GDPR Chapter V.

Sources

Numbered sources used in the text. Legal research cut-off: 25 October 2026.

SOURCE NOTE **How to read these sources**

Binding law is cited by instrument. **Regulatory guidance** (EDPB, Commission, ENISA, national authorities) is not itself binding law. **Industry standards and frameworks** are good practice, not obligations. The last column says how each source was checked for this edition. **Read** means the text was opened and read on 25 October 2026. **Search only** means a web search found consistent descriptions but the primary document was not opened. **Working knowledge** means stable text that was cited from the author's knowledge and not re-read in full for this edition. Anything marked Search only or Working knowledge should be verified against the primary source before publication or reliance. Sources [10], [13], [21], [23], [30] and [34] are further reading and are not cited by number in the text. No provider-specific terms are cited, because they change often.

Sources

No.	Source	Where to find it	Type and check
[1]	Regulation (EU) 2016/679 (General Data Protection Regulation), cited by article	https://eur-lex.europa.eu/eli/reg/2016/679/oj	Binding law. Working knowledge; verify article wording on EUR-Lex
[2]	Regulation (EU) 2024/1689 (Artificial Intelligence Act), Articles 2, 4, 5, 6, 25, 26, 27, 50, 86, 99, 111, 113 and Annexes I and III	https://eur-lex.europa.eu/eli/reg/2024/1689/oj	Binding law. Working knowledge, except where amended by [3], which was read
[3]	Regulation (EU) 2026/1744 of 8 July 2026 amending Regulations (EU) 2024/1689, (EU) 2018/1139 and (EU) 2023/1230 as regards the simplification of the implementation of harmonised rules on AI (Digital Omnibus on AI), OJ L, 2026/1744, 24.7.2026	https://eur-lex.europa.eu/eli/reg/2026/1744/oj	Binding law. Read on EUR-Lex, 25 October 2026: Article 4 as replaced, Article 5(1)(ba), (bb), (1a), (1b), Article 99 amendments, Article 111, Article 113 dates
[4]	Directive 2002/58/EC (ePrivacy Directive), Articles 5(3) and 13, as implemented in national law	https://eur-lex.europa.eu/eli/dir/2002/58/oj	Binding law. Working knowledge; check national transposition
[5]	Directive (EU) 2022/2555 (NIS2)	https://eur-lex.europa.eu/eli/dir/2022/2555/oj	Binding law. Working knowledge; scope depends on national transposition
[6]	EDPB, Guidelines 07/2020 on the concepts of controller and processor in the GDPR	https://www.edpb.europa.eu/ (Our work and tools, Guidelines)	Regulatory guidance. Working knowledge
[7]	EDPB, Guidelines 9/2022 on personal data breach notification under GDPR, version 2.0, adopted 4 April 2023	https://www.edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-92022-personal-data-breach-notification-under_en	Regulatory guidance. Working knowledge; the "reasonable degree of certainty" test should be re-checked in the text
[8]	EDPB, Guidelines 01/2021 on examples regarding personal data breach notification	https://www.edpb.europa.eu/ (Guidelines)	Regulatory guidance. Working knowledge
[9]	Article 29 Working Party, Guidelines on Data Protection Impact Assessment (WP248 rev.01), endorsed by the EDPB	https://ec.europa.eu/newsroom/article29/items/611236	Regulatory guidance. Working knowledge

No.	Source	Where to find it	Type and check
[10]	EDPB, Guidelines 4/2019 on Article 25 data protection by design and by default	https://www.edpb.europa.eu / (Guidelines)	Regulatory guidance. Working knowledge
[11]	EDPB, Opinion 28/2024 on certain data protection aspects related to the processing of personal data in the context of AI models, adopted 17 December 2024	https://www.edpb.europa.eu / (Opinions)	Regulatory guidance. Search only (summaries); read the opinion before relying on wording
[12]	EDPB, Guidelines 01/2022 on data subject rights: right of access	https://www.edpb.europa.eu / (Guidelines)	Regulatory guidance. Working knowledge
[13]	EDPB, Guidelines 05/2020 on consent under Regulation 2016/679	https://www.edpb.europa.eu / (Guidelines)	Regulatory guidance. Working knowledge
[14]	Article 29 Working Party, Guidelines on automated individual decision-making and profiling (WP251 rev.01), endorsed by the EDPB	https://ec.europa.eu/newsroom/article29/items/612053	Regulatory guidance. Working knowledge
[15]	Article 29 Working Party, Opinion 2/2017 on data processing at work (WP249)	https://ec.europa.eu/newsroom/article29/items/610169	Regulatory guidance. Working knowledge
[16]	EDPB, Recommendations 01/2020 on supplementary measures; CJEU, Case C-311/18 (Schrems II)	https://www.edpb.europa.eu / and https://curia.europa.eu	Guidance and case law. Working knowledge
[17]	Commission Implementing Decision (EU) 2021/914 on standard contractual clauses	https://eur-lex.europa.eu/eli/dec_impl/2021/914/oj	Binding law. Working knowledge
[18]	Commission Implementing Decision (EU) 2023/1795 (EU-US Data Privacy Framework); General Court, Case T-553/23, Latombe v Commission (3 September 2025); appeal Case C-703/25 P reported as pending	https://eur-lex.europa.eu/eli/dec_impl/2023/1795/oj and https://curia.europa.eu	Binding law and case law. Appeal status Search only; verify on the Court's register

No.	Source	Where to find it	Type and check
[19]	ENISA, Cybersecurity guide for SMEs: 12 steps to securing your business (2021)	https://www.enisa.europa.eu / (publications)	Voluntary guidance. Existence confirmed by search; content working knowledge
[20]	OWASP, Top 10 for Large Language Model Applications	https://genai.owasp.org/	Voluntary guidance. Working knowledge; check the current list
[21]	NIST, AI Risk Management Framework 1.0 (NIST AI 100-1)	https://www.nist.gov/itl/ai-risk-management-framework	Voluntary framework. Working knowledge; reading suggestion only
[22]	NIST, Cybersecurity Framework (CSF) 2.0	https://www.nist.gov/cyberframework	Voluntary framework. Working knowledge
[23]	ISO/IEC 42001:2023, Artificial intelligence management systems	https://www.iso.org/	Voluntary standard. Working knowledge; reading suggestion only
[24]	ISO/IEC 27001, Information security management systems	https://www.iso.org/	Voluntary standard. Working knowledge
[25]	CJEU, Case C-634/21, SCHUFA Holding (Scoring), 7 December 2023	https://curia.europa.eu	Case law. Working knowledge; verify
[26]	CJEU, Case C-203/22, Dun & Bradstreet Austria, 27 February 2025, on explaining the logic of automated decisions	https://curia.europa.eu	Case law. Working knowledge; verify
[27]	CJEU, Case C-300/21, UI v Österreichische Post, 4 May 2023: no minimum seriousness threshold for non-material damage	https://curia.europa.eu	Case law. Working knowledge; verify
[28]	CJEU, Case C-340/21, Natsionalna agentsia za prihodite, 14 December 2023: fear of misuse can be non-material damage	https://curia.europa.eu	Case law. Working knowledge; verify

No.	Source	Where to find it	Type and check
[29]	CJEU, Case C-807/21, Deutsche Wohnen, 5 December 2023: fines require intentional or negligent infringement; concept of undertaking	https://curia.europa.eu	Case law. Working knowledge; verify
[30]	CJEU, Case C-413/23 P, EDPS v SRB, 4 September 2025, on pseudonymised data	https://curia.europa.eu	Case law. Working knowledge; verify (not relied on in the text beyond the general warning that pseudonymised data can remain personal data)
[31]	Directive (EU) 2016/943 on the protection of trade secrets	https://eur-lex.europa.eu/eli/dir/2016/943/oj	Binding law. Working knowledge
[32]	European Commission, AI Act pages and guidelines on prohibited AI practices (February 2025), including AI literacy materials	https://digital-strategy.ec.europa.eu/en/policies/regulatory-framework-ai	Regulatory guidance. Working knowledge; check current versions and any guidelines on high-risk classification
[33]	EDPB, list of national supervisory authorities; Croatia: Agency for the Protection of Personal Data (AZOP), page on reporting breaches	https://www.edpb.europa.eu/about-edpb/about-edpb/members_en and https://azop.hr/	National authorities. Page existence only; form contents not confirmed
[34]	GDPRGard (publisher's associated resource)	https://gdprgard.eu/	Publisher resource. Not independently evaluated
[35]	CJEU, Case C-184/20, OT v Vyriausioji tarnybinės etikos komisija, 1 August 2022, on data that indirectly reveal sensitive information	https://curia.europa.eu	Case law. Working knowledge; verify

WATCH OUT **What to verify before relying on this edition**

1. The Digital Omnibus proposals on the GDPR and ePrivacy (procedure 2025/0360(COD)) were, according to commentary found on 25 October 2026, at the stage of a Council negotiating mandate with Parliament's position unconfirmed. Check the European Parliament Legislative Observatory. **2.** The appeal in Case C-703/25 P on the EU-US framework. **3.** Any Commission guidelines on high-risk classification and transparency under the AI Act. **4.** Each GDPR article and CJEU judgment against the official text. **5.** The terms of every AI provider you use, as they stand on the day you read them. **6.** National rules on employment, recording of conversations, breach reporting and direct marketing in your country.

About the Author and GDPRGard

Zirlandia Milkovic and GDPRGard.

Zirlandia Milkovic writes practical guides that help small businesses understand data protection, cybersecurity and responsible AI use, and turn them into everyday habits. She wrote *The Hidden Cost of AI* for the owners, freelancers and small teams who have to adopt AI tools without a legal or compliance department behind them.

GDPRGard is an AI compliance suite for European small and medium-sized businesses: a resource for those exploring GDPR compliance and responsible AI adoption, with education, tools and templates at https://gdprgard.eu/. This book is an independent educational publication. Neither the book, the author nor GDPRGard has been endorsed, certified or approved by any regulator or supervisory authority.

This book is educational and is not legal advice. For decisions with real consequences, consult a qualified professional.



Use AI.
Keep control.
Protect the people behind the data.

ZIRLANDIA MILKOVIC